Tema 35 · Bloque II | 60 preguntas de test

Internet: arquitectura de red

Origen, evolución y estado actual · Gobernanza y RFC · Pila TCP/IP · Sistemas autónomos, BGP e IXP · IPv4, IPv6 y DNS · Correo, FTP, SSH y DHCP · HTTP/1.1, HTTP/2 y HTTP/3 · SSL/TLS y HTTPS · ENS y sede electrónica

Enunciado oficial del programa (BOAM n.º 10.032, de 23 de diciembre de 2025): Internet: arquitectura de red. Origen, evolución y estado actual. Principales servicios. Protocolos HTTP, HTTPS y SSL/TLS.

EXTENSIÓN
~20.500 palabras · 18 diagramas · 60 preguntas de test

TIEMPO ESTIMADO DE ESTUDIO
19–21 horas (primera vuelta completa, sin contar repasos)

Índice

- [ ] **1. Origen, evolución y estado actual de Internet**
  - [ ] **1.1. Origen e historia de Internet**
  - [ ] **1.2. Gobernanza de Internet y estandarización**
- [ ] **2. Arquitectura de red de Internet**
  - [ ] **2.1. Modelo de comunicación TCP/IP**
  - [ ] **2.2. Infraestructura y direccionamiento**
- [ ] **3. Principales servicios de Internet**
  - [ ] **3.1. Servicios de la capa de aplicación**
  - [ ] **3.2. Servicios de gestión y red**
- [ ] **4. Protocolo HTTP**
  - [ ] **4.1. Fundamentos y versiones del protocolo HTTP**
  - [ ] **4.2. Mensajes HTTP y mecanismos de estado**
- [ ] **5. Protocolos SSL/TLS y HTTPS**
  - [ ] **5.1. Protocolos de seguridad SSL y TLS**
  - [ ] **5.2. Protocolo HTTPS**
- [ ] **6. Seguridad y normativa en la Administración Pública**
  - [ ] **6.1. Requisitos de seguridad en servicios web públicos**
- [ ] **Los siete datos que no se pueden fallar**

Conceptos clave para memorizar

Concepto	Dato clave
Fechas fundacionales	**1969**: primeros cuatro nodos de ARPANET (UCLA, SRI, UCSB, Utah). **1974**: artículo de **Cerf y Kahn** con el protocolo TCP. **1-1-1983**: *flag day* — ARPANET abandona NCP y adopta **TCP/IP**; es la fecha de nacimiento de Internet tal como se entiende hoy. **1989-1991**: **Berners-Lee** propone y publica la **World Wide Web** en el **CERN**. **1993**: navegador **Mosaic**. **30-4-1993**: el CERN libera la Web al dominio público
Internet ≠ Web	**Internet** es la infraestructura (red de redes con TCP/IP); la **Web** es **un servicio más** que se ejecuta sobre ella, junto al correo, DNS, FTP o SSH. Confundirlas es el error conceptual más penalizado del tema
Gobernanza: quién hace qué	**ICANN** (con la **IANA**, operada desde 2016 por la **PTI**) gestiona identificadores únicos: nombres, números y parámetros de protocolo. **IETF** elabora los estándares (RFC). **IAB** supervisa la arquitectura; **IRTF**, la investigación. **ISOC** es el paraguas institucional. **W3C** estandariza la **Web** (HTML, CSS), **no** Internet. **IEEE** normaliza las capas físicas (802.3, 802.11)
Transición IANA	El contrato del Departamento de Comercio de EE. UU. sobre las funciones IANA **expiró el 30-9-2016**; desde el **1-10-2016** las ejerce **PTI**, filial de ICANN, bajo modelo de **múltiples partes interesadas** (*multistakeholder*)
Los cinco RIR	**ARIN** (Norteamérica) · **RIPE NCC** (Europa, Oriente Medio y Asia Central) · **APNIC** (Asia-Pacífico) · **LACNIC** (Latinoamérica y Caribe) · **AFRINIC** (África). España pertenece a **RIPE NCC**. Reparten direcciones a los **LIR** (operadores)
Serie RFC	Publica el **RFC Editor**. Un documento nace como **Internet-Draft** (caduca a los **6 meses**), y si prospera se publica como RFC con **número inmutable**: no se modifica, se **obsoleta** (*obsoletes*) o se **actualiza** (*updates*). Categorías: *Standards Track* (**Proposed Standard → Internet Standard**, con serie **STD**), *Informational*, *Experimental*, *Historic* y *Best Current Practice* (**BCP**)
Pila TCP/IP	**Cuatro** capas: **acceso a red / enlace**, **internet**, **transporte** y **aplicación**. OSI tiene **siete**. Correspondencia: la capa de aplicación de TCP/IP absorbe **aplicación + presentación + sesión** de OSI; la de acceso a red, **enlace + física**
PDU por capa	Aplicación → **mensaje** · Transporte → **segmento** (TCP) o **datagrama** (UDP) · Internet → **paquete** o datagrama IP · Enlace → **trama** · Física → **bit**
TCP vs UDP	**TCP**: orientado a conexión (**saludo en tres pasos**: SYN, SYN-ACK, ACK), fiable, ordenado, con control de flujo y congestión. **UDP**: sin conexión, sin garantías,

Concepto	Dato clave
	cabecera de 8 bytes frente a los **20** mínimos de TCP. HTTP/3 corre sobre **UDP** porque QUIC reimplementa la fiabilidad en espacio de usuario
Sistema Autónomo (AS)	Conjunto de redes con una **política de encaminamiento única** bajo una administración común, identificado por un **ASN** de **32 bits** (antes 16). El protocolo que los une es **BGP-4** (RFC 4271), **TCP/179**, único protocolo de encaminamiento **exterior** de Internet. Hay ≈ **80.000 AS** activos
Tránsito, *peering* e IXP	**Tránsito**: se paga a un operador superior para llegar a *todo* Internet. **Peering**: intercambio directo, normalmente **sin coste**, solo del tráfico propio y de los clientes de ambos. Un **IXP** (punto neutro) es la infraestructura donde ese intercambio se hace masivamente: en España, **ESPANIX** y **DE-CIX Madrid**
Agotamiento de IPv4	**IANA** agotó su reserva libre el **3-2-2011**; **RIPE NCC** entró en fase de agotamiento el **25-11-2019**. Paliativos: **CIDR** (RFC 4632), **direccionamiento privado** (RFC 1918: 10/8, 172.16/12, 192.168/16), **NAT/PAT** y **CGNAT** (RFC 6598: 100.64.0.0/10). Ninguno resuelve el problema: solo lo aplaza
IPv4 vs IPv6	**IPv4**: 32 bits, ≈ 4.294 millones de direcciones, notación decimal con puntos, cabecera **variable (20-60 bytes)**, con suma de control. **IPv6** (RFC 8200): **128 bits**, notación hexadecimal con dos puntos, cabecera **fija de 40 bytes**, **sin suma de control**, **sin fragmentación en tránsito** (la hace el origen), **sin difusión** (*broadcast*): usa **multidifusión** y **anycast**. Prefijo estándar de subred: **/64**
Mecanismos de transición	**Doble pila** (*dual stack*, el recomendado) · **túneles** (6in4, 6to4, Teredo, GRE) · **traducción** (NAT64/DNS64, 464XLAT). **Nunca** hay traducción directa IPv4↔IPv6 sin pasarela: son protocolos **incompatibles**
DNS: jerarquía	**Raíz** (`.`) → **TLD** (gTLD, ccTLD como `.es`) → dominio de segundo nivel → subdominios. **13 identidades** de servidor raíz (A-M) sobre **más de 2.000 instancias** con **anycast**. Puerto **53** (UDP para consultas, **TCP** para respuestas grandes y transferencias de zona **AXFR**)
Resolución DNS	El cliente hace una consulta **recursiva** al resolutor; el resolutor hace consultas **iterativas** a raíz, TLD y servidor autoritativo. Registros: **A** (IPv4), **AAAA** (IPv6), **CNAME** (alias), **MX** (correo), **NS**, **PTR** (inverso), **TXT**, **SOA**, **SRV**, **CAA** (qué AC puede emitir certificados)

Concepto	Dato clave
Seguridad del DNS	**DNSSEC** (RFC 4033-4035) **firma** las respuestas: aporta **autenticidad e integridad**, **no confidencialidad**. **DoT** (RFC 7858, **TCP/853**) y **DoH** (RFC 8484, **HTTPS/443**) cifran la consulta: aportan **confidencialidad**, no autenticidad de la zona. Son complementarios, no alternativos
Correo: puertos	**SMTP** entre servidores: **25**. **Envío desde el cliente** (*submission*): **587** con STARTTLS o **465** con TLS implícito. **POP3**: 110 · **POP3S**: 995. **IMAP**: 143 · **IMAPS**: 993. El **RFC 8314** desaconseja el texto en claro y recomienda **TLS implícito**
Autenticación del remitente	**SPF** (RFC 7208, registro TXT con los emisores autorizados) · **DKIM** (RFC 6376, **firma criptográfica** de la cabecera y el cuerpo) · **DMARC** (política de alineamiento y de informes; reeditado en **mayo de 2026** por los **RFC 9989, 9990 y 9991**, que obsoletan el RFC 7489)
FTP	**RFC 959**, dos canales: **control TCP/21** y **datos TCP/20**. **Modo activo**: el servidor abre la conexión de datos hacia el cliente (lo bloquean los cortafuegos). **Modo pasivo**: la abre el cliente. **FTPS** = FTP sobre TLS; **SFTP** = subsistema de **SSH** (puerto **22**), no tiene nada que ver con FTP
SSH	**Puerto 22**, RFC 4251-4254. Tres capas: **transporte** (cifrado e integridad), **autenticación** y **conexión** (canales multiplexados). Sustituye a **Telnet (23)**, `rlogin` y `rsh`, que van en claro. Permite **túneles** y reenvío de puertos
DHCP	**RFC 2131**, puertos **UDP 67** (servidor) y **68** (cliente). Intercambio **DORA**: *Discover* → *Offer* → *Request* → *Acknowledge*. En IPv6 conviven **SLAAC** (autoconfiguración sin estado) y **DHCPv6** (**UDP 546/547**), reeditado en enero de 2026 como **RFC 9915 (STD 102)**
HTTP: naturaleza	Protocolo de **capa de aplicación**, **cliente-servidor**, **sin estado** (*stateless*) y **sin conexión** en su semántica. Puerto **80**; sobre TLS, **443**. La especificación vigente está en los **RFC 9110-9112** (junio de 2022, **STD 97, 98 y 99**), que sustituyen a los RFC 723x y al RFC 2616
Versiones de HTTP	**0.9** (1991, solo `GET`) · **1.0** (RFC 1945, 1996) · **1.1** (1997; **conexiones persistentes**, `Host` obligatorio, *pipelining*) · **2** (RFC 9113: **binario**, **multiplexado**, **HPACK**, *server push*) · **3** (RFC 9114: sobre **QUIC/UDP**, cifrado obligatorio, **QPACK**, elimina el bloqueo de cabecera de línea del transporte)
Métodos HTTP	**Seguros** (no modifican): `GET`, `HEAD`, `OPTIONS`, `TRACE`. **Idempotentes** (repetirlos da el mismo resultado): los seguros más `PUT` y `DELETE`. **`POST` no es ni seguro ni idempotente**; **`PATCH` tampoco es idempotente**

Concepto	Dato clave
Códigos de estado	**1xx** informativo · **2xx** éxito (200 OK, 201 Created, 204 No Content) · **3xx** redirección (**301** permanente, **302/307** temporal, **304** no modificado) · **4xx** error del **cliente** (400, **401** no autenticado, **403** no autorizado, 404, 429) · **5xx** error del **servidor** (500, 502, **503** no disponible, 504)
Cookies	**RFC 6265**. Cabecera `Set-Cookie` del servidor y `Cookie` del cliente. Atributos de seguridad: `Secure` (solo por HTTPS), `HttpOnly` (invisible para JavaScript, mitiga XSS), `SameSite` (mitiga CSRF) y `Expires` / `Max-Age` (de sesión frente a persistente)
SSL vs TLS	**SSL** es el nombre histórico de Netscape (1994-1996); **TLS** es su continuación en el IETF desde **1999**. **SSL 2.0 y 3.0 están prohibidos** (RFC 6176 y **RFC 7568**); **TLS 1.0 y 1.1**, declarados obsoletos por el **RFC 8996** (2021). Vigentes: **TLS 1.2 y TLS 1.3**
TLS 1.3 hoy	Publicado en **2018** como RFC 8446 y **reeditado en julio de 2026 como RFC 9846**, que **obsoleta tanto el RFC 8446 como el RFC 5246** (TLS 1.2) y unifica la especificación. Novedades de la versión 1.3: saludo en **1-RTT** (0-RTT en reanudación), **confidencialidad directa obligatoria**, solo cifrado **AEAD**, sin RSA estático, sin renegociación y sin compresión
Subprotocolos TLS	**Record** (el que transporta a todos los demás y aplica el cifrado) más **Handshake**, **Alert**, **Change Cipher Spec** (residual en 1.3, solo por compatibilidad con equipos intermedios) y los **datos de aplicación**
Certificados y revocación	**X.509 v3** (RFC 5280), emitido por una **AC**; validación por **cadena de confianza** hasta una raíz del almacén del navegador. Revocación por **CRL** o por **OCSP** (RFC 6960). Tendencia dominante: **certificados de vida corta**. Calendario del **CA/Browser Forum (SC-081v3)**: máximo **200 días desde el 15-3-2026**, **100 días desde el 15-3-2027** y **47 días desde el 15-3-2029**
HTTPS	No es un protocolo nuevo: es **HTTP transportado sobre TLS** en el puerto **443**. Orden correcto: **TCP → TLS → HTTP**. Protege el **cuerpo**, las **cabeceras**, las **cookies** y la **ruta** de la URL; **no oculta** la dirección IP de destino ni, salvo con ECH, el nombre del servidor en la extensión **SNI**
Refuerzos de HTTPS	**HSTS** (RFC 6797) obliga al navegador a usar siempre HTTPS · **CAA** limita qué AC puede emitir para el dominio · **CT** (transparencia de certificados) publica lo emitido en registros auditables · **ECH** cifra el nombre del servidor en el saludo
Servicios web en el ENS	`mp.s.2` **— Protección de servicios y aplicaciones web**, exigible en las **tres categorías** con **[R1 o R2]** (auditorías de caja negra o de caja blanca) desde la

Concepto	Dato clave
	BÁSICA, y **+R2+R3** en la ALTA. `mp.com.2` protege la **confidencialidad** del canal y `mp.com.3` su **integridad y autenticidad**; `mp.s.4` cubre la **denegación de servicio** (desde nivel MEDIO de disponibilidad)
Sede electrónica	Regulada en el **art. 38 de la Ley 40/2015** y desarrollada por el **RD 203/2021**: titularidad, gestión y administración corresponden a una **Administración concreta**, y sus comunicaciones deben realizarse **mediante certificado de sede electrónica** que garantice identificación y comunicación segura. La del Ayuntamiento de Madrid es `sede.madrid.es`

Contenido

Convenciones del documento

Este tema incluye cuatro tipos de **cajas callout** para facilitar el estudio:

> **DATO CLAVE**
> Información de alta densidad memorística: fechas, puertos, números de RFC, siglas y umbrales.

> **EJERCICIO RESUELTO**
> Problema + solución paso a paso: leer una traza, interpretar un código de estado, decidir un mecanismo de transición, calcular la duración de un certificado.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
> Aplicación real de la teoría al entorno municipal (sede electrónica, portal `madrid.es`, correo corporativo, red del IAM).

> **RELACIÓN CON OTROS TEMAS**
> Enlace conceptual a otros temas del temario oficial.

Advertencia de frontera, y es la más importante de este tema. El enunciado oficial del Tema 35 se solapa deliberadamente con el del **Tema 34** («El modelo TCP/IP y el modelo de referencia OSI de ISO. Protocolos TCP/IP»). El criterio que se ha seguido aquí, y que conviene que el alumno tenga presente al estudiar los dos, es el siguiente:

- **El Tema 34 explica los protocolos**: qué campos tiene una cabecera IP, cómo funciona el control de congestión de TCP, qué hace ARP o ICMP.
- **El Tema 35 explica cómo esos protocolos construyen *Internet*** como red de redes de alcance mundial: quién reparte las direcciones, cómo se encaminan los paquetes **entre operadores distintos** (sistemas autónomos, BGP, puntos neutros), cómo se traduce un nombre en una dirección y qué servicios se prestan encima.

Por eso aquí la pila TCP/IP se presenta como **marco de referencia** (§2.1) y no se desmenuza campo a campo, mientras que el **encaminamiento interdominio**, el **agotamiento de IPv4** y el **DNS** —que el Tema 34 apenas roza— se desarrollan a fondo. En la misma línea: la **seguridad perimetral, los cortafuegos y las VPN** son objeto del **Tema 36**; la **criptografía y la firma electrónica**, del **Tema 32**; los **principios del ENS y del ENI**, del **Tema 39**; y el **desarrollo de aplicaciones web y los navegadores**, del **Tema 23**. Aquí aparecen solo en la medida en que el

enunciado del Tema 35 los reclama: los protocolos HTTP, HTTPS y SSL/TLS, y los requisitos de seguridad de un servicio web público.

La segunda advertencia es de método. Este tema tiene **dos naturalezas mezcladas**. Una parte es **narrativa** (el origen y la evolución, la gobernanza), donde lo que importa son **fechas, siglas y competencias**. La otra es **técnica y muy exacta** (protocolos, puertos, versiones, códigos de estado), donde importa el **dato literal**. Ambas se aprueban con técnicas distintas: la primera con una línea del tiempo y un mapa de organismos; la segunda con tablas de puertos y de códigos. Quien estudie este tema «leyéndolo» sin fijar tablas, fallará.

Las fuentes se citan con etiquetas breves tipo `[RFC9110]`, `[ENS]` o `[ICANN]`; el registro completo está en la pestaña Fuentes. **Todos los números, títulos y fechas de RFC citados en este tema se han verificado contra el índice oficial del RFC Editor**, y las medidas del ENS, contra el PDF del BOE.

Caso de referencia usado en todo el tema (contexto Ayuntamiento de Madrid, supuesto simplificado): la **sede electrónica municipal**, `sede.madrid.es`, publicada en internet y accesible desde cualquier navegador. Ese único servicio concentra todas las materias del tema: necesita un **nombre de dominio** y un **DNS** que lo resuelva (§2), viaja por **HTTP** (§4), va protegido por **TLS** (§5), depende de los servicios de correo y de acceso remoto que lo sostienen (§3), se encamina por Internet entre **sistemas autónomos** distintos (§2) y está sujeto al **Esquema Nacional de Seguridad** (§6).

---

1. Origen, evolución y estado actual de Internet

1.1. Origen e historia de Internet

1.1.1. De ARPANET a la consolidación de la pila TCP/IP

Qué es Internet, con precisión. Internet es una **red de redes**: un conjunto mundial de redes de ordenadores heterogéneas, gestionadas por miles de organizaciones independientes, que se interconectan y se entienden entre sí porque todas hablan **la misma familia de protocolos, TCP/IP**. La definición oficial más citada es la que aprobó el **Federal Networking Council** de Estados Unidos el **24 de octubre de 1995** [FNC]: Internet es el sistema global de información que (a) está **lógicamente enlazado** por un espacio de direcciones único basado en el **protocolo IP**, (b) soporta comunicaciones usando **TCP/IP**, y (c) proporciona, usa o hace accesibles, de forma pública o privada, **servicios de alto nivel** construidos sobre esa infraestructura.

De esa definición se extraen las tres ideas que hay que retener: **espacio de direcciones único**, **protocolo común** y **servicios superpuestos**. Y de la tercera se deriva una distinción clave.

DATO CLAVE

Internet no es la Web. Internet es la **infraestructura** de comunicación (la red de redes con TCP/IP); la **World Wide Web** es **uno de los servicios** que se prestan sobre ella, junto con el correo electrónico, el DNS, la transferencia de archivos, el acceso remoto o la mensajería. La Web nació **veinte años después** que Internet. Toda pregunta que identifique ambas cosas es falsa.

Los orígenes: la conmutación de paquetes. Internet nace de una idea teórica de principios de los años sesenta: la **conmutación de paquetes**, formulada de forma independiente por **Paul Baran** en la RAND Corporation (1964) y por **Donald Davies** en el National Physical Laboratory británico —a quien se debe el propio término *packet*—. Frente a la **conmutación de circuitos** de la red telefónica, que reserva un camino físico completo durante toda la comunicación, la conmutación de paquetes trocea el mensaje en unidades pequeñas que viajan **independientemente**, comparten los enlaces con el tráfico de otros y se reensamblan en destino. Es más eficiente y, sobre todo, **más resistente**: si un nodo cae, los paquetes buscan otro camino.

También de esos años es el trabajo de **J. C. R. Licklider** en ARPA, que en 1962 describió una «red galáctica» de ordenadores interconectados, y de **Leonard Kleinrock**, cuyo análisis matemático de colas dio soporte teórico al reparto de paquetes.

ARPANET (1969). El proyecto lo financia la **ARPA** (*Advanced Research Projects Agency*, después **DARPA**) del Departamento de Defensa estadounidense. El **29 de octubre de 1969** se produce la primera transmisión entre dos nodos, y a final de ese año la red tiene **cuatro nodos**: la **UCLA** (Universidad de California en Los Ángeles), el **SRI** (Stanford Research Institute), la **UCSB** (Universidad de California en Santa Bárbara) y la **Universidad de Utah**. Los ordenadores no se conectaban directamente a la línea, sino a través de un equipo intermedio llamado **IMP** (*Interface Message Processor*), el antepasado del encaminador. El protocolo de aquella primera ARPANET era el **NCP** (*Network Control Program*), **no** TCP/IP.

DATO CLAVE

Es un mito extendido que ARPANET se diseñara «para resistir un ataque nuclear». El objetivo declarado fue **compartir recursos de computación escasos y caros** entre centros de investigación; la resistencia a fallos era una propiedad deseable de la conmutación de paquetes, no su finalidad política. Los propios protagonistas (Cerf, Kahn, Kleinrock) lo han desmentido por escrito.

1974: TCP. El problema siguiente fue interconectar redes **distintas** (ARPANET, redes por radio como PRNET, redes por satélite). A eso se le llamó el **problema del *internetworking***, y de ahí viene la palabra *Internet*. En **1974**, **Vinton Cerf** y **Robert Kahn** publican el artículo *A Protocol for Packet Network Intercommunication*, donde definen el **TCP** y establecen los principios de diseño que siguen vigentes:

- **Cada red conserva su autonomía**: no hay que modificarla para conectarla a Internet.
- **Comunicación de mejor esfuerzo** (*best effort*): si un paquete se pierde, se retransmite desde el origen.
- **Cajas negras de interconexión** (los futuros **encaminadores**), que no guardan información del estado de los flujos.
- **No hay control global** de la operación.

En **1978**, Cerf, Postel y Danny Cohen **parten TCP en dos**: **IP** se queda con el direccionamiento y el encaminamiento (sin garantías), y **TCP** con la fiabilidad extremo a extremo. Esa separación es el acto fundacional de la arquitectura actual y la razón de que UDP pueda existir.

1 de enero de 1983: el «día de la bandera». ARPANET **abandona NCP y adopta TCP/IP** de forma obligatoria en una única fecha (*flag day*). Es la fecha que se cita convencionalmente como **nacimiento de Internet**, porque a partir de ella existe una familia de protocolos común capaz de unir redes heterogéneas. Ese mismo año, ARPANET se escinde: la parte militar se separa como **MILNET**.

1983-1990: la infraestructura civil. En **1983-1984** se introduce el **DNS** (Paul Mockapetris, RFC 882/883, sustituidos en 1987 por los **RFC 1034 y 1035**), que reemplaza el fichero único `HOSTS.TXT` que hasta entonces mantenía a mano el **NIC** del SRI. En **1986** la **NSF** estadounidense crea **NSFNET**, la red troncal académica que sustituye progresivamente a ARPANET —**desmantelada formalmente en 1990**— y que en **1995** se privatiza, abriendo la red al tráfico comercial. En Europa, **RIPE** se constituye en **1989** para coordinar las redes IP europeas y **RedIRIS** (creada en 1988, hoy dependiente de Red.es) conecta a la comunidad académica española.

> RELACIÓN CON OTROS TEMAS
> La conmutación de paquetes frente a la de circuitos, los medios de transmisión y los equipos de conmutación se estudian en el **Tema 33** (Comunicaciones). El detalle interno de los protocolos TCP, UDP e IP corresponde al **Tema 34**.

1.1.2. Evolución de la World Wide Web y estado actual

El nacimiento de la Web (1989-1993). En **marzo de 1989**, **Tim Berners-Lee**, físico e informático del **CERN** (Organización Europea para la Investigación Nuclear), presenta el documento *Information Management: A Proposal* para resolver un problema doméstico: la información del laboratorio estaba dispersa en sistemas incompatibles y se perdía cuando los investigadores rotaban. Su propuesta combinaba tres invenciones que hoy siguen siendo el núcleo de la Web:

Componente	Qué es	Vigencia
HTML	Lenguaje de marcado para escribir los documentos e insertar enlaces	Vigente (HTML Living Standard, WHATWG/W3C)
URI/URL	Identificador uniforme que localiza cualquier recurso de forma global	Vigente (RFC 3986)
HTTP	Protocolo de transferencia entre el navegador y el servidor	Vigente (RFC 9110-9114)

En **1990** Berners-Lee escribe el primer servidor (`httpd`) y el primer navegador (`WorldWideWeb` , después renombrado `Nexus`) sobre una estación NeXT. El **6 de agosto de 1991** publica el proyecto en el grupo de noticias `alt.hypertext` : es la fecha en que la Web se hace pública. Y el **30 de abril de 1993** el CERN toma la decisión que lo cambia todo: **liberar el software de la Web al dominio público**, sin regalías. Ese mismo año aparece **Mosaic** (NCSA, Marc Andreessen), el primer navegador gráfico de uso masivo, del que derivará Netscape Navigator. En **octubre de 1994** Berners-Lee funda el **W3C**.

Las etapas de la Web. Es una clasificación de manual, útil para ordenar la evolución, aunque no sea una norma técnica:

- **Web 1.0** (≈1991-2003): **estática y de solo lectura**. Páginas HTML servidas tal cual, el usuario es un consumidor pasivo. Portales, directorios, primeros buscadores.
- **Web 2.0** (≈2004-2015): **social y de lectura-escritura**. El usuario **genera el contenido**: blogs, wikis, redes sociales, plataformas de vídeo. Técnicamente la habilitan **AJAX**, las API y el desarrollo en el lado del cliente. El término lo populariza Tim O'Reilly en 2004.
- **Web 3.0**: aquí hay que ser cuidadoso, porque **coexisten dos acepciones distintas** y es fácil confundirlas. La original de Berners-Lee es la **Web Semántica**: dar significado procesable por máquinas a los datos mediante **RDF**, **OWL** y **SPARQL** (estándares del W3C). La acepción posterior, **Web3**, se refiere a la web descentralizada sobre **cadenas de bloques**. **No son lo mismo.**
- **Estado actual**: predominio del acceso **móvil**, de las **redes de distribución de contenidos (CDN)**, del **cloud** y, desde 2023, de la **IA generativa** como capa de consumo de la información. Al mismo tiempo se ha producido una **reconcentración**: una parte enorme del tráfico termina en un número reducido de plataformas y de proveedores de nube, lo que tensiona el diseño distribuido original.

DATO CLAVE

Web 3.0 (Web Semántica) = datos con significado, RDF/OWL/SPARQL, propuesta del **W3C** y de **Berners-Lee**. **Web3** = descentralización sobre cadena de bloques, criptoactivos, contratos inteligentes. Si el enunciado habla de «significado procesable por máquinas», es la primera; si habla de «descentralización y cadena de bloques», es la segunda.

El estado actual en cifras. Estos datos son **volátiles por naturaleza**: se dan con fecha y hay que reverificarlos antes de cada convocatoria. Aun así, un opositor debe manejar los órdenes de magnitud.

Indicador	Valor	Fecha y fuente
Personas usuarias de Internet	**≈ 6.000 millones (74 %** de la población mundial)	2025, **ITU**, *Facts and Figures 2025*
Población sin conexión	**≈ 2.200 millones (26 %)**; el **96 %** vive en países de renta baja y media	2025, ITU
Brecha urbana/rural	**85 %** de la población urbana conectada frente al **58 %** rural	2025, ITU
Adopción de **IPv6** (medida por Google)	Supera por primera vez el **50 %** el **28 de marzo de 2026**	Google IPv6 Statistics
Adopción de IPv6 **en España**	≈ **10 %** — a la cola de Europa occidental	2026, Google / APNIC
Sistemas autónomos activos	≈ **80.000**	2026, CIDR Report
Prefijos en la tabla global de BGP	**> 1.000.000** en IPv4 y ≈ **250.000** en IPv6	2026, CIDR Report
Cargas de página cifradas con **HTTPS** en Chrome	**> 95 %** en escritorio y **> 97 %** en Android	2026, Google Transparency Report
Sitios que anuncian **HTTP/3**	≈ **39,5 %**	junio de 2026, W3Techs
Dominios `.es` registrados	**2.226.598**	6 de agosto de 2026, **Red.es**

DATO CLAVE

El **28 de marzo de 2026** la medición de Google registró por primera vez que **más de la mitad** de los accesos a sus servicios se hacían por **IPv6 nativo** (50,10 %). Es el hito que cierra dieciocho años de despliegue. **España, en cambio, está en torno al 10 %**, muy por detrás de Francia (≈73 %) o la India (≈72 %): es un contraste que conviene recordar, porque explica por qué en la Administración española la **doble pila** sigue siendo la regla y no la excepción.

EJEMPLO DE APLICACIÓN EN EL AYTO

El contraste anterior tiene una consecuencia directa en un ayuntamiento: un servicio municipal publicado **solo en IPv6** sería inaccesible para la mayoría de la ciudadanía española, mientras que uno publicado **solo en IPv4** ya empieza a penalizar a quien accede desde redes móviles con CGNAT. La respuesta correcta —y la que exige el ENI para los servicios públicos— es **publicar en doble pila**.

1.2. Gobernanza de Internet y estandarización

1.2.1. Organismos internacionales de regulación

La idea de fondo. Internet **no tiene un propietario ni una autoridad central**. Su gobierno se articula mediante un modelo de **múltiples partes interesadas** (*multistakeholder*): gobiernos, sector privado, comunidad técnica y sociedad civil participan en organismos abiertos que **coordinan** lo estrictamente necesario. Y lo estrictamente necesario son dos cosas: que **los identificadores sean únicos** (dos máquinas no pueden tener la misma dirección, ni dos sitios el mismo nombre) y que **los protocolos sean comunes**. Todo lo demás queda a la autonomía de cada red. Ver **diagrama D2**.

ICANN e IANA. La **ICANN** (*Internet Corporation for Assigned Names and Numbers*), creada en **1998**, es una corporación sin ánimo de lucro con sede en California que coordina el sistema de **identificadores únicos**. Dentro de ella, la **IANA** (*Internet Assigned Numbers Authority*) es la **función** —no una organización separada— que lleva los registros de:

1. **Nombres de dominio**: la zona raíz del DNS y la delegación de los TLD.
2. **Números**: bloques de direcciones IP y de números de sistema autónomo, que se entregan **en bloque a los cinco RIR**.
3. **Parámetros de protocolo**: los registros de valores que usan los RFC (números de puerto, códigos de estado HTTP, algoritmos de TLS…).

DATO CLAVE

Transición de las funciones IANA. Hasta 2016 la ICANN ejercía las funciones IANA en virtud de un **contrato con el Departamento de Comercio de EE. UU.** (la NTIA). Ese contrato **expiró el 30 de septiembre de 2016** y no se renovó: desde el **1 de octubre de 2016** las funciones las ejerce **PTI** (*Public Technical Identifiers*), una **filial** de ICANN, bajo supervisión de la propia comunidad. Es el momento en que la gestión de los identificadores pasa de la tutela de un gobierno a un modelo plenamente multiactor.

Los cinco Registros Regionales de Internet (RIR). Reciben bloques de la IANA y los distribuyen en su región a los **LIR** (*Local Internet Registries*), que son típicamente los operadores:

RIR	Región	Sede
ARIN	Norteamérica	Estados Unidos
RIPE NCC	**Europa**, Oriente Medio y Asia Central	Países Bajos
APNIC	Asia-Pacífico	Australia
LACNIC	América Latina y Caribe	Uruguay
AFRINIC	África	Mauricio

DATO CLAVE

España pertenece a RIPE NCC. El orden de la cadena es siempre: **IANA → RIR → LIR (operador) → usuario final**. Y el registro de **quién tiene cada dominio o cada bloque** se consulta con **WHOIS**, sustituido progresivamente por **RDAP**, que sí permite control de acceso y respuestas estructuradas en JSON —un cambio impulsado, entre otras razones, por el **RGPD**—.

Los organismos técnicos. Conviene tener clarísimo quién hace qué:

Organismo	Qué hace	Qué NO hace
IETF (*Internet Engineering Task Force*)	Desarrolla y publica los **estándares de Internet**: los **RFC**. Trabaja en grupos de trabajo abiertos, por consenso aproximado, sin cuotas ni votaciones formales	No gestiona direcciones ni nombres
IAB (*Internet Architecture Board*)	**Supervisión arquitectónica** a largo plazo, series RFC y relación con otros organismos	No redacta los estándares uno a uno
IESG (*Internet Engineering Steering Group*)	**Aprueba** los documentos del IETF y gestiona sus áreas técnicas	—
IRTF (*Internet Research Task Force*)	**Investigación** a largo plazo (criptografía, encaminamiento futuro)	No produce estándares
ISOC (*Internet Society*)	Paraguas **institucional, jurídico y de defensa** de la Internet abierta; hogar organizativo del IETF	No decide contenidos técnicos
ICANN / IANA / PTI	**Identificadores únicos**: nombres, números y parámetros	No define protocolos
W3C	Estándares **de la Web**: HTML, CSS, DOM, XML, accesibilidad **WCAG**, RDF	**No** estandariza Internet ni TCP/IP
IEEE	Normas de **capa física y de enlace**: **802.3** (Ethernet), **802.11** (Wi-Fi)	No define IP ni HTTP
ITU-T	Recomendaciones de telecomunicación (X.25, X.509, series G) desde un organismo **intergubernamental** de la ONU	No gobierna Internet
IGF (*Internet Governance Forum*)	Foro **de diálogo** político auspiciado por la ONU desde 2006	**No** adopta decisiones vinculantes

DATO CLAVE

Las tres confusiones más frecuentes: (1) **W3C ≠ IETF** — el W3C estandariza la **Web** (HTML, CSS), el IETF estandariza **Internet** (IP, TCP, HTTP, TLS); nótese que **HTTP es del IETF**, no del W3C, pese a ser el protocolo de la Web. (2) **ICANN ≠ IETF** — la primera reparte identificadores, el segundo escribe protocolos. (3) **El IGF no decide nada**: es un foro de diálogo sin capacidad normativa.

El plano europeo y nacional. Junto a los organismos técnicos globales, hay un plano jurídico que sí es vinculante y que crece: la **Directiva NIS2** (UE) 2022/2555 sobre ciberseguridad, el **Reglamento de Servicios Digitales** (DSA), el **Reglamento de Mercados Digitales** (DMA), el **Reglamento eIDAS** y su revisión **eIDAS 2**, y el **Reglamento de Datos**. En España, la gestión del dominio `.es` corresponde a **Red.es** a través de **Dominios.es**, y la conectividad de la Administración se articula sobre la **red SARA**.

1.2.2. Proceso de estandarización técnica y documentos RFC

Qué es un RFC. *Request for Comments* es la serie documental donde se publican las especificaciones de Internet. El nombre —«petición de comentarios»— es un resto de su origen informal en **1969**: **Steve Crocker** escribió el **RFC 1** (*Host Software*) precisamente con ese título modesto para no parecer que imponía nada. Hoy la serie la publica el **RFC Editor** y supera con creces los **9.900** documentos.

Dos propiedades definen la serie:

DATO CLAVE

Un RFC publicado nunca se modifica. Su número y su contenido son **inmutables**. Cuando la tecnología cambia, se publica un **RFC nuevo** que **obsoleta** (*obsoletes*) o **actualiza** (*updates*) al anterior. Por eso hay que citar siempre el número y, si importa, comprobar en el índice del RFC Editor si sigue vigente. Ejemplo vivo: el RFC 2616 (HTTP/1.1, 1999) fue sustituido por los RFC 723x en 2014, y estos por los **RFC 9110-9112 en 2022**.

El camino de un estándar. Ver **diagrama D3**.

1. **Internet-Draft (I-D)**: borrador de trabajo. **Caduca a los seis meses** si no se actualiza y **no puede citarse como referencia normativa**. Un documento en fase de borrador no es un estándar, por muy implantado que esté.
2. **Adopción por un grupo de trabajo** del IETF y discusión pública en su lista de correo.
3. **Última llamada** (*Last Call*) del grupo y del IETF, y **aprobación por el IESG**.
4. **Publicación como RFC** por el RFC Editor, con número definitivo.

Categorías de RFC (el error frecuente es creer que todo RFC es un estándar; **no lo es**):

Categoría	Significado	Ejemplo
Standards Track	Camino de estandarización, en dos escalones desde 2011: **Proposed Standard** e **Internet Standard**	RFC 9114 (HTTP/3) es *Proposed*; RFC 9110 (semántica HTTP) es **Internet Standard**
Best Current Practice (BCP)	Práctica recomendada o procedimiento del propio IETF; se numera además como **BCP n**	RFC 1918 (direccionamiento privado) es **BCP 5**
Informational	Información, sin pretensión normativa	RFC 2818 (HTTP sobre TLS), hoy obsoleto
Experimental	Especificación en pruebas	Protocolos aún no maduros
Historic	Superado y desaconsejado	RFC de SSL, Telnet en claro

DATO CLAVE

Cuando un documento alcanza el rango de **Internet Standard**, además de su número de RFC recibe un número de la serie **STD**, que **no cambia** aunque se reedite el RFC. Ejemplos verificados: **STD 97 = RFC 9110** (semántica HTTP), **STD 98 = RFC 9111** (caché), **STD 99 = RFC 9112** (HTTP/1.1), **STD 86 = RFC 8200** (IPv6), **STD 102 = RFC 9915** (DHCPv6, enero de 2026). El nivel «Draft Standard» intermedio **se eliminó en 2011** (RFC 6410), aunque quedan RFC antiguos etiquetados así.

EJERCICIO RESUELTO

Enunciado: un pliego técnico municipal exige que el servicio «cumpla el RFC 5246». ¿Es correcto redactarlo así en 2026? **Solución**: no. El **RFC 5246** especificaba **TLS 1.2** y fue **obsoletado**, primero parcialmente por el RFC 8446 y de forma completa por el **RFC 9846 (julio de 2026)**, que reedita TLS 1.3 y absorbe la especificación de TLS 1.2. Un pliego correcto no debería fijar un número de RFC congelado, sino exigir **«TLS 1.2 o superior, con los algoritmos y parámetros autorizados por el CCN»**, que es la formulación que emplea el propio ENS en `mp.com.2.r1`. Así el pliego sigue siendo válido cuando el IETF reedite la especificación.

RELACIÓN CON OTROS TEMAS

La normalización de las capas físicas y de enlace (IEEE 802.3, 802.11) se trata en los **Temas 33 y 37**. Los estándares del W3C relativos a **accesibilidad (WCAG)** se estudian en el **Tema 25**, y los de marcado (HTML, XML) en el **Tema 23**.

2. Arquitectura de red de Internet

2.1. Modelo de comunicación TCP/IP

2.1.1. Pila TCP/IP y correspondencia con el modelo OSI

Por qué hay capas. La arquitectura de Internet está **estratificada**: cada capa presta un servicio a la superior y se apoya en la inferior, y **solo dialoga con su capa homóloga** del otro extremo. La ventaja es la **independencia**: se puede cambiar la tecnología de acceso (fibra en vez de cobre) sin tocar HTTP, y se puede inventar un protocolo de aplicación nuevo sin rediseñar la red. Ver **diagrama D4**.

Dos modelos conviven en la literatura y en los exámenes:

- El **modelo OSI** de ISO (norma **ISO/IEC 7498-1**), de **siete capas**, es un modelo **de referencia**: se estudia, se cita y se usa para hablar con precisión («esto es un problema de capa 2»), pero **su pila de protocolos no se implantó**.
- El **modelo TCP/IP**, de **cuatro capas**, es el modelo **real** de Internet: nació de implementaciones que funcionaban y se describió después (RFC 1122 y 1123).

Modelo TCP/IP (4 capas)	Modelo OSI (7 capas)	Protocolos representativos	PDU	Dispositivo típico
Aplicación	7 Aplicación · 6 Presentación · 5 Sesión	HTTP, HTTPS, DNS, SMTP, IMAP, FTP, SSH, DHCP	**Mensaje** / datos	Pasarela, proxy
Transporte	4 Transporte	**TCP**, **UDP**, QUIC (sobre UDP)	**Segmento** (TCP) / **Datagrama** (UDP)	Cortafuegos con estado
Internet o red	3 Red	**IP** (v4 y v6), ICMP, IGMP, ARP (*), protocolos de encaminamiento	**Paquete** / datagrama IP	**Encaminador**
Acceso a red o enlace	2 Enlace de datos · 1 Física	Ethernet (802.3), Wi-Fi (802.11), PPP	**Trama** / **bit**	Conmutador · concentrador

(*) La ubicación de **ARP** tiene trampa: resuelve direcciones IP en direcciones MAC, por lo que se sitúa **entre** las capas 2 y 3; el RFC 1122 lo coloca en la capa de **enlace**, y buena parte de la literatura, «entre» ambas.

DATO CLAVE

La correspondencia exacta: la capa de **aplicación** de TCP/IP **absorbe tres** capas de OSI (aplicación, presentación y sesión), y la de **acceso a red** absorbe **dos** (enlace y física). Las capas de **transporte** e **internet/red** se corresponden **una a una**. Hay quien presenta TCP/IP con **cinco** capas separando física y enlace: es una variante didáctica admitida, pero **el modelo canónico del RFC 1122 tiene cuatro**.

El principio del reloj de arena. La forma de la pila de Internet se describe como un **reloj de arena**: abajo hay **muchas** tecnologías de acceso (Ethernet, Wi-Fi, 5G, fibra, satélite), arriba hay **muchísimos** protocolos y aplicaciones, y en el centro, en el cuello estrecho, hay **uno solo: IP**. Esa estrechez es lo que hace universal a Internet —todo puede ir sobre IP e IP puede ir sobre todo— y también lo que ha hecho tan doloroso el cambio de IPv4 a IPv6: **cambiar el cuello del reloj afecta a todo lo demás**.

Los dos protocolos de transporte. Es materia del Tema 34, pero sin este contraste no se entiende HTTP/3:

	TCP	UDP
Conexión	**Orientado a conexión**: saludo en tres pasos **SYN → SYN-ACK → ACK**	**Sin conexión**: se envía y ya
Fiabilidad	Confirmaciones, retransmisión, **entrega ordenada**	**Ninguna**: puede perder, duplicar o desordenar
Control	De **flujo** (ventana) y de **congestión**	No
Cabecera	**20 bytes** mínimo	**8 bytes**
Usos típicos	Web, correo, transferencia de archivos, SSH	DNS, DHCP, voz y vídeo en tiempo real, **QUIC**

DATO CLAVE

Un **puerto** es un identificador de **16 bits** (0-65535) que multiplexa las aplicaciones sobre una misma dirección IP. Rangos de la **IANA**: **0-1023 puertos bien conocidos** (*well-known*, reservados a servicios de sistema), **1024-49151 registrados**, **49152-65535 dinámicos o efímeros**. La combinación **IP origen + puerto origen + IP destino + puerto destino + protocolo** identifica de forma única una conexión: es la **quíntupla** o *5-tuple*.

2.1.2. Encapsulamiento y transmisión de datos

El mecanismo. Cuando un dato baja por la pila, **cada capa le añade su propia cabecera** (y, en el caso de la trama Ethernet, también una cola con la comprobación de errores). Ese envoltorio sucesivo se llama **encapsulamiento**, y su inverso, en el receptor, **desencapsulamiento**. La regla mental: **cada capa trata como «datos opacos» todo lo que le entrega la capa superior**, cabeceras incluidas. Ver **diagrama D5**.

Recorrido completo de una petición a la sede electrónica:

1. **Aplicación**: el navegador construye el **mensaje HTTP** (`GET /tramites HTTP/1.1` , cabeceras).
2. **Transporte**: TCP antepone su cabecera con **puerto origen** (efímero) y **puerto destino 443**, número de secuencia y confirmación → **segmento**.
3. **Internet**: IP antepone la suya con **dirección IP origen y destino** y el TTL → **paquete**.
4. **Enlace**: Ethernet antepone **direcciones MAC** de origen y destino y añade la **FCS** al final → **trama**.
5. **Física**: la trama se convierte en **bits** y se transmite como señales.

En el destino se repite el proceso a la inversa, y cada capa **quita su cabecera** y entrega el resto a la superior.

> DATO CLAVE
>
> El encapsulamiento explica la **sobrecarga** (*overhead*) y el concepto de **MTU**. La **MTU** de Ethernet es de **1.500 bytes** de carga útil. Si un paquete IPv4 supera la MTU de un enlace, **el encaminador puede fragmentarlo**; en **IPv6 los encaminadores intermedios NO fragmentan**: solo lo hace el **origen**, que descubre la MTU del camino con **Path MTU Discovery** (y si algo no cabe, se devuelve un error ICMPv6 «paquete demasiado grande»). Es una de las diferencias clave entre IPv4 e IPv6.

Qué cambia en cada salto y qué no. Al atravesar un encaminador, **las direcciones MAC de la trama cambian en cada salto** (son locales al enlace), mientras que **las direcciones IP de origen y destino permanecen** de extremo a extremo —salvo que haya un **NAT** por medio, que precisamente lo que hace es reescribirlas—. El **TTL** (o *hop limit* en IPv6) se **decrementa en una unidad** en cada encaminador, y cuando llega a cero el paquete se descarta y se genera un mensaje ICMP: ese es el mecanismo en el que se apoya la herramienta `traceroute` .

EJERCICIO RESUELTO

Enunciado: un empleado municipal no puede acceder a `sede.madrid.es`. Se comprueba que `ping 8.8.8.8` responde, pero `ping sede.madrid.es` devuelve «host desconocido». ¿En qué capa está el problema y cuál es la causa más probable? **Solución**: hay conectividad **de capa de red** (el `ping` a una IP funciona: IP, enlace y física están bien), pero falla la **resolución de nombres**, que es un servicio de la **capa de aplicación**. La causa más probable es una **configuración o caída del servidor DNS** del puesto, no un problema de red. Comprobación: `nslookup sede.madrid.es 8.8.8.8`; si resuelve contra un DNS externo pero no contra el corporativo, el fallo está en el resolutor de la organización. **Lección de método**: aislar siempre **por capas**, de abajo arriba.

2.2. Infraestructura y direccionamiento

2.2.1. Sistemas Autónomos y puntos de intercambio de tráfico

El problema. Dentro de una organización, el encaminamiento es un asunto técnico: se busca el camino más corto. **Entre organizaciones distintas**, el encaminamiento es sobre todo un asunto **económico y de política**: un operador no quiere transportar gratis el tráfico de su competidor. La arquitectura de Internet resuelve esa tensión con dos piezas: el **sistema autónomo** y el protocolo **BGP**. Ver **diagrama D6**.

Sistema Autónomo (AS). Es un conjunto de redes y encaminadores bajo **una misma administración** que presenta hacia el exterior una **política de encaminamiento única y coherente**. Se identifica con un **ASN** (*Autonomous System Number*), asignado por la IANA a través de los RIR, de **32 bits** desde 2007 (antes eran de 16 bits, y los 16 bits se agotaron: por eso hoy se ven ASN «altos»).

DATO CLAVE

Distinción **IGP frente a EGP**: - **IGP** (*Interior Gateway Protocol*): encamina **dentro** de un AS. Ejemplos: **RIP** (vector de distancias), **OSPF** e **IS-IS** (estado de enlace), **EIGRP**. Optimizan una **métrica técnica** (saltos, coste, ancho de banda). - **EGP** (*Exterior Gateway Protocol*): encamina **entre** AS. Solo hay uno en uso: **BGP-4** (RFC 4271), que funciona sobre **TCP puerto 179**, es un protocolo de **vector de caminos** (*path vector*) y decide **por política**, no por métrica.

Cómo se relacionan los AS. Dos modelos económicos básicos:

- **Tránsito** (relación cliente-proveedor): el AS cliente **paga** al proveedor para que le lleve el tráfico a **todo Internet**. Es la relación jerárquica.
- ***Peering*** (relación entre iguales): dos AS intercambian **directamente** el tráfico de sus propias redes y el de sus clientes, normalmente **sin cobrarse** (*settlement-free*). No es tránsito: por un enlace de *peering* **no** se accede a los clientes de terceros del otro.

Esa estructura suele describirse en niveles: los **Tier 1** son los AS que alcanzan toda la tabla global **solo por acuerdos de *peering***, sin pagar tránsito a nadie; los **Tier 2** compran tránsito y hacen *peering*; los **Tier 3** son fundamentalmente clientes.

Puntos neutros (IXP). Un **Internet Exchange Point** es una infraestructura física —en la práctica, una red conmutada de gran capacidad alojada en uno o varios centros de datos— donde muchos operadores se conectan y hacen *peering* entre sí. Beneficios: **reduce costes** de tránsito, **baja la latencia** (el tráfico local no da un rodeo por otro país) y **mejora la resiliencia**.

> DATO CLAVE
>
> Los dos puntos neutros de referencia en España son **ESPANIX** (Madrid, constituido el **13 de mayo de 1997**, el veterano; con picos que superan los **2 Tbps** y un crecimiento superior al 12 % interanual en 2026) y **DE-CIX Madrid** (abierto en 2016, con picos por encima de **1,5 Tbit/s**). Su función es que el tráfico entre operadores españoles **se quede en España** en vez de intercambiarse en Londres, París o Fráncfort.

Riesgos del encaminamiento interdominio. BGP fue diseñado **sobre la confianza mutua** y no valida quién anuncia qué. De ahí dos incidentes recurrentes: el **secuestro de prefijos** (*BGP hijacking*), en el que un AS anuncia un bloque que no le pertenece y atrae tráfico ajeno, y las **fugas de rutas** (*route leaks*). Las contramedidas actuales son la **RPKI** (infraestructura de clave pública de recursos, que firma criptográficamente qué AS está autorizado a originar cada prefijo mediante objetos **ROA**), el filtrado por objetos del registro **IRR** y las buenas prácticas del acuerdo sectorial **MANRS**.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> Un ayuntamiento grande no compra «Internet» a una sola empresa y se olvida: contrata **al menos dos operadores de tránsito** con encaminamiento redundante y, si dispone de **ASN y de bloque propio**, anuncia sus prefijos por ambos, de modo que la caída de un operador no deja fuera de servicio la sede electrónica ni el correo municipal. Esa redundancia es, además, la forma natural de cumplir las medidas de **disponibilidad** del ENS sobre el servicio de comunicaciones.

2.2.2. Coexistencia de los protocolos IPv4 e IPv6

El agotamiento de IPv4. IPv4 usa direcciones de **32 bits**: **2^{32} = 4.294.967.296** direcciones teóricas, y bastantes menos utilizables tras descontar los rangos reservados. Cuando se diseñó, en 1981, parecían inagotables. No lo eran.

DATO CLAVE

Fechas del agotamiento: la **IANA** entregó sus **últimos cinco bloques** `/8` a los RIR el **3 de febrero de 2011**. **RIPE NCC** —el RIR de España— **entró en la fase del «último** `/8` **»** el **14 de septiembre de 2012**, desde la cual cada operador solo podía recibir una **única asignación final de un** `/22` (1.024 direcciones), y alcanzó el **agotamiento pleno el 25 de noviembre de 2019**, desde el cual solo asigna direcciones **recuperadas**, mediante lista de espera.

Los paliativos que aplazaron el problema (y que hay que saber distinguir):

Mecanismo	RFC	Qué hace	Limitación
Subredes y máscara	RFC 950	Divide una red en subredes	Reparto interno
CIDR	RFC 4632	Elimina las **clases A/B/C** y permite prefijos de longitud variable (`/22` , `/19`) más **agregación de rutas**	Frena el crecimiento de la tabla, no crea direcciones
Direccionamiento privado	**RFC 1918** (BCP 5)	Reserva **10.0.0.0/8**, **172.16.0.0/12** y **192.168.0.0/16** para uso interno	**No encaminable** en Internet
NAT / PAT	RFC 3022	Traduce muchas direcciones privadas a una pública, multiplexando por **puerto**	Rompe el principio **extremo a extremo**, complica servidores entrantes, VoIP e IPsec
CGNAT	**RFC 6598**	NAT **del operador**, con el rango compartido **100.64.0.0/10**	Varios clientes comparten IP pública: dificulta la **trazabilidad** y el bloqueo por IP

DATO CLAVE

CGNAT y trazabilidad. Cuando un operador aplica CGNAT, **decenas o cientos de abonados comparten una misma IP pública**. Para identificar a un usuario a partir de una dirección ya **no basta la IP y la hora**: hace falta también el **puerto de origen**. Tiene consecuencias prácticas directas en la Administración: los registros (*logs*) de un servicio público deben guardar **IP y puerto de origen** si se quiere poder responder a un requerimiento judicial, y el bloqueo por dirección IP puede dejar fuera a usuarios legítimos.

IPv6. Especificado en el **RFC 8200** (julio de 2017, **STD 86**), que sustituyó al RFC 2460. Sus rasgos, en contraste con IPv4:

Característica	IPv4	IPv6
Longitud	**32 bits**	**128 bits** (≈ 3,4 × 10^{38} direcciones)
Notación	Decimal con puntos: `192.168.1.1`	Hexadecimal con dos puntos: `2001:db8::1`, con supresión de ceros y **una sola** abreviatura `::` por dirección
Cabecera	**Variable**, 20-60 bytes, con opciones	**Fija de 40 bytes**, con **cabeceras de extensión** encadenadas
Suma de control	Sí, recalculada en cada salto	**No** (se delega en las capas superior e inferior)
Fragmentación	La hace el emisor **y los encaminadores**	**Solo el emisor**
Difusión (*broadcast*)	Sí	**No existe**: se sustituye por **multidifusión** (`ff00::/8`) y **anycast**
Configuración	Manual o **DHCP**	**SLAAC** (autoconfiguración sin estado, con anuncios del encaminador) o **DHCPv6**
Seguridad	IPsec opcional	IPsec previsto en la arquitectura (aunque su uso también es opcional en la práctica)
Resolución de vecinos	**ARP**	**NDP** (protocolo de descubrimiento de vecinos, sobre ICMPv6)

DATO CLAVE

Direcciones IPv6 que hay que reconocer a simple vista: `::1/128` es la de bucle local (equivalente a `127.0.0.1`); `fe80::/10` son las de **enlace local**, obligatorias en toda interfaz y no encaminables; `fc00::/7` son las **únicas locales** (el equivalente conceptual a las privadas del RFC 1918); `ff00::/8` son las de **multidifusión**; `2000::/3` es el rango de las **globales unidifusión** actualmente asignado. El prefijo estándar de una subred es `/64`, y `2001:db8::/32` está reservado para **documentación**: si aparece en un ejemplo, no es una red real.

Los tres mecanismos de coexistencia. La clave conceptual: **IPv4 e IPv6 son protocolos incompatibles**; un nodo que solo hable IPv6 **no puede** comunicarse directamente con uno que

solo hable IPv4. Por eso hacen falta mecanismos de transición. Ver **diagrama D7**.

1. **Doble pila** (*dual stack*): el equipo ejecuta **ambas** pilas simultáneamente y elige según el destino (con la preferencia del RFC 6724 y el algoritmo de **globos felices** —*Happy Eyeballs*, RFC 8305— para no penalizar al usuario si una de las dos falla). Es el mecanismo **recomendado** y el más usado en la Administración. Inconveniente: hay que **gestionar y securizar dos redes**.
2. **Túneles**: se **encapsula** IPv6 dentro de IPv4 para atravesar una zona que no habla IPv6 (**6in4**, **6to4**, **Teredo**, **GRE**, **6rd**). Útil como parche; añade sobrecarga y dificulta la inspección de tráfico.
3. **Traducción**: una pasarela **convierte** entre protocolos. La combinación vigente es **NAT64 + DNS64** (el DNS sintetiza registros AAAA a partir de los A, y la pasarela traduce), con **464XLAT** en redes móviles. Es el camino de las redes que ya son **solo IPv6**.

> DATO CLAVE
>
> El mecanismo **NAT-PT** (RFC 2766) está **declarado histórico** (RFC 4966) y no debe proponerse. Y una trampa habitual: **no existe** ningún mecanismo que permita que un nodo solo-IPv4 hable con uno solo-IPv6 **sin un elemento intermedio**; toda solución pasa por doble pila, túnel o traducción.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> Escenario típico municipal: la red interna del Ayuntamiento funciona en **IPv4 privado con NAT**, y los servicios publicados a la ciudadanía —sede electrónica, portal, API— se ofrecen en **doble pila** para ser accesibles desde ambos mundos. La adopción interna de IPv6 se aborda normalmente por fases y empezando por lo publicado hacia fuera, porque el mayor riesgo no es técnico sino de **gestión**: durante el periodo de coexistencia, cada regla de cortafuegos y cada lista de control de acceso hay que **duplicarla y mantenerla en los dos protocolos**; una regla que solo se aplica a IPv4 deja abierta la puerta IPv6.

2.2.3. Sistema de Nombres de Dominio

Para qué sirve. Las máquinas se encaminan por **direcciones IP**; las personas recordamos **nombres**. El **DNS** (*Domain Name System*) es la base de datos **jerárquica y distribuida** que traduce entre ambos mundos. Se especifica en los **RFC 1034** (conceptos) y **1035** (implementación), de **noviembre de 1987**, y sustituyó al fichero `HOSTS.TXT` centralizado, que era insostenible.

Tres propiedades definen su diseño:

- **Jerárquico**: el espacio de nombres es un árbol invertido cuya raíz se escribe con un punto (`.`).

- **Distribuido y delegado**: **nadie tiene la base de datos completa**. Cada zona la administra quien corresponde y **delega** las inferiores. Esa delegación es lo que lo hace escalable.
- **Con caché**: cada respuesta lleva un **TTL** que indica cuánto tiempo puede guardarse. Sin caché, la raíz se hundiría.

La jerarquía. Ver **diagrama D8**.

`sede.madrid.es.` se lee **de derecha a izquierda**: raíz (`.`) → **TLD** `es` → dominio de segundo nivel `madrid` → subdominio `sede` .

- **Raíz**: **13 identidades** de servidor raíz, etiquetadas de la **A a la M**, operadas por **12 organizaciones** distintas. Hay 13 **nombres**, no 13 máquinas: mediante **anycast** cada identidad se replica en decenas o centenares de emplazamientos que anuncian la misma dirección IP. En agosto de 2026 el conjunto sumaba **más de 2.000 instancias** operativas en todo el mundo.
- **TLD**: **gTLD** genéricos (`.com` , `.org` , `.net` , y desde 2012 centenares de nuevos gTLD), **ccTLD** de código de país (`.es` , `.fr` , `.eu` como caso especial supranacional) y los **IDN** con caracteres no latinos.
- **Dominios de segundo nivel y siguientes**: los registra el titular a través de un **agente registrador** (*registrar*) acreditado por el **registro** (*registry*) del TLD.

> DATO CLAVE
>
> ¿Por qué **13** servidores raíz? Por una limitación histórica: para que la respuesta con la lista completa de servidores raíz **cupiera en un único datagrama UDP de 512 bytes**, que era el tamaño máximo garantizado del DNS clásico. Hoy la restricción se ha superado con **EDNSO** (RFC 6891), pero el número 13 se mantiene por compatibilidad. **La cifra que no cambia es 13 identidades; el número de instancias físicas crece continuamente.**

Cómo se resuelve un nombre. Hay dos tipos de consulta y **confundirlos es un fallo típico**:

- **Consulta recursiva**: la que hace el cliente a su **resolutor** (el servidor DNS configurado en el equipo). El cliente pide la respuesta final y **el resolutor asume el trabajo** de conseguirla.
- **Consulta iterativa**: la que hace el **resolutor** a los servidores autoritativos. Cada uno responde con lo que sabe: la raíz no conoce `sede.madrid.es` , pero **sí sabe quién manda en** `.es` , y así sucesivamente.

Resolución completa de `sede.madrid.es` :

1. El navegador consulta su **caché** y la del sistema operativo; si no, pregunta al **resolutor** (recursiva).
2. El resolutor pregunta a un **servidor raíz** → responde con los **NS de** `.es` (referencia).
3. Pregunta a un servidor de `.es` → responde con los **NS de** `madrid.es` .

4. Pregunta al servidor **autoritativo de** `madrid.es` → devuelve el **registro A/AAAA** de `sede.madrid.es`.
5. El resolutor **cachea** la respuesta durante su **TTL** y se la entrega al cliente.

> DATO CLAVE
>
> El DNS usa el **puerto 53**. **UDP** para las consultas ordinarias (rápido, sin conexión) y **TCP** cuando la respuesta **excede el tamaño admisible** —respuesta truncada, marcada con el bit **TC**— y **siempre** para las **transferencias de zona** entre servidores autoritativos (**AXFR** completa, **IXFR** incremental). Que las transferencias de zona vayan por TCP y estén restringidas es además una medida de seguridad: una **AXFR abierta** entrega a un atacante el mapa completo de la organización.

Tipos de servidor y de registro.

Tipo de servidor	Función
Autoritativo	Custodia los datos **originales** de una zona: es la fuente de la verdad. Uno **primario** (donde se editan) y varios **secundarios** que replican por transferencia de zona
Recursivo o resolutor	No posee datos propios: **resuelve** en nombre de los clientes y **cachea**
De reenvío (*forwarder*)	Delega las consultas en otro resolutor
Raíz	Punto de entrada de la jerarquía

Registro	Contenido
A	Dirección **IPv4**
AAAA	Dirección **IPv6**
CNAME	**Alias** de otro nombre (no puede coexistir con otros registros en el mismo nombre)
MX	Servidor de **correo** del dominio, con **prioridad** (número menor, mayor preferencia)
NS	Servidores **autoritativos** de la zona
PTR	Resolución **inversa** IP → nombre (zona `in-addr.arpa` / `ip6.arpa`)
SOA	Inicio de autoridad: primario, correo del responsable, número de serie y temporizadores
TXT	Texto libre; soporte de **SPF**, **DKIM**, **DMARC** y verificaciones de propiedad
SRV	Servicio, protocolo, puerto y destino
CAA	**Qué autoridades de certificación** pueden emitir certificados para el dominio

Seguridad del DNS. El DNS original **no autentica nada**: cualquiera que se adelante con una respuesta falsa puede desviar a un usuario a un servidor impostor (**envenenamiento de caché**, del que el ataque de **Kaminsky** en 2008 fue el caso canónico). Las respuestas también viajan **en claro**, de modo que quien observe la red sabe qué sitios visita cada usuario. **Son dos problemas distintos con dos soluciones distintas**, y esa distinción es clave. Ver **diagrama D9**.

> DATO CLAVE
>
> **DNSSEC** (RFC 4033-4035) **firma digitalmente** las respuestas y encadena la confianza desde la raíz: aporta **autenticidad e integridad** del dato, y **no aporta confidencialidad** (las respuestas siguen viajando legibles). **DoT** (*DNS over TLS*, **RFC 7858**, puerto **TCP 853**) y **DoH** (*DNS over HTTPS*, **RFC 8484**, sobre **HTTPS/443**) **cifran el transporte** de la consulta: aportan **confidencialidad**, y **no garantizan** que el dato de la zona sea auténtico. Son **complementarios**. A julio de 2026, **1.348 de los 1.437 TLD** de la raíz estaban firmados con DNSSEC (≈ 93,8 %), pero la adopción **en los dominios de segundo nivel sigue siendo minoritaria**.

Otras amenazas y contramedidas que conviene citar: el **secuestro de dominio** (robo de las credenciales del registrador; se mitiga con **bloqueo de registro** y doble factor), el **typosquatting** y los **dominios homógrafos** con caracteres visualmente idénticos, y el **túnel DNS** (*DNS tunneling*), técnica de exfiltración que saca datos codificados en consultas y que se detecta vigilando volumen y entropía de las peticiones.

EJEMPLO DE APLICACIÓN EN EL AYTO

El DNS es un **punto único de fallo con apariencia inofensiva**. Si `madrid.es` deja de resolverse, no se cae ningún servidor: simplemente **nadie los encuentra**, y el efecto para la ciudadanía es idéntico a una caída total. De ahí tres exigencias prácticas en un ayuntamiento: **servidores autoritativos redundantes** en emplazamientos y redes distintas; **vigilancia de la fecha de renovación** del dominio (una caducidad por descuido administrativo ha tumbado servicios públicos en más de una ocasión); y **registro CAA** publicado, para que ninguna autoridad de certificación distinta de la contratada pueda emitir un certificado válido para el dominio municipal.

RELACIÓN CON OTROS TEMAS

La administración práctica de los servicios de red en el ámbito local —incluidos DNS y DHCP internos, la monitorización y el control de tráfico— corresponde al **Tema 30**. Los dispositivos de interconexión (conmutadores, encaminadores, puntos de acceso) se estudian en el **Tema 37**.

---

3. Principales servicios de Internet

Antes de entrar en cada uno, conviene fijar el mapa completo de puertos, porque es **la tabla más rentable de todo el tema**: se memoriza en diez minutos.

DATO CLAVE

La tabla de puertos siguiente es material de memorización directa: no admite razonamiento, solo repaso.

Servicio	Puerto en claro	Puerto seguro
HTTP / HTTPS	**80** (TCP)	**443** (TCP; y **UDP 443** para HTTP/3 sobre QUIC)
FTP	**21** control · **20** datos	**990** (FTPS implícito) · **989** datos
SSH / SFTP / SCP	—	**22**
Telnet	**23** (en claro, **proscrito**)	—
SMTP entre servidores	**25**	**465** (TLS implícito)
SMTP envío desde cliente (*submission*)	**587** (con STARTTLS)	465
POP3	**110**	**995**
IMAP	**143**	**993**
DNS	**53** (UDP y TCP)	**853** (DoT) · **443** (DoH)
DHCP	**67** servidor · **68** cliente (UDP)	DHCPv6: **547** servidor · **546** cliente
LDAP	**389**	**636**
SNMP	**161** · **162** trampas	SNMPv3 sobre los mismos
NTP	**123** (UDP)	—
RDP	**3389**	—
BGP	**179** (TCP)	—

3.1. Servicios de la capa de aplicación

3.1.1. Correo electrónico y sus protocolos

La arquitectura del correo. El correo electrónico es **el servicio más antiguo de Internet en uso continuo**: el primer mensaje entre ordenadores distintos lo envió **Ray Tomlinson en 1971**, y suya es la decisión de usar el símbolo `@` para separar el usuario del sistema. Su arquitectura sigue siendo la de entonces, con cuatro piezas que conviene saber nombrar. Ver **diagrama D10**.

Sigla	Nombre	Qué es
MUA	*Mail User Agent*	El **cliente** del usuario: Outlook, Thunderbird, un correo web
MSA	*Mail Submission Agent*	Recibe el mensaje **del usuario** (puerto 587) y lo valida
MTA	*Mail Transfer Agent*	El **servidor** que encamina el mensaje entre dominios (puerto 25)
MDA	*Mail Delivery Agent*	Deposita el mensaje **en el buzón** del destinatario

Los tres protocolos, y la diferencia esencial entre ellos.

- **SMTP** (*Simple Mail Transfer Protocol*, **RFC 5321**) es el protocolo de **envío y tránsito**: mueve el mensaje del cliente al servidor y de servidor a servidor. Es un protocolo **de empuje** (*push*).
- **POP3** (*Post Office Protocol v3*, **RFC 1939**) e **IMAP** (*Internet Message Access Protocol v4rev2*, **RFC 9051**) son protocolos de **acceso al buzón**, es decir, **de recogida** (*pull*). **No sirven para enviar**.

> DATO CLAVE
>
> El error más penalizado del bloque: **«el correo se envía con SMTP y se recibe con POP3 o IMAP»** es la formulación correcta. SMTP **no descarga** nada y POP3/IMAP **no envían** nada. Un cliente de correo configurado necesita **siempre las dos** cosas: un servidor de salida (SMTP) y uno de entrada (POP3 o IMAP).

POP3 frente a IMAP, que es la otra comparación segura:

	POP3 (110 / 995)	IMAP (143 / 993)
Modelo	**Descarga y borra** (por defecto) del servidor	**Mantiene** el mensaje en el servidor
Sincronización	No: cada dispositivo tiene su copia	**Sí**: estado leído/no leído y carpetas sincronizados
Carpetas en servidor	No	**Sí**, con gestión remota
Multidispositivo	Malo	**Diseñado para ello**
Consumo en servidor	Bajo	Alto (almacenamiento e índices)
Trabajo sin conexión	Bueno (todo local)	Requiere caché local

En 2026 **IMAP es la opción por defecto** en cualquier organización, porque el usuario medio consulta el correo desde el ordenador y el teléfono.

Estructura de un mensaje. Un correo tiene **cabeceras** (`From`, `To`, `Cc`, `Bcc`, `Subject`, `Date`, `Message-ID`, y la traza de `Received` que van añadiendo los MTA) y **cuerpo**. El formato original solo admitía texto **ASCII de 7 bits**; **MIME** (*Multipurpose Internet Mail Extensions*, RFC 2045-2049) es la extensión que permite **acentos, otros alfabetos, HTML y archivos adjuntos**, codificando el binario en texto con **Base64** o *quoted-printable*.

> DATO CLAVE
>
> Dos precisiones sobre las cabeceras: (1) la cabecera `Bcc` **no viaja** a los destinatarios —el servidor la elimina—, que es justamente lo que hace que la copia sea oculta; y (2) **la cabecera `From` la escribe el emisor y no está autenticada por SMTP**: esa es la raíz técnica de la **suplantación de remitente** (*spoofing*) y del **phishing**, y la razón de que existan SPF, DKIM y DMARC.

Autenticación del remitente: SPF, DKIM y DMARC. Los tres se publican como **registros DNS** del dominio y son la respuesta estándar a la suplantación:

Mecanismo	Qué hace	Se publica en	Qué verifica
SPF (RFC 7208)	Lista **qué servidores están autorizados** a enviar correo con ese dominio	Registro **TXT**	La **IP** del servidor emisor frente a la envuelta (`MAIL FROM`)
DKIM (RFC 6376)	**Firma criptográficamente** cabeceras y cuerpo con una clave privada; el receptor valida con la pública publicada en el DNS	Registro **TXT** en un selector	**Integridad** del mensaje y **autenticidad** del dominio firmante
DMARC	Exige el **alineamiento** del `From` visible con SPF o DKIM, fija la **política** ante el fallo (`none` , `quarantine` , `reject`) e instaura **informes**	Registro **TXT** en `_dmarc`	La coherencia del conjunto

DATO CLAVE

DMARC se reeditó en mayo de 2026: los **RFC 9989** (especificación), **9990** (informes agregados) y **9991** (informes de fallo) **obsoletan el RFC 7489**, que era informativo, y elevan DMARC a *Standards Track*. Es un dato reciente y diferencial. Idea clave: **SPF y DKIM por sí solos no impiden el fraude**, porque validan el dominio de la envuelta o del firmante, no el que **ve el usuario**; es **DMARC** quien exige que coincidan y quien dice qué hacer si no coinciden.

Seguridad del transporte del correo. Dos modelos que conviene no mezclar: **TLS implícito** (la conexión nace cifrada en un puerto dedicado: 465, 993, 995) y **STARTTLS** (la conexión nace en claro en el puerto ordinario y **se promociona** a cifrada con un comando; 587, 143, 110). STARTTLS es vulnerable al **ataque de degradación** (*stripping*) si un intermediario elimina el anuncio de la capacidad, por lo que el **RFC 8314** recomienda el **TLS implícito** para el acceso del usuario. Entre servidores, además, existen **MTA-STS** (RFC 8461) y **DANE** para exigir que el correo saliente vaya cifrado a los dominios que lo declaran.

EJEMPLO DE APLICACIÓN EN EL AYTO

El correo del dominio municipal es un objetivo natural de suplantación: un mensaje que aparente venir de `@madrid.es` reclamando el pago de una tasa tiene una credibilidad enorme. Por eso la configuración correcta consiste en publicar **SPF, DKIM y DMARC con política** `reject` —no `none`, que solo observa—, y en el lado de entrada, filtrado antimalware y antispam. El ENS lo respalda con la medida `mp.s.1` **(protección del correo electrónico)**, exigible en las **tres categorías**, que obliga expresamente a proteger la información y los **datos de encaminamiento**, y a actuar frente al **correo no solicitado**, el **código dañino** y el **código móvil**, además de exigir **concienciación** del personal.

RELACIÓN CON OTROS TEMAS

La firma electrónica de los mensajes (**S/MIME**, PGP) y los fundamentos criptográficos que la sustentan se estudian en el **Tema 32**. Las herramientas de trabajo en grupo y de comunicación corporativa, en el **Tema 40**.

3.1.2. Transferencia de archivos

FTP. El *File Transfer Protocol* está especificado en el **RFC 959** (octubre de 1985) y es, junto con el correo, uno de los servicios más antiguos. Su rasgo distintivo es que usa **dos conexiones TCP separadas**:

- **Canal de control**, **puerto 21**: permanece abierto toda la sesión y transporta comandos (`USER` , `PASS` , `LIST` , `RETR` , `STOR`) y respuestas numéricas.
- **Canal de datos**, **puerto 20** en modo activo: se abre y se cierra **para cada transferencia**.

DATO CLAVE

Modo activo frente a modo pasivo: - **Activo**: el cliente indica al servidor un puerto suyo con el comando `PORT` , y **es el servidor quien abre la conexión de datos hacia el cliente**, desde su puerto **20**. Problema: esa conexión **entrante** la bloquea normalmente el cortafuegos o el NAT del cliente. - **Pasivo** (comando `PASV`): el servidor abre un puerto alto y se lo comunica al cliente, y **es el cliente quien abre las dos conexiones**. Es el modo **que funciona con NAT y cortafuegos**, y por eso el habitual hoy. Regla mnemotécnica: en **modo pasivo el servidor «se queda pasivo»** y espera; en modo activo, actúa.

El problema de FTP y sus sustitutos. FTP transmite **las credenciales y los datos en claro**. En 2026 su uso en Internet abierto es inadmisible y las alternativas son tres, que **no hay que confundir**:

Protocolo	Qué es realmente	Puerto	Base
FTPS	**FTP con TLS** añadido (implícito en 990, o explícito con `AUTH TLS` sobre el 21)	990 / 21	FTP + TLS
SFTP	**Subsistema de SSH**. **No tiene ninguna relación con FTP** pese al nombre	**22**	SSH
SCP	Copia segura sobre SSH, más simple y hoy desaconsejado frente a SFTP	**22**	SSH
HTTPS	Descarga y subida por web, con la ventaja de atravesar cualquier cortafuegos	443	HTTP + TLS

DATO CLAVE

SFTP ≠ FTPS. FTPS **es FTP** envuelto en TLS y conserva sus dos canales (con los problemas de cortafuegos asociados). SFTP **es SSH**: un solo canal, puerto 22, autenticación por clave pública. Es la confusión más frecuente del epígrafe.

En cuanto a servicios de intercambio, el panorama actual añade el **almacenamiento en la nube** con sincronización, las **API REST** para intercambio entre sistemas y, en el ámbito público español, mecanismos específicos como los **repositorios de intercambio de la red SARA** y las plataformas de intermediación de datos.

EJEMPLO DE APLICACIÓN EN EL AYTO

Un caso municipal típico: el envío nocturno de un fichero de padrón a otro organismo. La solución correcta **no** es un FTP anónimo, sino **SFTP con autenticación por par de claves** (no por contraseña), acceso restringido por dirección de origen, **cifrado del fichero además del canal** si contiene datos personales, y registro de cada transferencia. Si además el fichero incluye datos personales, el **RGPD** exige medidas de seguridad apropiadas y el ENS lo cubre con `mp.com.2` (confidencialidad de las comunicaciones) y `mp.si.2` (criptografía en los soportes).

3.2. Servicios de gestión y red

3.2.1. Acceso remoto seguro

De Telnet a SSH. El acceso remoto a línea de comandos se hacía tradicionalmente con **Telnet** (puerto **23**) y con las órdenes `rlogin`, `rsh` y `rcp` del mundo Unix. Todos ellos transmiten **usuario, contraseña y sesión completa en texto plano**: cualquiera que capture el tráfico ve las credenciales. Están **proscritos** en cualquier red moderna y su presencia en una auditoría es un hallazgo grave.

SSH (*Secure Shell*), creado por Tatu Ylönen en 1995 y normalizado en los **RFC 4251 a 4254**, los sustituye a todos. Escucha en el **puerto TCP 22** y ofrece confidencialidad, integridad y autenticación **mutua**. Ver **diagrama D12**.

Arquitectura en tres capas:

1. **Capa de transporte** (RFC 4253): negocia algoritmos, **autentica al servidor** ante el cliente mediante su clave de host, establece las claves de sesión y aporta cifrado, integridad y compresión opcional.
2. **Capa de autenticación de usuario** (RFC 4252): autentica al **cliente** ante el servidor.
3. **Capa de conexión** (RFC 4254): **multiplexa varios canales lógicos** sobre la única conexión cifrada: sesión interactiva, ejecución de comandos, SFTP, reenvío de puertos y de X11.

Métodos de autenticación del usuario, en orden de robustez:

- **Por contraseña**: cómoda pero vulnerable a fuerza bruta y a reutilización.
- **Por par de claves** (*publickey*): el cliente guarda la **clave privada** —protegida por frase de paso — y el servidor tiene la **pública** en `authorized_keys`. Es el método recomendado.
- **Por certificado de host o de usuario**, **GSSAPI/Kerberos** o **teclado interactivo** con segundo factor.

> DATO CLAVE
>
> La **primera conexión** SSH muestra la huella (*fingerprint*) de la clave del servidor y pide confirmación: es el modelo de **confianza en el primer uso** (*trust on first use*). A partir de ahí la huella se guarda en `known_hosts`, y si cambia, el cliente **aborta la conexión** avisando de un posible ataque de intermediario. Ese aviso **nunca debe ignorarse a la ligera**: o han reinstalado el servidor, o alguien se está interponiendo.

Túneles SSH. La capa de conexión permite **reenvío de puertos**: **local** (`-L`, expone un puerto remoto en la máquina local), **remoto** (`-R`, expone un puerto local en el servidor) y **dinámico** (`-D`, actúa como proxy SOCKS). Es una capacidad muy útil para administración… y un riesgo de seguridad de primer orden, porque **un túnel inverso puede abrir un camino hacia el interior de la red saltándose el cortafuegos perimetral**. En un entorno administrado debe **deshabilitarse el reenvío** salvo necesidad justificada.

Buenas prácticas de bastionado de un servidor SSH, que son materia de caso práctico: deshabilitar el **acceso directo del superusuario** (`PermitRootLogin no`), **deshabilitar la autenticación por contraseña** cuando se usan claves, restringir por origen, limitar los intentos, **registrar** todos los accesos y no publicar el servicio directamente en Internet, sino tras una **VPN** o un **bastión**.

RELACIÓN CON OTROS TEMAS

Las **VPN**, el acceso remoto seguro desde el exterior y la seguridad perimetral son el objeto propio del **Tema 36**. El **control remoto del puesto de usuario** (RDP, VNC, herramientas de asistencia) y la gestión de incidencias, del **Tema 29**.

3.2.2. Configuración dinámica de red

Para qué sirve DHCP. Configurar a mano la dirección IP, la máscara, la pasarela y el DNS de cada equipo es inviable a partir de unas decenas de puestos, y garantiza errores y duplicidades. El **DHCP** (*Dynamic Host Configuration Protocol*, **RFC 2131**) automatiza esa entrega. Es el sucesor de **BOOTP**, con el que mantiene compatibilidad de puertos. Ver **diagrama D13**.

DATO CLAVE

DHCP usa **UDP**, con el **puerto 67 en el servidor** y el **68 en el cliente**. La secuencia se memoriza con el acrónimo **DORA**: 1. **DISCOVER** — el cliente, que aún no tiene dirección, emite una **difusión** buscando servidores. 2. **OFFER** — uno o varios servidores **ofrecen** una dirección con sus parámetros. 3. **REQUEST** — el cliente **solicita formalmente** una de las ofertas, en difusión, para que los demás servidores retiren la suya. 4. **ACK** — el servidor **confirma** y entrega la **concesión** (*lease*) con su tiempo de vida. La concesión se **renueva** normalmente al **50 % de su duración** (temporizador **T1**) directamente con el servidor que la otorgó, y si no hay respuesta, al **87,5 %** (**T2**) se intenta con cualquiera.

Además de la dirección, la máscara, la pasarela y los servidores DNS, DHCP entrega **opciones** numeradas: dominio de búsqueda, servidor NTP, servidor de arranque en red **PXE**, o la opción 82 de información del agente de retransmisión.

Dos piezas clave:

- **Agente de retransmisión** (*DHCP relay*): como el DISCOVER es una **difusión** y las difusiones **no atraviesan encaminadores**, en redes con varias VLAN el encaminador actúa de **relay** y reenvía la petición al servidor central en unidifusión. Es la razón de que no haga falta un servidor DHCP por planta.
- **Reserva o asignación estática**: se vincula una dirección concreta a una **MAC** determinada. Es lo adecuado para impresoras y servidores, que necesitan una dirección estable pero se siguen gestionando de forma central.

IPv6: SLAAC y DHCPv6. En IPv6 conviven dos formas de configuración:

- **SLAAC** (*Stateless Address Autoconfiguration*, RFC 4862): el encaminador anuncia el **prefijo** de la red mediante mensajes **RA** (*Router Advertisement*, sobre ICMPv6) y **cada equipo se**

construye su propia dirección. **Sin estado**: el encaminador no lleva registro de quién tiene qué.

- **DHCPv6** (**RFC 9915**, enero de 2026, **STD 102**, que obsoleta el RFC 8415): funciona **con estado**, como el DHCP de IPv4, en los puertos **UDP 547** (servidor) y **546** (cliente). Existe también un modo **sin estado** que solo entrega parámetros (DNS, dominio) mientras la dirección la fija SLAAC.

> DATO CLAVE
>
> Diferencia conceptual: en IPv4 **la dirección la asigna el servidor DHCP**; en IPv6 **puede asignársela el propio equipo** a partir del prefijo anunciado (SLAAC). Consecuencia para la Administración: **SLAAC dificulta la trazabilidad**, porque no hay un registro central de concesiones; en una red donde se exija saber quién tenía cada dirección en cada momento —requisito derivado de la dimensión de **trazabilidad** del ENS— hay que usar **DHCPv6 con estado** o complementar SLAAC con vigilancia de la tabla de vecinos.

Riesgos de seguridad. DHCP no autentica: un **servidor DHCP no autorizado** (*rogue*) conectado a una toma de red puede repartir configuraciones falsas y convertirse en **intermediario** de todo el tráfico —basta con anunciarse como pasarela y como DNS—. La contramedida en la red conmutada es **DHCP snooping**, que solo admite respuestas DHCP por los puertos declarados de confianza; en IPv6, el equivalente frente a anuncios de encaminador falsos es **RA Guard**.

> EJEMPLO DE APLICACIÓN EN EL AYTO
>
> En una oficina de atención a la ciudadanía, las tomas de red de la zona de público son el punto débil clásico: cualquiera puede enchufar un equipo. Las medidas habituales son **deshabilitar las tomas no usadas**, **DHCP snooping** y **RA Guard** en el conmutador de planta, autenticación de puerto **802.1X**, y VLAN separada para los equipos que no son del Ayuntamiento. El respaldo normativo está en `mp.com.4` del ENS, «**separación de flujos de información en la red**», que exige segregar el tráfico y que las comunicaciones inalámbricas vayan en un segmento propio.

---

4. Protocolo HTTP

4.1. Fundamentos y versiones del protocolo HTTP

4.1.1. Modelo cliente-servidor y comunicación sin estado

Qué es HTTP. El *HyperText Transfer Protocol* es el protocolo de **capa de aplicación** que sostiene la Web. Nació con ella, en el CERN, y su nombre se ha quedado corto: hoy no transfiere solo hipertexto, sino **cualquier recurso** —imágenes, vídeo, JSON de una API, formularios— y es el

sustrato de los servicios web, de las aplicaciones móviles y de buena parte de la comunicación entre sistemas.

> DATO CLAVE
>
> **La especificación vigente de HTTP no es el RFC 2616.** Aquel documento de 1999 fue sustituido en 2014 por la serie RFC 7230-7235, y esta, en **junio de 2022**, por la serie actual: **RFC 9110 (semántica, STD 97)**, **RFC 9111 (caché, STD 98)**, **RFC 9112 (HTTP/1.1, STD 99)**, **RFC 9113 (HTTP/2)** y **RFC 9114 (HTTP/3)**. La reorganización tiene una lógica: **la semántica se separó de la sintaxis de cada versión**, de modo que los métodos, los códigos de estado y las cabeceras son **los mismos** en HTTP/1.1, HTTP/2 y HTTP/3; lo que cambia entre versiones es **cómo se transmiten**, no qué significan.

Modelo cliente-servidor y petición-respuesta. HTTP funciona por **turnos**: el cliente (normalmente un navegador, pero también una aplicación o un servicio) envía una **petición** y el servidor devuelve una **respuesta**. El servidor **nunca inicia** la conversación —el *server push* de HTTP/2 fue un intento de romperlo que acabó desactivado en la práctica—, y cuando hace falta comunicación iniciada por el servidor se recurre a **WebSocket** (RFC 6455), a los eventos enviados por el servidor (SSE) o al sondeo.

Entre ambos extremos puede haber **intermediarios**:

Intermediario	Posición	Función
Proxy directo (*forward proxy*)	Junto al **cliente**	Sale a Internet en su nombre: control de navegación, caché, filtrado
Proxy inverso (*reverse proxy*)	Junto al **servidor**	Recibe las peticiones externas, reparte carga, **termina el TLS**, protege el origen
Pasarela (*gateway*)	Delante del servidor	Traduce a otro protocolo
Túnel	Extremo a extremo	Retransmite sin interpretar (método `CONNECT`)
Caché	En cualquier punto	Guarda respuestas reutilizables (RFC 9111)

Sin estado: qué significa exactamente. HTTP es **sin estado** (*stateless*): **cada petición se interpreta de forma independiente** y el servidor **no recuerda** por sí mismo nada de las anteriores. Es una decisión de diseño deliberada, no una carencia: permite que cualquier servidor

de una granja atienda cualquier petición y es la razón de que la Web escale a miles de millones de usuarios.

> **DATO CLAVE**
>
> No hay que confundir **sin estado** con **sin conexión**. HTTP es **sin estado** en todas sus versiones. En cuanto a la conexión: **HTTP/1.0** abría y cerraba una conexión TCP **por cada recurso**; **HTTP/1.1 introdujo las conexiones persistentes** (`keep-alive`) **como comportamiento por defecto**, de modo que varias peticiones reutilizan la misma conexión. Reutilizar la conexión **no** convierte a HTTP en un protocolo con estado: el estado de la **aplicación** (que el usuario está identificado, qué lleva en el carrito) hay que construirlo aparte, con **cookies**, **sesiones** o **tokens** (§4.2.2).

La URL. El identificador que HTTP usa para nombrar recursos es la **URI**, en su forma localizadora **URL** (RFC 3986):

```
https://sede.madrid.es:443/tramites/licencias?id=471&pag=2#requisitos
└──┘   └──────────────┘└─┘└──────────────────┘└──────────┘└──────┘
esquema      autoridad  puerto     ruta          consulta   fragmento
```

Dos detalles: el **fragmento** (lo que va tras `#`) **no se envía al servidor**, lo procesa el navegador; y la **cadena de consulta** (tras `?`) **sí viaja**, y por tanto queda registrada en los *logs* del servidor y del proxy —razón por la cual **nunca deben ponerse datos sensibles ni contraseñas en la URL**, aunque se use HTTPS—.

4.1.2. Evolución desde HTTP/1.1 hasta HTTP/3

Ver **diagrama D15**.

Versión	Año / RFC	Aportación principal	Problema que dejó abierto
HTTP/0.9	1991	Una sola línea: `GET /pagina`. Sin cabeceras, sin códigos de estado, sin versiones	Solo servía documentos HTML
HTTP/1.0	1996, **RFC 1945**	**Cabeceras**, **códigos de estado**, `Content-Type` (con MIME), métodos `HEAD` y `POST`	Una conexión TCP por recurso
HTTP/1.1	1997/1999; hoy **RFC 9112**	**Conexiones persistentes**, cabecera `Host` **obligatoria** (hace posible el alojamiento virtual), transferencia **por trozos** (*chunked*), caché avanzada, peticiones de **rango**, *pipelining*	**Bloqueo de cabecera de línea** (*head-of-line blocking*) en la aplicación: las respuestas deben devolverse **en orden**
HTTP/2	2015; hoy **RFC 9113**	Protocolo **binario** en lugar de textual, **multiplexación** de varias corrientes (*streams*) sobre **una** conexión TCP, compresión de cabeceras **HPACK** (RFC 7541), priorización, *server push*	Persiste el bloqueo de cabecera de línea **en TCP**: la pérdida de **un** segmento detiene **todas** las corrientes
HTTP/3	2022, **RFC 9114**	Cambia el transporte: se apoya en **QUIC** (**RFC 9000**) sobre **UDP**. **Elimina** el bloqueo de cabecera de línea del transporte, cifrado **obligatorio** e integrado, compresión **QPACK** (RFC 9204), **establecimiento en 1-RTT (0-RTT en reanudación)** y **migración de conexión** por identificador	Requiere UDP abierto; dificulta la inspección en los equipos intermedios

DATO CLAVE

El bloqueo de cabecera de línea explica toda la evolución de HTTP, y es la idea conceptual del epígrafe: - En **HTTP/1.1** el bloqueo es **de aplicación**: por una conexión las respuestas van en orden, y una lenta retrasa a las siguientes (por eso los navegadores abrían **6 conexiones por dominio**). - **HTTP/2** lo resuelve **en la capa de aplicación** con multiplexación… pero **no en TCP**: como TCP garantiza la entrega ordenada, un segmento perdido bloquea a **todas** las corrientes que viajan por esa conexión. - **HTTP/3** lo resuelve del todo porque **QUIC gestiona cada corriente de forma independiente** sobre UDP: la pérdida en una no detiene a las demás.

Qué es QUIC. Un protocolo de transporte publicado como **RFC 9000** (mayo de 2021) que se ejecuta **sobre UDP** y reimplementa en el **espacio de usuario** lo que TCP hace en el núcleo:

fiabilidad, orden por corriente, control de congestión. Su rasgo definitorio es que **integra TLS 1.3 en el propio establecimiento** (RFC 9001): no hay un saludo TCP y luego otro TLS, sino **uno solo**. De ahí que HTTP/3 sea **siempre cifrado**: no existe un «HTTP/3 en claro».

> **DATO CLAVE**
>
> Dos ventajas de QUIC: (1) **0-RTT en la reanudación**, que permite enviar datos con el primer paquete cuando ya se ha hablado antes con ese servidor —a costa de perder la protección frente a **repetición** (*replay*), por lo que solo debe usarse con peticiones **idempotentes**—; y (2) la **migración de conexión**: como la conexión se identifica por un **identificador propio** y no por la cuádrupla IP/puerto, un móvil que pasa de Wi-Fi a red móvil **conserva la sesión** sin reconectar.

Cómo se negocia la versión. No hay una elección manual: **HTTP/2 se negocia dentro del saludo TLS mediante la extensión ALPN** (*Application-Layer Protocol Negotiation*, RFC 7301); **HTTP/3 se descubre** porque el servidor lo anuncia en la cabecera `Alt-Svc` o en un registro DNS de tipo **HTTPS**, y el cliente **prueba** entonces por UDP y conserva HTTP/2 como respaldo. Ese matiz explica por qué las estadísticas de adopción varían tanto según se mida «sitios que lo anuncian» o «peticiones realmente servidas».

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Para una sede electrónica, migrar a HTTP/2 o HTTP/3 no es una cuestión estética: mejora de forma perceptible la carga de páginas con muchos recursos —hojas de estilo, tipografías, iconos, formularios— y sobre todo la experiencia en **red móvil**, que es como accede una parte creciente de la ciudadanía. Como HTTP/2 y HTTP/3 exigen TLS en la práctica, el requisito previo es tener **HTTPS bien configurado** (§5), y el despliegue típico se hace en el **proxy inverso** o el balanceador, sin tocar la aplicación.

4.2. Mensajes HTTP y mecanismos de estado

4.2.1. Estructura de mensajes, métodos y códigos de respuesta

Anatomía del mensaje. Un mensaje HTTP/1.1 tiene tres partes: la **línea de inicio**, un bloque de **cabeceras** (`Nombre: valor`, una por línea) y, tras **una línea en blanco**, un **cuerpo** opcional. En HTTP/2 y HTTP/3 la información es la misma, pero **codificada en binario** y comprimida. Ver **diagrama D14**.

Petición:

```
GET /tramites/licencias?id=471 HTTP/1.1
Host: sede.madrid.es
User-Agent: Mozilla/5.0
```

```
Accept: text/html,application/xhtml+xml
Accept-Language: es-ES,es;q=0.9
Cookie: JSESSIONID=8F2A...
```

Respuesta:

```
HTTP/1.1 200 OK
Date: Thu, 27 Aug 2026 09:15:22 GMT
Content-Type: text/html; charset=utf-8
Content-Length: 34871
Cache-Control: no-store
Strict-Transport-Security: max-age=31536000; includeSubDomains

<!DOCTYPE html> ...
```

Los métodos. El método declara la **acción** solicitada sobre el recurso. Las dos propiedades que los clasifican son la **seguridad** y la **idempotencia**:

Método	¿Seguro?	¿Idempotente?	¿Cuerpo?	Uso
GET	**Sí**	**Sí**	No	Recuperar un recurso
HEAD	**Sí**	**Sí**	No	Como GET, pero **solo las cabeceras**
OPTIONS	**Sí**	**Sí**	No	Consultar capacidades; base de **CORS**
TRACE	**Sí**	**Sí**	No	Eco de diagnóstico; **debe deshabilitarse** en producción
POST	**No**	**No**	Sí	Enviar datos, crear subordinados, formularios
PUT	**No**	**Sí**	Sí	**Sustituir por completo** el recurso
PATCH	**No**	**No**	Sí	Modificación **parcial**
DELETE	**No**	**Sí**	Opcional	Borrar el recurso
CONNECT	No	No	—	Establecer un **túnel** (proxy HTTPS)

DATO CLAVE

Definiciones exactas: **seguro** significa que el método **no pretende modificar** el estado del servidor (es de solo lectura). **Idempotente** significa que **repetir la misma petición varias veces produce el mismo efecto que hacerla una vez**. Todo método seguro es idempotente, pero **no al revés**: `PUT` y `DELETE` son **idempotentes y no seguros** (borrar dos veces deja el recurso igualmente borrado). **`POST` no es ninguna de las dos cosas** —por eso el navegador avisa al recargar un formulario enviado— y **`PATCH` no es idempotente**. Trampa habitual: presentar `DELETE` como «no idempotente porque el segundo intento da 404»; el código de respuesta puede cambiar, pero **el efecto sobre el servidor es el mismo**, y la idempotencia se define por el efecto.

DATO CLAVE

GET frente a POST en un formulario: con `GET` los datos viajan en la **URL** (visibles, registrados en los *logs*, limitados en longitud, guardables en marcadores y en el historial); con `POST` viajan en el **cuerpo**. Precisión importante: **`POST` no cifra nada**. Lo único que protege el contenido es **HTTPS**. `POST` simplemente evita que el dato quede escrito en la URL.

Los códigos de estado. Un número de tres cifras cuya **primera cifra indica la familia**:

Familia	Significado	Códigos que hay que saber
1xx	**Informativo**: la petición se recibió, el proceso continúa	100 Continue · 101 Switching Protocols
2xx	**Éxito**	**200 OK** · 201 Created · 202 Accepted · **204 No Content** · 206 Partial Content
3xx	**Redirección**: se requiere una acción adicional	**301 Moved Permanently** · **302 Found** (temporal) · **304 Not Modified** (usa la caché) · 307 Temporary Redirect · 308 Permanent Redirect
4xx	**Error del cliente**	400 Bad Request · **401 Unauthorized** · **403 Forbidden** · **404 Not Found** · 405 Method Not Allowed · 409 Conflict · 413 Content Too Large · **429 Too Many Requests**
5xx	**Error del servidor**	**500 Internal Server Error** · 501 Not Implemented · **502 Bad Gateway** · **503 Service Unavailable** · **504 Gateway Timeout**

DATO CLAVE

Las tres parejas clave: - **401 frente a 403**: **401 = no estás autenticado** (o tus credenciales no valen); vuelve a identificarte. **403 = estás autenticado pero no tienes permiso**; volver a identificarte no servirá de nada. Autenticación frente a autorización. - **301 frente a 302**: **301 es permanente** —el navegador y los buscadores **actualizan el destino** y la cachean de forma agresiva, por lo que **equivocarse es caro**— y **302/307 es temporal**. - **502 frente a 504**: **502** es una respuesta **inválida** del servidor de origen a la pasarela; **504** es que el origen **no respondió a tiempo**. Ambos los devuelve el intermediario, no la aplicación. Y una precisión de vocabulario: **404 significa «no encontrado»**, no «la web no funciona»; si el servidor estuviera caído, no habría respuesta HTTP alguna o sería **503**.

EJERCICIO RESUELTO

Enunciado: en la traza de acceso de la sede electrónica se observa que una IP concreta ha generado **8.400 peticiones `POST` al formulario de acceso en cinco minutos**, con respuestas `401`, y que a continuación aparecen `429`. Interprete la secuencia y proponga dos medidas. **Solución**: (1) `POST` repetidos contra el formulario de acceso con respuesta **401** indican **intentos de autenticación fallidos**: es un ataque de **fuerza bruta** o de **relleno de credenciales**. (2) El **429 Too Many Requests** indica que ya está actuando un mecanismo de **limitación de tasa** (*rate limiting*), que ha empezado a rechazar por volumen. (3) Medidas: **bloqueo temporal progresivo** de la cuenta y del origen, **segundo factor** de autenticación, prueba de humanidad tras N fallos, y **vigilancia con alerta** al detectar el patrón. (4) Anclaje normativo: `op.acc.5` del ENS sobre el mecanismo de autenticación —que para usuarios externos prevé la limitación de intentos— y `mp.s.4`, protección frente a la **denegación de servicio**, si el volumen degrada el servicio. **Ojo al matiz**: el `401` no es un fallo del servidor; es el sistema funcionando y rechazando correctamente.

4.2.2. Cabeceras HTTP, cookies y sesiones

Familias de cabeceras. Se clasifican en **generales** (`Date` , `Connection`), **de petición** (`Host` , `User-Agent` , `Accept` , `Authorization` , `Referer` , `Cookie`), **de respuesta** (`Server` , `Set-Cookie` , `Location` , `WWW-Authenticate`) y **de entidad o representación** (`Content-Type` , `Content-Length` , `Content-Encoding` , `Last-Modified` , `ETag`).

La negociación de contenido merece mención propia: mediante las cabeceras `Accept` , `Accept-Language` , `Accept-Encoding` y `Accept-Charset` , el cliente declara **qué prefiere** con valores de calidad (`q=0.9`), y el servidor elige la representación. Es el mecanismo que permite servir la misma URL en español o en inglés, comprimida o sin comprimir.

La caché (RFC 9111) se controla sobre todo con `Cache-Control` (`no-store` , `no-cache` , `private` , `public` , `max-age`) y con la **validación condicional**: el servidor envía `ETag` o `Last-`

`Modified`, y el cliente pregunta después con `If-None-Match` o `If-Modified-Since`; si nada ha cambiado, el servidor responde **`304 Not Modified` sin cuerpo**, ahorrando la transferencia.

> DATO CLAVE
>
> Diferencia entre **`no-cache`** y **`no-store`**, que tiene trampa: **`no-cache` sí permite almacenar** la respuesta, pero obliga a **revalidarla** con el servidor antes de reutilizarla. **`no-store` prohíbe almacenarla** en cualquier caché. Para páginas con **datos personales** de una sede electrónica, la correcta es **`no-store`** (junto con `private`), porque impide que la respuesta quede en la caché del navegador de un puesto compartido.

Cookies. Como HTTP no tiene estado, el estado se transporta con **cookies** (**RFC 6265**): el servidor envía `Set-Cookie: nombre=valor; atributos` y el navegador **devuelve** `Cookie: nombre=valor` en cada petición siguiente al mismo ámbito. Ver **diagrama D16**.

Atributo	Efecto
`Expires` / **`Max-Age`**	Si faltan, la cookie es **de sesión** y muere al cerrar el navegador; si están, es **persistente**
`Domain` / **`Path`**	Ámbito al que se enviará
`Secure`	**Solo se envía por HTTPS**
`HttpOnly`	**Inaccesible desde JavaScript** → mitiga el robo por **XSS**
`SameSite` (`Strict`, `Lax`, `None`)	Controla el envío en peticiones de **origen cruzado** → mitiga **CSRF**

> DATO CLAVE
>
> Combinación mínima para una cookie de sesión de un servicio público: **`Secure`** + **`HttpOnly`** + **`SameSite=Lax`** **(o `Strict`)**, con identificador **aleatorio, largo e impredecible**, **renovado tras el inicio de sesión** —para evitar la **fijación de sesión**— y con **caducidad por inactividad**. Nótese que `Secure` y `HttpOnly` protegen frente a amenazas **distintas**: la primera frente a la interceptación en red, la segunda frente al robo por *script*.

Sesiones frente a tokens. Dos modelos de mantener el estado:

- **Sesión en el servidor**: la cookie solo transporta un **identificador opaco**; los datos viven en el servidor. Ventaja: se puede **revocar al instante**. Inconveniente: exige estado compartido entre los nodos de la granja.

- **Token autocontenido** (típicamente **JWT**): el propio testigo lleva la información firmada. Ventaja: **sin estado**, escala mejor. Inconveniente: **no se puede revocar** antes de su caducidad sin añadir una lista de revocación, y **firmado no es cifrado** —su contenido es legible por quien lo tenga—.

Cabeceras de seguridad. Un servicio web público debe enviar, como mínimo:

Cabecera	Para qué
`Strict-Transport-Security` (HSTS)	Obliga al navegador a usar **siempre HTTPS** en ese dominio
`Content-Security-Policy`	Declara de dónde puede cargarse cada tipo de recurso → principal mitigación de **XSS**
`X-Content-Type-Options: nosniff`	Impide que el navegador **adivine** el tipo de contenido
`X-Frame-Options` / `frame-ancestors`	Impide el enmarcado del sitio → mitiga el **secuestro de clic** (*clickjacking*)
`Referrer-Policy`	Limita qué URL de origen se filtra al navegar a otro sitio
`Permissions-Policy`	Restringe el acceso a cámara, micrófono o geolocalización

> RELACIÓN CON OTROS TEMAS
>
> Las vulnerabilidades web que estas cabeceras mitigan —**XSS**, **CSRF**, inyección, control de acceso roto— y su catálogo **OWASP** se desarrollan en el **Tema 23** (aplicaciones web) y en el **Tema 25** (seguridad en el desarrollo). Las arquitecturas de servicios web (REST, SOAP) y sus protocolos, en el **Tema 22**.

---

5. Protocolos SSL/TLS y HTTPS

5.1. Protocolos de seguridad SSL y TLS

5.1.1. Arquitectura, subprotocolos y negociación TLS

Qué problema resuelve. HTTP, SMTP, IMAP o FTP viajan **en claro**: cualquiera que observe la red puede leerlos y modificarlos. **TLS** (*Transport Layer Security*) es un protocolo **de propósito general** que se interpone entre la capa de transporte y la de aplicación y aporta tres garantías:

1. **Confidencialidad**: los datos van cifrados.
2. **Integridad**: cualquier alteración se detecta.
3. **Autenticación**: **siempre la del servidor** mediante certificado; **opcionalmente la del cliente** (autenticación mutua, la que se usa con certificado electrónico en una sede).

Lo que TLS **no** hace: no protege el equipo del usuario ni el del servidor, no garantiza que el sitio sea honrado —solo que es **quien dice ser**—, y no oculta **con quién** se comunica uno.

De SSL a TLS: la historia y las versiones. SSL (*Secure Sockets Layer*) fue creado por **Netscape**: la versión 1.0 nunca se publicó, la **2.0** salió en 1995 con fallos graves y la **3.0**, en 1996, fue un rediseño completo. En **1999** el IETF toma el relevo, y para evitar una marca comercial lo renombra **TLS 1.0** (RFC 2246), que es esencialmente SSL 3.1.

> DATO CLAVE
>
> Estado de las versiones de SSL y TLS en 2026: ver la tabla siguiente.

Versión	Año	Estado en 2026
SSL 2.0	1995	**Prohibido** (RFC 6176)
SSL 3.0	1996	**Prohibido** (**RFC 7568**), roto por **POODLE** (2014)
TLS 1.0	1999	**Obsoleto** (**RFC 8996**, 2021)
TLS 1.1	2006	**Obsoleto** (RFC 8996)
TLS 1.2	2008	**Vigente**, mínimo admisible
TLS 1.3	2018 (RFC 8446), **reeditado en julio de 2026 como RFC 9846**	**Vigente y recomendado**

Consecuencia práctica: **«SSL» hoy es solo un nombre coloquial**. Cuando alguien dice «certificado SSL» quiere decir **certificado TLS**, y cuando un pliego exige «SSL/TLS» está exigiendo, en rigor, **TLS 1.2 o superior**. Todo lo que se llame SSL de verdad está prohibido.

DATO CLAVE

Dato reciente y diferencial. En **julio de 2026** el IETF publicó el **RFC 9846**, que reedita la especificación de **TLS 1.3** y **obsoleta el RFC 8446** —la referencia que citan todos los temarios— **y también el RFC 5246**, que especificaba **TLS 1.2**, junto con los RFC 5077, 6961, 7627 y 8422. Hay que entender bien qué significa: **no prohíbe TLS 1.2**, que sigue siendo admisible; lo que hace es **unificar la especificación en un solo documento** y fijar en él requisitos adicionales para las implementaciones de TLS 1.2 (protección frente a degradación de versión, `supported_versions`, RSASSA-PSS, y la sustitución de la terminología *master* por *main*). Al citar TLS en un documento técnico en 2026, **la referencia correcta es el RFC 9846**.

Arquitectura en dos niveles. TLS se organiza en un protocolo de base y varios subprotocolos que viajan dentro de él. Ver **diagrama D17**.

Subprotocolo	Función
Record (registro)	**El de abajo**: fragmenta, comprime (ya no en 1.3), **cifra y protege la integridad** de todo lo que transportan los demás. Todos los otros subprotocolos van **dentro** de él
Handshake (saludo)	Negocia versión y algoritmos, **autentica** mediante certificado y **acuerda las claves** de sesión
Alert (alerta)	Comunica errores y cierres, con dos niveles: *warning* y **fatal**
Change Cipher Spec	Señalaba el cambio a los parámetros recién negociados. **En TLS 1.3 desaparece funcionalmente** y solo se conserva como relleno por compatibilidad con equipos intermedios
Application Data	Los datos de la aplicación ya protegidos

DATO CLAVE

El subprotocolo **fundamental** o de más bajo nivel es el **Record Protocol**, porque **encapsula a todos los demás**, incluido el Handshake. Y el que **acuerda las claves** es el **Handshake**.

El saludo TLS 1.2 (dos vueltas). Simplificado:

1. **ClientHello**: versión máxima, número aleatorio, lista de **suites de cifrado**, extensiones (**SNI**, **ALPN**).
2. **ServerHello**: versión y suite elegidas, su número aleatorio; **Certificate** con la cadena; **ServerKeyExchange** si procede; **ServerHelloDone**.

3. El cliente **valida el certificado**, genera el material de clave (**ClientKeyExchange**), envía **ChangeCipherSpec** y **Finished**.
4. El servidor responde **ChangeCipherSpec** y **Finished**. A partir de ahí, datos cifrados.

El saludo TLS 1.3 (una vuelta). El cambio de diseño es sustancial: el cliente **ya envía en el ClientHello su parte del intercambio Diffie-Hellman** (extensión `key_share`) apostando por los grupos más probables, de modo que el servidor puede responder con su parte, el certificado **ya cifrado** y su `Finished` en un solo viaje: **1-RTT**. Si ya hubo conexión previa, se puede reanudar con **0-RTT**.

> DATO CLAVE
>
> Las cinco novedades de **TLS 1.3**: 1. **Saludo en 1-RTT** (0-RTT en reanudación) frente a los 2-RTT de TLS 1.2. 2. **Confidencialidad directa obligatoria** (*forward secrecy*): **se elimina el intercambio de claves RSA estático**; solo hay Diffie-Hellman efímero (**ECDHE/DHE**). Consecuencia: **comprometer la clave privada del servidor no permite descifrar el tráfico capturado en el pasado**. 3. **Solo cifrado autenticado con datos asociados (AEAD)**: AES-GCM, AES-CCM, ChaCha20-Poly1305. Se eliminan RC4, 3DES, CBC con MAC-then-encrypt, y también la **compresión** (por CRIME) y la **renegociación**. 4. **La suite de cifrado se simplifica**: ya solo nombra el algoritmo de registro y el hash; el intercambio de claves y la autenticación se negocian aparte por extensiones. 5. **Todo lo posterior al ServerHello va cifrado**, incluido el **certificado del servidor**. Trampa frecuente: creer que TLS 1.3 «elimina RSA». **No**: elimina RSA **como método de intercambio de claves**; RSA **sigue admitido para la firma** del certificado.

La suite de cifrado. En TLS 1.2 se lee de izquierda a derecha, y saber desmenuzarla es un buen ejercicio:

```
TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256
    └──┘ └┘      └─────────┘ └──┘
 intercambio │       cifrado    hash/PRF
          autenticación
```

- **ECDHE**: intercambio de claves **efímero** de curva elíptica → aporta confidencialidad directa.
- **RSA**: algoritmo con el que **firma** el servidor (su certificado es RSA).
- **AES_128_GCM**: cifrado simétrico **autenticado**.
- **SHA256**: función hash de la derivación de claves.

En **TLS 1.3** la misma suite se escribiría simplemente `TLS_AES_128_GCM_SHA256`, porque lo demás se negocia por separado.

DATO CLAVE

Migración post-cuántica: el estado real en 2026. Los navegadores mayoritarios negocian ya por defecto un intercambio de claves **híbrido** que combina el clásico **X25519** con el algoritmo post-cuántico **ML-KEM-768** (FIPS 203), bajo el nombre **X25519MLKEM768** (**valor IANA 4588,** `0x11EC`). Dos precisiones que casi ningún temario recoge: (1) su especificación, `draft-ietf-tls-ecdhe-mlkem` , **todavía no era RFC en agosto de 2026** —estaba aprobada y en cola de publicación—, y (2) lo que se protege es la **clave de sesión**, no la **firma**: los certificados siguen firmados con **RSA o ECDSA** clásicos. El motivo de desplegarlo ya es el ataque de **«cosechar ahora, descifrar después»**: quien capture hoy tráfico cifrado podría descifrarlo en el futuro con un ordenador cuántico. En España, los algoritmos admisibles en sistemas del ENS los fija la guía **CCN-STIC-807**, que es la referencia que hay que citar en un pliego.

5.1.2. Criptografía, certificados digitales e infraestructura PKI

El cifrado híbrido. TLS combina las dos familias criptográficas porque cada una resuelve la mitad del problema: la **asimétrica** (RSA, ECDSA, EdDSA, Diffie-Hellman) es lenta pero permite **acordar un secreto con un desconocido** y **autenticar**; la **simétrica** (AES, ChaCha20) es rápida pero exige compartir la clave antes. La solución es el **sobre digital**: el saludo usa criptografía **asimétrica** para acordar una **clave de sesión**, y todo el tráfico posterior se cifra con esa clave, de forma **simétrica**.

RELACIÓN CON OTROS TEMAS

Los fundamentos de la criptografía simétrica y asimétrica, las funciones hash, la PKI completa y los **mecanismos de firma digital** se desarrollan en el **Tema 32**. Aquí se tratan solo en la medida en que TLS y HTTPS los usan.

El certificado X.509. Un certificado digital (**X.509 v3**, **RFC 5280**) es un documento electrónico que **vincula una identidad con una clave pública** y que va **firmado por una autoridad de certificación (AC)**. Sus campos esenciales:

Campo	Contenido
Versión y **número de serie**	v3; serie única del emisor
Emisor (*issuer*)	La AC que lo firma
Sujeto (*subject*)	El titular; en un certificado de servidor, su nombre de dominio
Validez	`notBefore` y `notAfter`
Clave pública	Algoritmo y clave del titular
Extensiones	**`subjectAltName` (SAN)**, `keyUsage`, `extendedKeyUsage`, `basicConstraints`, `cRLDistributionPoints`, acceso a información de la AC
Firma de la AC	Lo que hace confiable a todo lo anterior

DATO CLAVE

El nombre del sitio ya **no se valida por el campo `CN`** del sujeto, sino por la extensión **`subjectAltName` (SAN)**, que es la única que miran los navegadores modernos y la que permite **múltiples nombres** en un solo certificado. Tipos según cobertura: **de un solo nombre**, **comodín** (*wildcard*, `*.madrid.es`, que cubre **un solo nivel** de subdominio) y **multidominio (SAN/UCC)**.

Tipos por nivel de validación:

Tipo	Qué comprueba la AC	Uso
DV (*Domain Validated*)	Solo el **control del dominio**	Automatizable; el más extendido
OV (*Organization Validated*)	Además, la **existencia de la organización**	Sedes y organizaciones
EV (*Extended Validation*)	Comprobación reforzada de la entidad	Su valor ha caído: los navegadores **retiraron la barra verde** distintiva

La cadena de confianza. El navegador no confía en el certificado del servidor directamente, sino que **construye una cadena**: certificado de servidor → una o varias **AC intermedias** → una **AC raíz** que ya está en el **almacén de confianza** del sistema o del navegador. La validación comprueba, en

cada eslabón: la **firma**, la **vigencia**, que el nombre solicitado esté en el **SAN**, que las **restricciones básicas** permitan actuar como AC, y **que no esté revocado**. Ver **diagrama D18**.

Revocación. Un certificado puede dejar de ser fiable antes de caducar (clave comprometida, cese de la organización). Hay dos mecanismos clásicos:

Mecanismo	Cómo funciona	Problema
CRL (RFC 5280)	Lista firmada de números de serie revocados, publicada periódicamente	Puede estar **desactualizada**; es grande
OCSP (**RFC 6960**)	Consulta **en línea** del estado de **un** certificado: `good`, `revoked`, `unknown`	Añade latencia, exige disponibilidad del respondedor y **filtra a la AC qué sitios visita cada usuario** (problema de **privacidad**)
OCSP stapling	**El propio servidor** adjunta en el saludo una respuesta OCSP reciente y firmada	Resuelve latencia y privacidad; requiere configurarlo

DATO CLAVE

La revocación está siendo sustituida por la caducidad rápida, y es la tendencia más importante del epígrafe. Dos hechos verificados: (1) **Let's Encrypt apagó su servicio OCSP el 6 de agosto de 2025** por motivos de privacidad, y emite ya certificados **de seis días**; (2) el **CA/Browser Forum** aprobó en abril de 2025 el acuerdo **SC-081v3**, que reduce la vida máxima de un certificado TLS público en tres escalones: **200 días desde el 15 de marzo de 2026**, **100 días desde el 15 de marzo de 2027** y **47 días desde el 15 de marzo de 2029**. La lógica es que **un certificado que dura poco no necesita revocarse**: caduca antes de que la revocación llegue a propagarse.

EJERCICIO RESUELTO

Enunciado: el Ayuntamiento renueva hoy, agosto de 2026, el certificado de `sede.madrid.es` y el proveedor ofrece «un año de validez». ¿Es posible? ¿Qué consecuencia organizativa tiene la respuesta? **Solución**: **no es posible** para un certificado TLS público. Desde el **15 de marzo de 2026** el máximo admitido por el CA/Browser Forum es de **200 días**, y los navegadores rechazan los que excedan ese límite, de modo que la oferta o es errónea o se refiere a un certificado que no es de servidor web público. **Consecuencia organizativa, que es lo que de verdad se evalúa**: con 200 días hoy, 100 en 2027 y 47 en 2029, **la renovación manual anotada en la agenda deja de ser viable**. Hay que implantar **renovación automatizada** (por ejemplo con el protocolo **ACME**), **inventario de certificados** con responsable asignado y **alertas** con antelación suficiente. La caducidad de un certificado es una causa banal y muy frecuente de caída de servicios públicos, y desde 2029 el margen de error será de mes y medio.

EJEMPLO DE APLICACIÓN EN EL AYTO

En una sede electrónica conviven **dos usos distintos de certificado** que no hay que mezclar: el **certificado de sede electrónica** —que identifica al sitio ante la ciudadanía y da soporte al canal seguro, art. 38 de la Ley 40/2015— y los **certificados de las personas usuarias** (DNI electrónico, certificado de la FNMT, Cl@ve) con los que la ciudadanía **se identifica y firma**. El primero opera en la **capa TLS**; los segundos, en la capa de **aplicación** —salvo que se configure autenticación TLS mutua—. Confundirlos es un error conceptual frecuente en los casos prácticos.

5.2. Protocolo HTTPS

5.2.1. Funcionamiento de HTTP sobre TLS

Qué es exactamente HTTPS. No es un protocolo distinto de HTTP. Es **HTTP transportado dentro de una sesión TLS**, con el esquema de URL `https://` y el puerto **443** por defecto. La semántica —métodos, códigos, cabeceras— es **idéntica**. Históricamente se describía en el **RFC 2818**, hoy **obsoleto**: la definición vigente está integrada en el **RFC 9110**, §4.2.2.

DATO CLAVE

El **orden de las capas** es clave: **TCP → TLS → HTTP**. Primero se establece la conexión **TCP** (saludo en tres pasos), después el **saludo TLS**, y solo entonces viaja el **mensaje HTTP**, ya cifrado. En **HTTP/3** el esquema cambia: **UDP → QUIC (con TLS 1.3 integrado) → HTTP/3**, y el saludo es **uno solo**.

Qué protege y qué no. Esta distinción es la idea conceptual del epígrafe:

Sí protege	No protege ni oculta
El **cuerpo** de la petición y de la respuesta	La **dirección IP** del servidor de destino
Las **cabeceras**, incluidas `Cookie` y `Authorization`	El **nombre del servidor** solicitado, visible en la extensión **SNI** del ClientHello (salvo con **ECH**)
La **ruta y la cadena de consulta** de la URL	El **tamaño** y el **patrón temporal** del tráfico
La **integridad**: no se puede alterar el contenido en tránsito	Las **consultas DNS** previas, si no se usa DoT o DoH
La **identidad del servidor** mediante certificado	Nada de lo que ocurra **en los extremos**

DATO CLAVE

SNI (*Server Name Indication*) es la extensión del saludo TLS con la que el cliente dice **a qué nombre de sitio quiere conectarse**, y es imprescindible para alojar **varios sitios HTTPS en una misma dirección IP**. Su problema es que **viaja en claro** —tiene que hacerlo: el servidor aún no sabe qué certificado presentar—, de modo que un observador de la red **sabe qué sitio se visita aunque no vea el contenido**. La solución en despliegue es **ECH** (*Encrypted Client Hello*), que cifra esa parte del saludo. Es el equivalente exacto, en la Web, del problema de privacidad que DoH resuelve en el DNS.

Mecanismos de refuerzo. Sobre HTTPS se han construido varias defensas complementarias:

- **HSTS** (*HTTP Strict Transport Security*, **RFC 6797**): la cabecera `Strict-Transport-Security: max-age=...` obliga al navegador a usar **siempre HTTPS** con ese dominio durante el plazo indicado, **incluso si el usuario escribe** `http://`. Combate el **ataque de degradación** (*SSL stripping*), en el que un intermediario convierte los enlaces a HTTP. Existe además una **lista de precarga** (*preload*) que incorpora el dominio al propio navegador, de modo que la protección se aplica **desde la primera visita**.
- **Redirección permanente 301** de todo el tráfico HTTP a HTTPS: necesaria, pero **insuficiente por sí sola**, porque la primera petición aún viaja en claro. Por eso se combina con HSTS.
- **CAA** (registro DNS): declara **qué AC** puede emitir certificados para el dominio.
- **Transparencia de certificados (CT)**: obliga a publicar cada certificado emitido en registros públicos **auditables**, de modo que un titular puede detectar emisiones indebidas para su dominio.

- **Contenido mixto**: si una página servida por HTTPS carga un recurso por HTTP, el navegador **lo bloquea** o lo degrada; una web pública no debe tener ni un solo recurso mixto.

EJERCICIO RESUELTO

Enunciado: un usuario escribe `sede.madrid.es` en la barra del navegador, sin `https://`, y ve el candado. Enumere lo que ha ocurrido y señale dónde estaba el único momento de riesgo. **Solución**: (1) el navegador consulta el **DNS** —salvo que el dominio esté en la lista **HSTS preload** o ya lo hubiera visitado, en cuyo caso el navegador reescribe la URL a `https://` **antes de nada**—; (2) abre **TCP** contra el puerto correspondiente; (3) si la petición fue a HTTP/80, el servidor responde **301** a `https://`; (4) el navegador abre **TCP/443** y ejecuta el **saludo TLS**, enviando el **SNI**; (5) **valida la cadena** del certificado —firma, vigencia, SAN, revocación—; (6) se acuerdan las claves y se envía la **petición HTTP cifrada**; (7) la respuesta incluye la cabecera **HSTS**, que evitará el paso (3) las próximas veces. **El único momento de riesgo es el paso (3)**: esa **primera petición en claro** es interceptable, y es exactamente lo que elimina la **precarga de HSTS**. Es también la razón de que la respuesta «con la redirección 301 ya es suficiente» sea incorrecta.

---

6. Seguridad y normativa en la Administración Pública

> **Material complementario.** El enunciado oficial de este tema no nombra este apartado. Se mantiene porque sitúa la materia en el Ayuntamiento y en la normativa que le aplica, pero lo exigible es lo que enumera el título del tema.

6.1. Requisitos de seguridad en servicios web públicos

6.1.1. Esquema Nacional de Seguridad y sedes electrónicas

Por qué este bloque cierra el tema. Todo lo anterior es tecnología común a cualquier organización. Lo que distingue a una Administración es que **publicar un servicio en internet no es una decisión libre**: está sujeta a un marco jurídico que impone requisitos concretos, exigibles y auditables. Un opositor a la Administración debe saber **traducir cada mecanismo técnico del tema en la norma que lo respalda**.

El marco, ordenado por capas.

Norma	Qué aporta a un servicio web público
Ley 39/2015 (LPACAP)	Derecho de la ciudadanía a **relacionarse electrónicamente**; **obligación** para las personas jurídicas (art. 14); sistemas de **identificación** (art. 9) y **firma** (art. 10); registro electrónico (art. 16)
Ley 40/2015 (LRJSP)	**Sede electrónica (art. 38)**, **portal de internet (art. 39)**, **sistemas de firma** de la Administración: sello electrónico y **CSV** (arts. 40-43), **actuación administrativa automatizada (art. 41)**, y el **art. 156**, que da fundamento legal al **ENI** y al **ENS**
RD 203/2021	Reglamento de actuación por medios electrónicos: desarrolla sede, sede asociada, **punto de acceso general**, CSV, archivo electrónico
RD 311/2022 (ENS)	Medidas de seguridad **exigibles y auditables** sobre el servicio
RD 4/2010 (ENI) y sus **NTI**	**Interoperabilidad**: documento y expediente electrónicos, política de firma, **reutilización**, y el requisito de **neutralidad tecnológica**
RGPD y **LOPDGDD**	Tratamiento de datos personales, **seguridad del tratamiento** (art. 32 RGPD), información y ejercicio de derechos
LSSI-CE (Ley 34/2002), art. 22.2	**Consentimiento para las cookies** no imprescindibles; competencia de la **AEPD**
RD 1112/2018	**Accesibilidad** de sitios web y aplicaciones móviles del sector público: **UNE-EN 301 549** y **declaración de accesibilidad** obligatoria
Directiva NIS2 (UE) 2022/2555	Refuerzo de la ciberseguridad y de la notificación de incidentes; la Administración local queda afectada en los términos de su transposición

DATO CLAVE

La sede electrónica se define en el **art. 38 de la Ley 40/2015** como la dirección electrónica **disponible a través de redes de telecomunicaciones** cuya **titularidad corresponde a una Administración Pública**, o a uno o varios organismos públicos en el ejercicio de sus competencias. Tres notas: (1) la **titularidad, la gestión y la administración** corresponden a la Administración —una sede **no puede** ser un sitio de un tercero—; (2) sujeta a los principios de **transparencia, publicidad, responsabilidad, calidad, seguridad, disponibilidad, accesibilidad, neutralidad e interoperabilidad**; y (3) sus comunicaciones deben realizarse **mediante sistemas de firma electrónica basados en certificados de sede electrónica** que garanticen la identificación y la comunicación segura. **La sede es responsabilidad de la Administración titular; el portal de internet (art. 39) no tiene ese régimen reforzado.**

Las medidas del ENS que se aplican a un servicio web, verificadas contra el anexo II del RD 311/2022:

Medida	Denominación literal	Dimensión / categoría	Qué exige, en lo esencial
`mp.s.1`	Protección del correo electrónico	Categoría · **las tres**	Proteger contenido y **datos de encaminamiento**, actuar frente a **correo no solicitado**, **código dañino** y **código móvil**, normativa de uso y **concienciación**
`mp.s.2`	Protección de **servicios y aplicaciones web**	Categoría · **las tres**	Evitar la manipulación en el acceso, prevenir el **escalado de privilegios** y los ataques de **secuencias de órdenes en sitios cruzados** (*cross-site scripting*), y **auditar**: `[R1 o R2]` ya en categoría **BÁSICA** (caja negra o caja blanca) y `+R2 +R3` en **ALTA**
`mp.s.3`	Protección de la navegación web	Categoría · las tres (**+R1** en ALTA)	Normativa de uso, concienciación, protección de la **resolución de nombres**, control de **cookies** y de código dañino
`mp.s.4`	Protección frente a la **denegación de servicio**	**D** · desde nivel **MEDIO** (**+R1** en ALTA)	Planificar capacidad, desplegar tecnologías de prevención y, en nivel alto, **detección y procedimientos de reacción**
`mp.com.1`	Perímetro seguro	Categoría · las tres	Sistema de protección perimetral y **control de todos los flujos** que lo atraviesan
`mp.com.2`	Protección de la **confidencialidad**	**C** · BAJO aplica · **MEDIO +R1** · ALTO +R1+R2+R3	**VPN cifradas** cuando se sale del dominio propio y, desde nivel medio, **algoritmos y parámetros autorizados por el CCN**
`mp.com.3`	Protección de la **integridad y de la autenticidad**	**I A** · BAJO aplica · **MEDIO +R1 +R2** · ALTO +R1..R4	Autenticación del **otro extremo**, prevención de ataques activos, y desde nivel medio, VPN y algoritmos autorizados por el CCN
`mp.com.4`	**Separación de flujos de información en la red**	Categoría · **n. a. en BÁSICA**	Segregación del tráfico y **segmento propio para las comunicaciones inalámbricas**; refuerzos por VLAN o redes separadas
`op.exp.10`	Protección de **claves criptográficas**	Categoría	Gestión del ciclo de vida de las claves: generación, custodia, uso y retirada. Es la

Medida	Denominación literal	Dimensión / categoría	Qué exige, en lo esencial
			medida que respalda la **custodia de la clave privada del certificado** de la sede
`op.acc.5` / `op.acc.6`	Mecanismo de autenticación de **usuarios externos / de la organización**	Categoría	Robustez creciente del mecanismo con el nivel; limitación de intentos, doble factor en los niveles altos
`mp.info.3` / `mp.info.4`	**Firma electrónica / Sellos de tiempo**	**I A / T**	La firma es exigible desde BÁSICA; el **sellado de tiempo, solo en nivel ALTO**

DATO CLAVE

La medida `mp.s.2` **es la que traduce este tema en obligación jurídica**: exige que un servicio web público se **audite** —de **caja negra** (R1) o de **caja blanca** (R2)— **ya en la categoría BÁSICA**, y las dos, más la prevención de manipulación de programas y dispositivos (R3), en la **ALTA**. Y hay una regla del ENS que conviene retener: la **categoría del sistema** la determina la **dimensión más alta**, mientras que las medidas marcadas «Categoría» se aplican **por categoría** y las marcadas con una letra (C, I, T, A, D) **por nivel de esa dimensión**.

RELACIÓN CON OTROS TEMAS

Los **principios básicos y requisitos mínimos** del ENS y del ENI se estudian en el **Tema 39**; los **conceptos de seguridad, la criptografía y la firma electrónica**, en el **Tema 32**; la **seguridad perimetral y las VPN**, en el **Tema 36**; y la **accesibilidad y la usabilidad**, en el **Tema 25**.

Cómo se traduce todo esto en la configuración real de una sede electrónica. El resumen operativo del tema, y el guion de cualquier caso práctico:

1. **Nombre y DNS**: dominio bajo control de la entidad, con **DNS autoritativo redundante**, **DNSSEC** si es posible, registro **CAA** y **vigilancia de la caducidad** del dominio.
2. **Publicación en doble pila** IPv4/IPv6, con las **reglas de cortafuegos duplicadas** en ambos protocolos.
3. **Solo HTTPS**: redirección **301** de todo el tráfico HTTP, **HSTS** con `includeSubDomains` y, si procede, **precarga**.
4. **TLS 1.2 como mínimo y TLS 1.3 preferente**, con suites y parámetros **autorizados por el CCN** (guía **CCN-STIC-807**), sin SSL ni TLS 1.0/1.1.

5. **Certificado de sede electrónica** vigente, con **renovación automatizada** e **inventario con responsable**, y la **clave privada custodiada** conforme a `op.exp.10`.
6. **Cabeceras de seguridad** (`Content-Security-Policy`, `nosniff`, `X-Frame-Options`, `Referrer-Policy`) y **cookies** con `Secure`, `HttpOnly` y `SameSite`, más el **consentimiento** del art. 22.2 de la LSSI para las no imprescindibles.
7. **Auditoría del servicio web** conforme a `mp.s.2` y **gestión de vulnerabilidades** con parcheado periódico.
8. **Protección frente a denegación de servicio** (`mp.s.4`) y **registro de actividad** con IP **y puerto** de origen —imprescindible con CGNAT— sincronizado por **NTP**.
9. **Accesibilidad** conforme al **RD 1112/2018** y **declaración de accesibilidad** publicada.
10. **Protección de datos**: información en capas, base jurídica del tratamiento y medidas del **art. 32 del RGPD** coordinadas con las del ENS.

> **EJEMPLO DE APLICACIÓN EN EL AYTO**
>
> Un detalle que suele pasarse por alto y que un técnico municipal debe conocer: cuando la sede se publica tras un **proxy inverso** o una **red de distribución de contenidos**, el TLS **termina en el intermediario**, no en el servidor de aplicación. Eso tiene tres consecuencias: (1) la **clave privada** del certificado vive en el intermediario, y su custodia entra en el alcance de `op.exp.10`; (2) el tramo interno entre el proxy y la aplicación **también debe ir cifrado** si sale del dominio propio, por exigencia de `mp.com.2`; y (3) la dirección IP que ve la aplicación es la del proxy, de modo que el **registro de la IP real del ciudadano** depende de que se propague correctamente la cabecera correspondiente. Si además el intermediario es un **servicio en la nube**, entra en juego el **art. 2.3 del ENS**, que extiende su aplicación al **proveedor privado** que presta servicios al sector público.

Los siete datos que no se pueden fallar

Cierre memorístico del tema. Si solo hubiera tiempo para repasar una página, es esta.

1. **Internet no es la Web.** Internet nace como red de redes con TCP/IP —**1 de enero de 1983**, cuando ARPANET abandona NCP—; la **Web** es un servicio que Berners-Lee crea en el **CERN** entre **1989 y 1991** y que el CERN libera al dominio público el **30 de abril de 1993**.
2. **Quién hace qué en la gobernanza**: **ICANN/IANA (hoy PTI, desde el 1 de octubre de 2016)** reparte **identificadores**; el **IETF** escribe los **RFC**; el **W3C** estandariza la **Web**, no Internet. España pertenece al RIR **RIPE NCC**.
3. **La pila tiene cuatro capas** (acceso a red, internet, transporte, aplicación) frente a las **siete** de OSI, y las PDU son **trama, paquete, segmento y mensaje**. La capa de aplicación de TCP/IP

absorbe **tres** de OSI.

4. **La tabla de puertos**: **80/443** HTTP y HTTPS · **21/20** FTP · **22** SSH y SFTP · **25/587/465** SMTP · **110/995** POP3 · **143/993** IMAP · **53** DNS (**853** DoT) · **67/68** DHCP · **179** BGP.
5. **DNSSEC autentica; DoT y DoH cifran.** Son problemas distintos y soluciones complementarias. Y el DNS tiene **13 identidades** de servidor raíz sobre **más de 2.000 instancias** con **anycast**.
6. **HTTP es sin estado**, y su especificación vigente son los **RFC 9110-9114 (2022)**, no el RFC 2616. `POST` **no es seguro ni idempotente**; `PUT` **y** `DELETE` **son idempotentes**; **401 es no autenticado** y **403 es sin permiso**. **HTTP/3 va sobre QUIC/UDP**.
7. **SSL está muerto y TLS 1.3 se ha reeditado.** SSL 2.0 y 3.0 **prohibidos**; TLS 1.0 y 1.1 **obsoletos** (RFC 8996). Vigentes **TLS 1.2 y 1.3**, este último especificado desde **julio de 2026 en el RFC 9846**, que obsoleta el RFC 8446. **HTTPS = HTTP sobre TLS en el 443**, con el orden **TCP → TLS → HTTP**. Y en un servicio público, todo ello se apoya en `mp.s.2` , `mp.com.2` y `mp.com.3` del ENS.

Diagramas

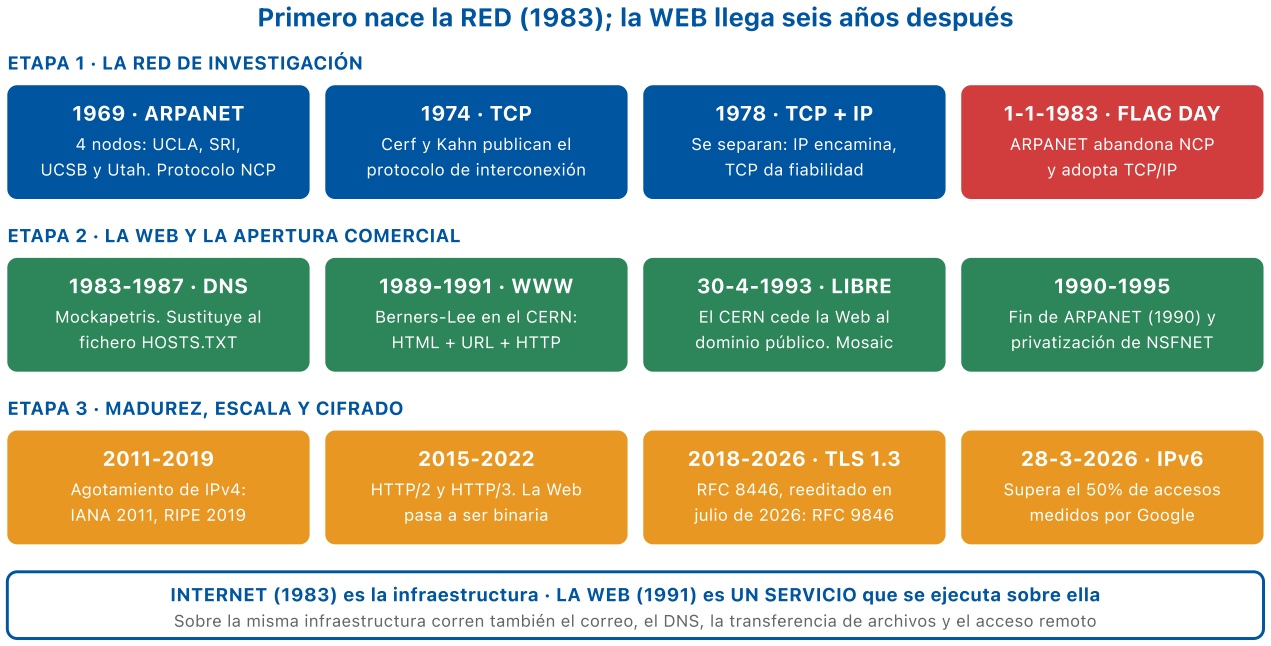
Índice de diagramas

ID	Título	Sección	Tipo
D1	De ARPANET a la Internet actual: línea del tiempo	§1.1.1	Línea temporal
D2	Quién gobierna qué en Internet	§1.2.1	Mapa de organismos
D3	El camino de un estándar: del Internet-Draft al STD	§1.2.2	Flujo + categorías
D4	Pila TCP/IP frente al modelo OSI	§2.1.1	Comparativa de capas
D5	Encapsulamiento y desencapsulamiento	§2.1.2	Estructura anidada
D6	Internet como red de redes: AS, tránsito, *peering* e IXP	§2.2.1	Topología
D7	Agotamiento de IPv4 y mecanismos de coexistencia con IPv6	§2.2.2	Línea temporal + comparativa
D8	DNS: jerarquía y resolución de un nombre paso a paso	§2.2.3	Flujo numerado
D9	Seguridad del DNS: qué resuelve DNSSEC y qué resuelven DoT y DoH	§2.2.3	Comparativa
D10	Correo electrónico: agentes, protocolos, puertos y autenticación	§3.1.1	Flujo + tabla
D11	FTP: modo activo, modo pasivo y alternativas seguras	§3.1.2	Comparativa de flujos
D12	SSH: arquitectura en tres capas y métodos de autenticación	§3.2.1	Capas + tabla
D13	DHCP: intercambio DORA y configuración en IPv6	§3.2.2	Secuencia
D14	Anatomía de un mensaje HTTP: petición y respuesta	§4.2.1	Estructura
D15	De HTTP/0.9 a HTTP/3: qué resuelve cada versión	§4.1.2	Evolución comparada
D16	El estado en HTTP: cookies, sesiones y atributos de seguridad	§4.2.2	Flujo + tabla

ID	Título	Sección	Tipo
D17	TLS: subprotocolos y saludo 1.2 frente a 1.3	§5.1.1	Arquitectura + secuencia
D18	HTTPS de extremo a extremo en una sede electrónica	§5.2.1 · §6.1.1	Flujo + validación

D1 · De ARPANET a la Internet actual: línea del tiempo

Sección: §1.1.1 — De ARPANET a la consolidación de la pila TCP/IP · §1.1.2 **Propósito**: Fijar en tres etapas las fechas clave, separando el nacimiento de la **red** (1969-1983) del nacimiento de la **Web** (1989-1993), que es la confusión más penalizada del tema.



[Fuente: elaboración propia sobre RFC 1, RFC 801, W3C y CERN]

D2 · Quién gobierna qué en Internet

Sección: §1.2.1 — Organismos internacionales de regulación **Propósito**: Separar los tres bloques de competencias —identificadores, estándares y otros ámbitos— para responder a «qué organismo hace qué», e incorporar la transición IANA de 2016.

Nadie manda en Internet: se coordina lo imprescindible

IDENTIFICADORES ÚNICOS

ICANN (1998)
Coordina nombres y números

Función IANA · PTI
Raíz DNS, bloques IP, parámetros

5 RIR
ARIN · RIPE NCC · APNIC · LACNIC · AFRINIC

ESTÁNDARES TÉCNICOS

ISOC
Paraguas institucional del IETF

IAB + IESG
Arquitectura y aprobación

IETF
Escribe los RFC. IRTF: investigación

OTROS ÁMBITOS

W3C (1994)
Estándares de la WEB: HTML, CSS

IEEE
802.3 Ethernet y 802.11 Wi-Fi

ITU-T · IGF
El IGF dialoga: NO decide

LIR (operadores)
España pertenece a RIPE NCC

HTTP, TLS, IP, DNS y el correo son estándares del IETF, no del W3C
El W3C estandariza lo que se ejecuta DENTRO del navegador; el IETF, cómo viaja por la red

TRANSICIÓN IANA: el contrato con el Gobierno de EE. UU. expiró el 30-9-2016
Desde el 1-10-2016 las funciones IANA las ejerce PTI, filial de ICANN, bajo modelo de múltiples partes interesadas

ICANN reparte IDENTIFICADORES · IETF escribe PROTOCOLOS · W3C estandariza la WEB
Cadena de direcciones: IANA da bloques al RIR, el RIR al LIR (operador) y el LIR al usuario final

[Fuente: ICANN, IETF, W3C, RIPE NCC]

D3 · El camino de un estándar: del Internet-Draft al STD

Sección: §1.2.2 — Proceso de estandarización técnica y documentos RFC **Propósito**: Mostrar el recorrido de un documento del IETF y, sobre todo, fijar las dos reglas clave: el borrador caduca a los seis meses y el RFC publicado es inmutable.

Un RFC publicado no se corrige nunca: se obsoleta o se actualiza

EL RECORRIDO

INTERNET-DRAFT
Caduca a los 6 MESES

→

GRUPO DE TRABAJO
Debate público y consenso

→

LAST CALL + IESG
Última llamada y aprobación

→

RFC PUBLICADO
Número definitivo e inmutable

Un Internet-Draft NO es un estándar y NO puede citarse como referencia normativa

CATEGORÍAS DE RFC · no todo RFC es un estándar

STANDARDS TRACK
Proposed Standard → Internet Standard (serie STD)

BEST CURRENT PRACTICE
Prácticas y procedimientos. Se numera como BCP n

INFORMATIONAL
Sin pretensión normativa

EXPERIMENTAL
Especificación en pruebas

HISTORIC
Superado y desaconsejado

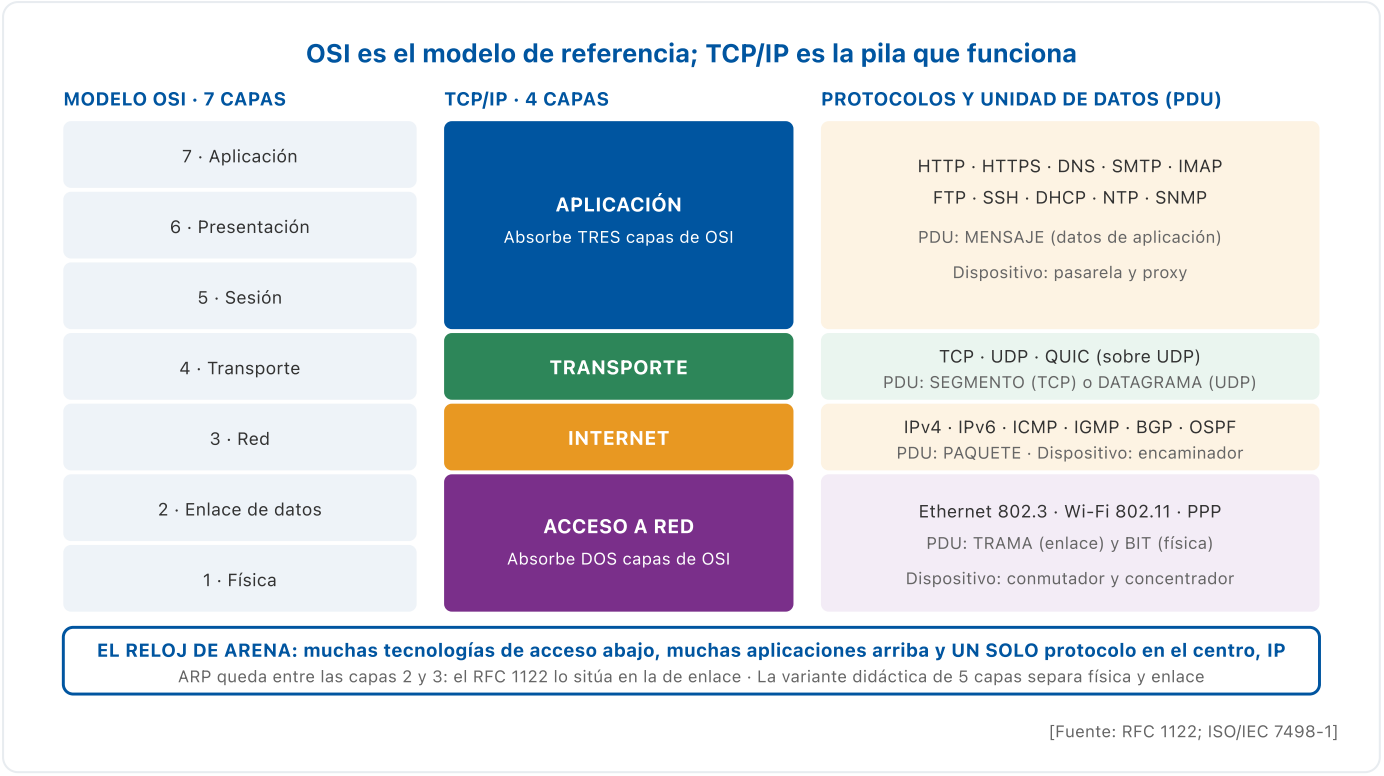
EJEMPLOS VERIFICADOS: STD 97 = RFC 9110 (HTTP) · STD 99 = RFC 9112 (HTTP/1.1) · STD 86 = RFC 8200 (IPv6)
STD 102 = RFC 9915 (DHCPv6, enero de 2026) · BCP 5 = RFC 1918 (direccionamiento privado)

El número STD no cambia aunque se reedite el RFC que lo desarrolla

[Fuente: RFC Editor; RFC 2026 y RFC 6410]

D4 · Pila TCP/IP frente al modelo OSI

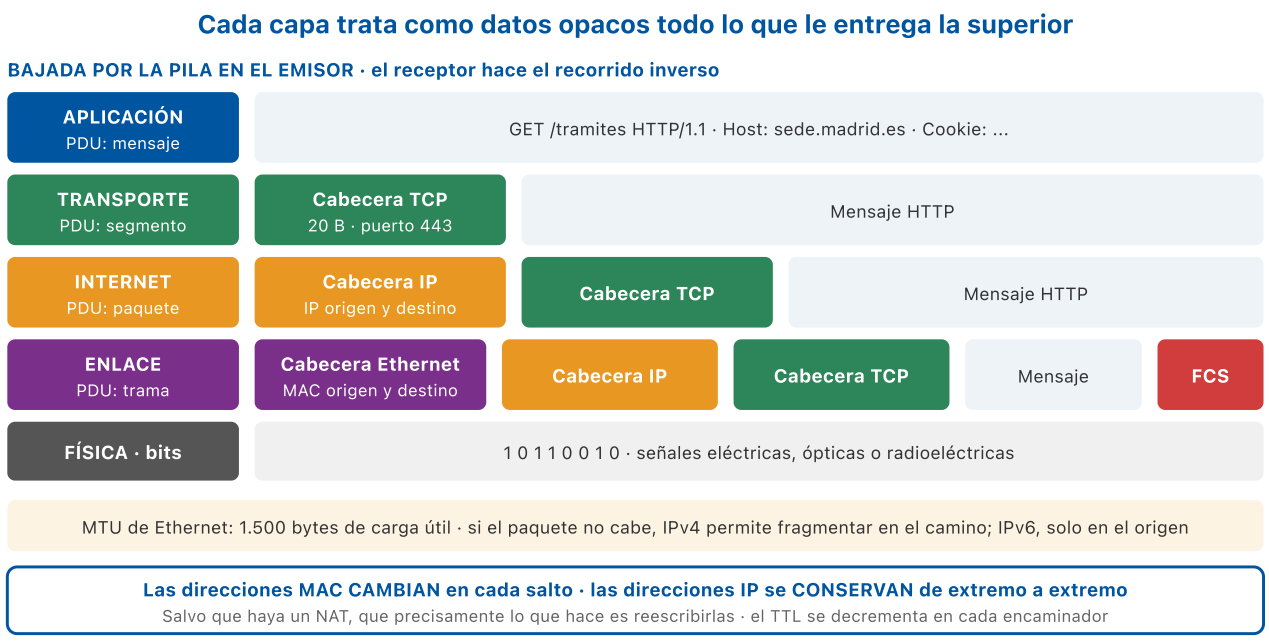
Sección: §2.1.1 — Pila TCP/IP y correspondencia con el modelo OSI **Propósito**: Fijar la correspondencia exacta entre las siete capas de OSI y las cuatro de TCP/IP, con los protocolos y la PDU de cada nivel.



[Fuente: RFC 1122; ISO/IEC 7498-1]

D5 · Encapsulamiento y desencapsulamiento

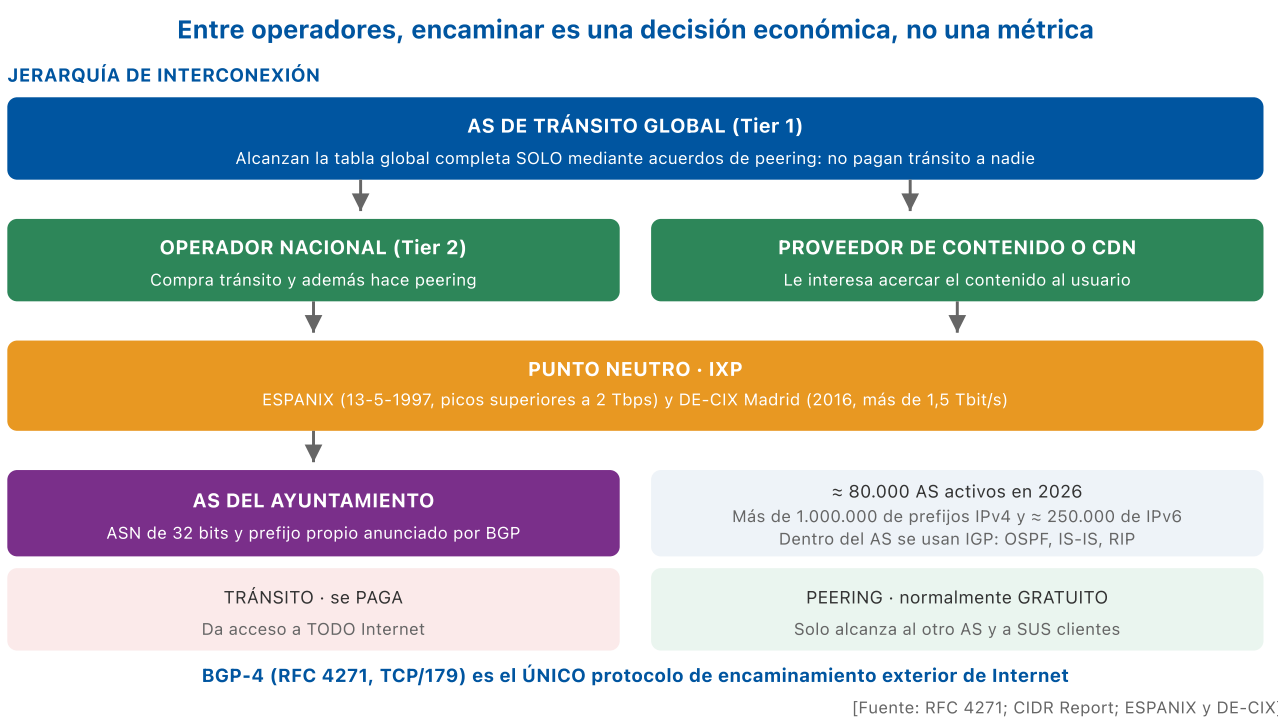
Sección: §2.1.2 — Encapsulamiento y transmisión de datos **Propósito**: Ver cómo cada capa antepone su cabecera y por qué el nombre de la PDU cambia en cada nivel, junto con el concepto de MTU y lo que se modifica en cada salto.



[Fuente: RFC 1122; RFC 791 y RFC 8200]

D6 · Internet como red de redes: AS, tránsito, *peering* e IXP

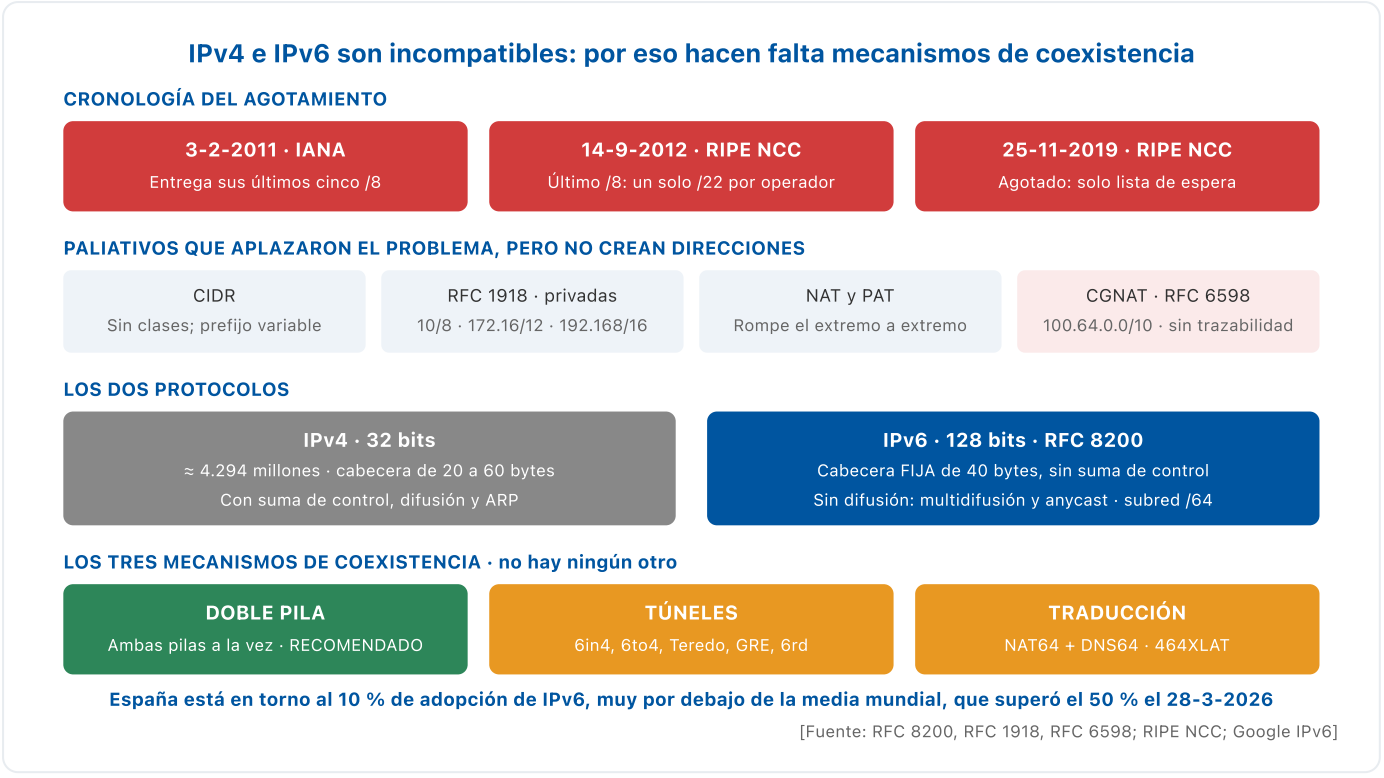
Sección: §2.2.1 — Sistemas Autónomos y puntos de intercambio de tráfico **Propósito**: Explicar por qué el encaminamiento entre operadores es una cuestión económica antes que técnica, y distinguir tránsito de *peering*, que es la distinción clave del epígrafe.



[Fuente: RFC 4271; CIDR Report; ESPANIX y DE-CIX]

D7 · Agotamiento de IPv4 y mecanismos de coexistencia con IPv6

Sección: §2.2.2 — Coexistencia de los protocolos IPv4 e IPv6 **Propósito**: Encadenar las tres fechas del agotamiento, los paliativos que solo lo aplazaron y los tres —y solo tres— mecanismos de coexistencia posibles.



D8 · DNS: jerarquía y resolución de un nombre paso a paso

Sección: §2.2.3 — Sistema de Nombres de Dominio **Propósito**: Distinguir consulta recursiva de iterativa —el error más frecuente del epígrafe— y ver de dónde sale cada respuesta parcial hasta llegar al registro A.

El cliente pregunta una vez; el resolutor pregunta tres

LA JERARQUÍA · un nombre se lee de derecha a izquierda

RAÍZ · el punto final	TLD · es	2.º NIVEL · madrid.es	SUBDOMINIO · sede
13 identidades, A a M	ccTLD gestionado por Red.es	Zona del Ayuntamiento	sede.madrid.es

RESOLUCIÓN DE sede.madrid.es

1. CLIENTE → RESOLUTOR: consulta RECURSIVA. «Dame la dirección de sede.madrid.es, resuélvelo tú»
2. RESOLUTOR → RAÍZ: consulta ITERATIVA. La raíz no lo sabe, pero responde con los NS de .es
3. RESOLUTOR → SERVIDOR DE .es: responde con los NS autoritativos de madrid.es
4. RESOLUTOR → AUTORITATIVO DE madrid.es: devuelve el registro A (IPv4) o AAAA (IPv6)
5. RESOLUTOR: guarda la respuesta en caché durante su TTL y la entrega al cliente

PUERTO 53	TRANSFERENCIA DE ZONA
UDP para consultas · TCP si la respuesta es grande	AXFR completa e IXFR incremental: SIEMPRE por TCP

Registros: A · AAAA · CNAME · MX · NS · PTR · SOA · TXT · SRV · CAA

[Fuente: RFC 1034 y RFC 1035; ICANN]

D9 · Seguridad del DNS: qué resuelve DNSSEC y qué resuelven DoT y DoH

Sección: §2.2.3 — Sistema de Nombres de Dominio **Propósito**: Fijar que son **dos problemas distintos con dos soluciones distintas y complementarias**.

DNSSEC autentica y no cifra; DoT y DoH cifran y no autentican la zona

DOS PROBLEMAS DISTINTOS DEL DNS ORIGINAL

PROBLEMA 1 · ¿ES VERDAD LA RESPUESTA?	PROBLEMA 2 · ¿QUIÉN VE MIS CONSULTAS?
Envenenamiento de caché y respuestas suplantadas	El DNS clásico viaja en claro: revela qué se visita
↓	↓
DNSSEC · RFC 4033 a 4035 FIRMA digitalmente los datos de la zona Cadena de confianza desde la raíz Aporta AUTENTICIDAD e INTEGRIDAD	**DoT (TCP/853) y DoH (HTTPS/443)** CIFRAN el transporte de la consulta RFC 7858 y RFC 8484 Aportan CONFIDENCIALIDAD
NO cifra: la respuesta sigue siendo legible	NO garantizan que el dato de la zona sea auténtico

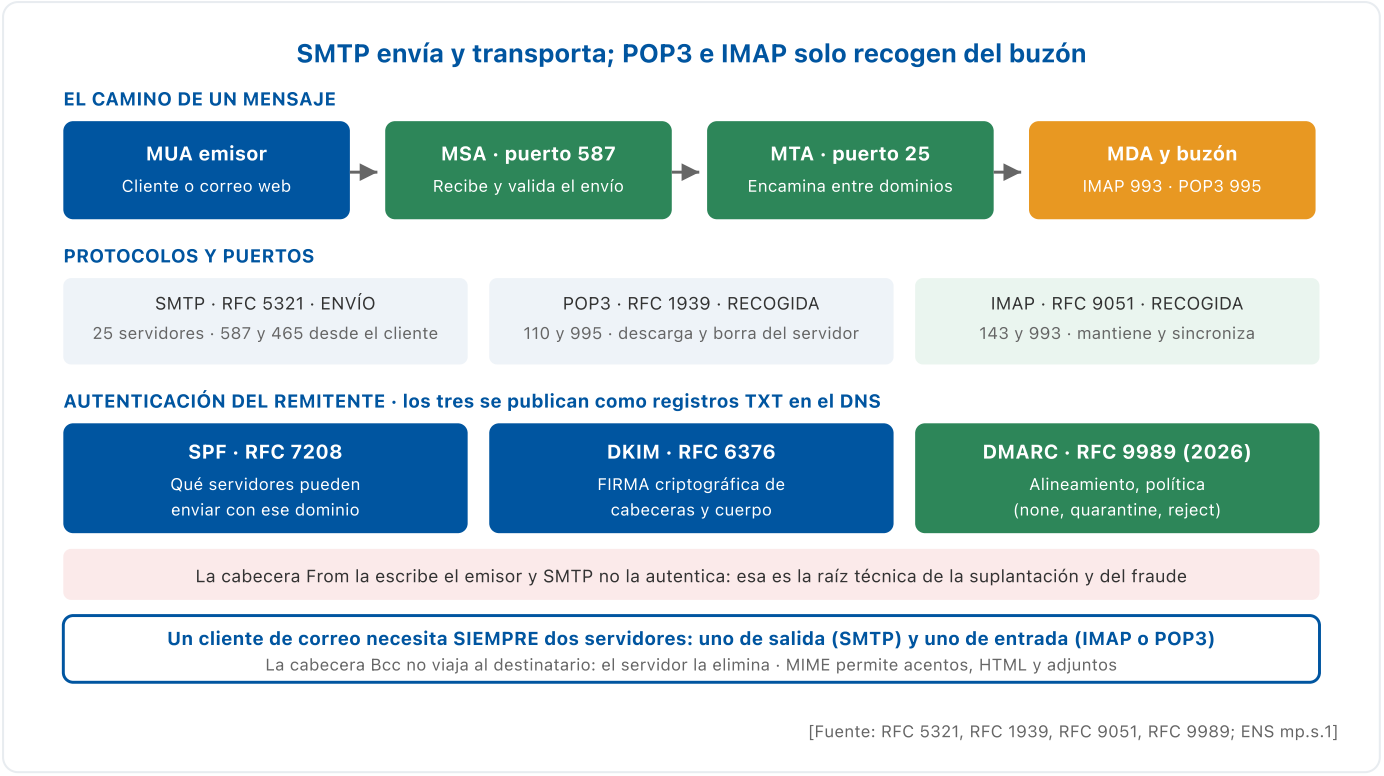
A julio de 2026, 1.348 de los 1.437 dominios de primer nivel de la raíz estaban firmados con DNSSEC (≈ 93,8 %)

SON COMPLEMENTARIOS, NO ALTERNATIVOS: lo ideal es DNSSEC en la zona propia y DoT o DoH en el cliente
Otras amenazas: secuestro del dominio en el registrador, dominios homógrafos y exfiltración por túnel DNS

[Fuente: RFC 4033-4035, RFC 7858, RFC 8484; ICANN]

D10 · Correo electrónico: agentes, protocolos, puertos y autenticación

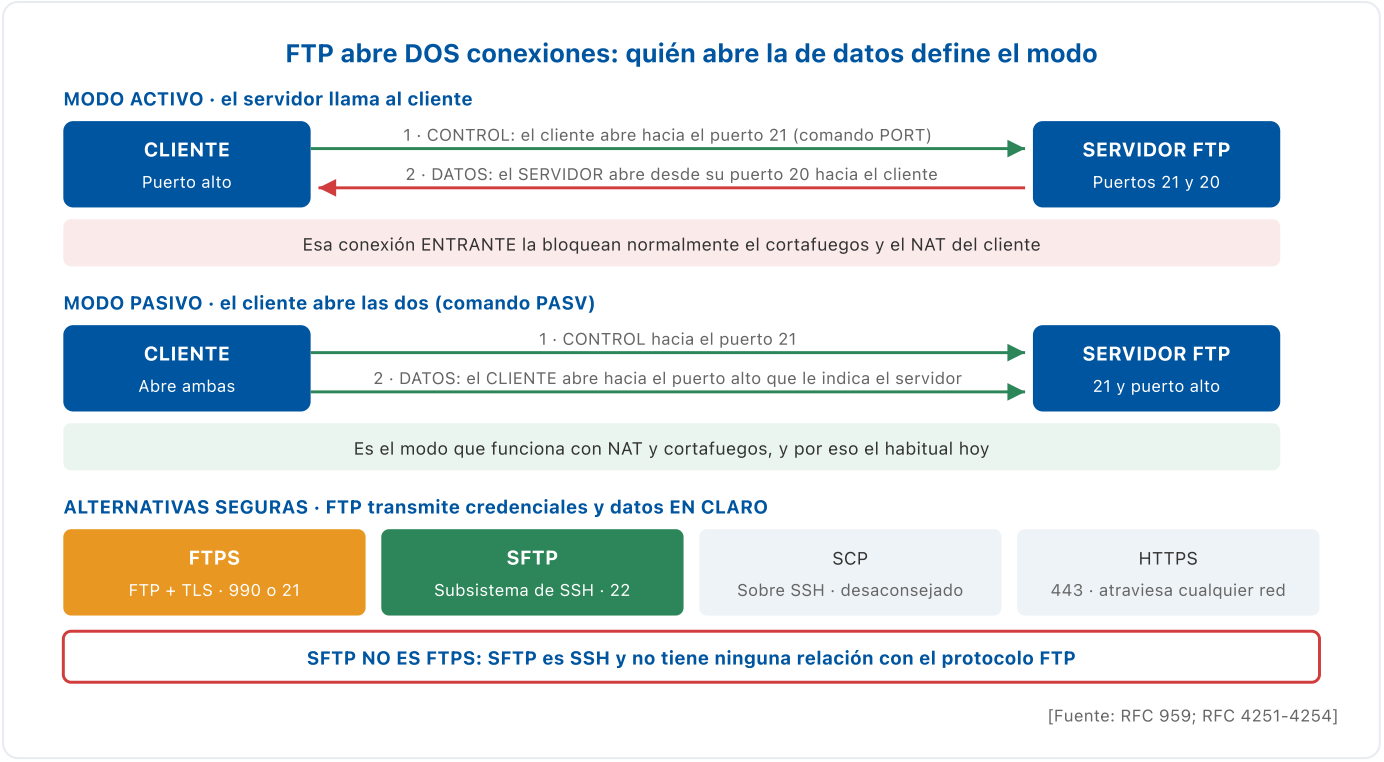
Sección: §3.1.1 — Correo electrónico y sus protocolos **Propósito**: Separar con claridad el protocolo de **envío** del de **recogida** —el error más penalizado del bloque— y añadir la tríada SPF, DKIM y DMARC con su reedición de 2026.



[Fuente: RFC 5321, RFC 1939, RFC 9051, RFC 9989; ENS mp.s.1]

D11 · FTP: modo activo, modo pasivo y alternativas seguras

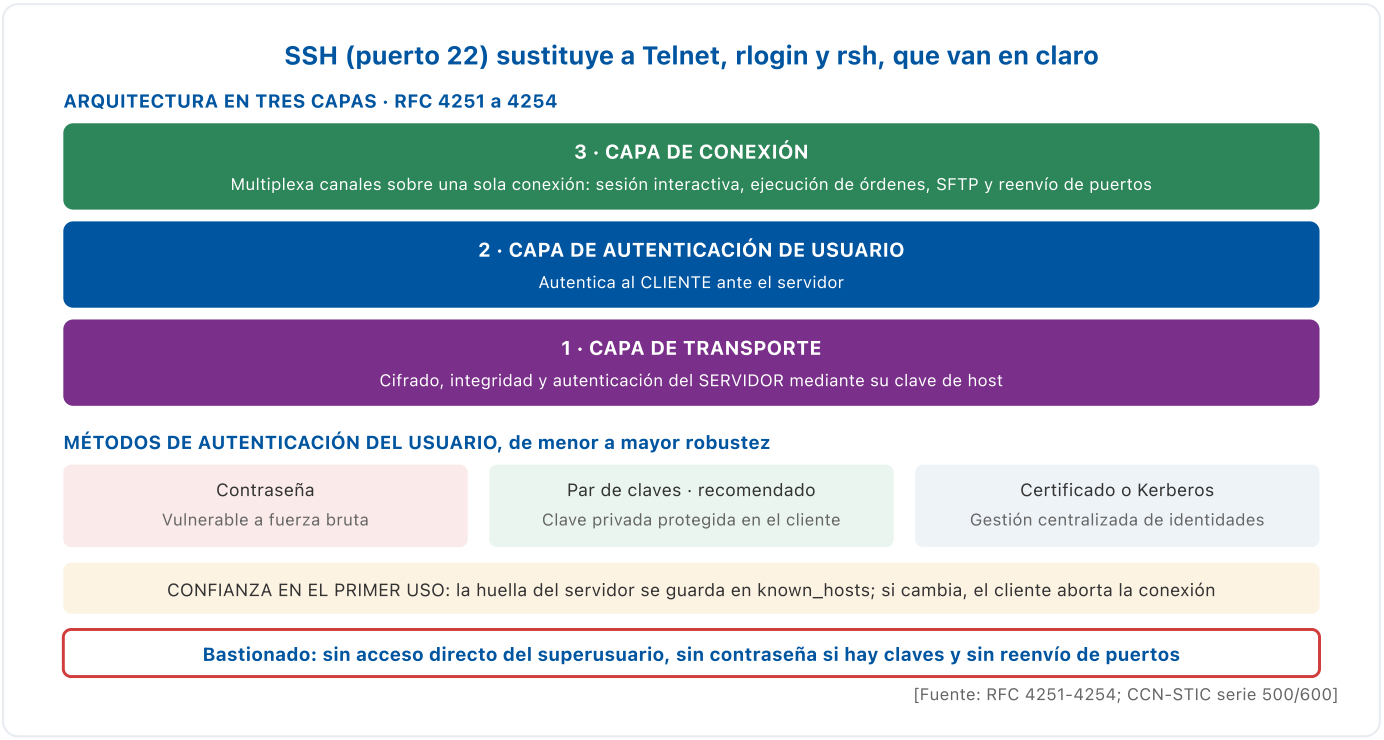
Sección: §3.1.2 — Transferencia de archivos **Propósito**: Explicar por qué FTP usa dos conexiones y en qué se diferencia el modo activo del pasivo, y separar de una vez **FTPS** de **SFTP**.



[Fuente: RFC 959; RFC 4251-4254]

D12 · SSH: arquitectura en tres capas y métodos de autenticación

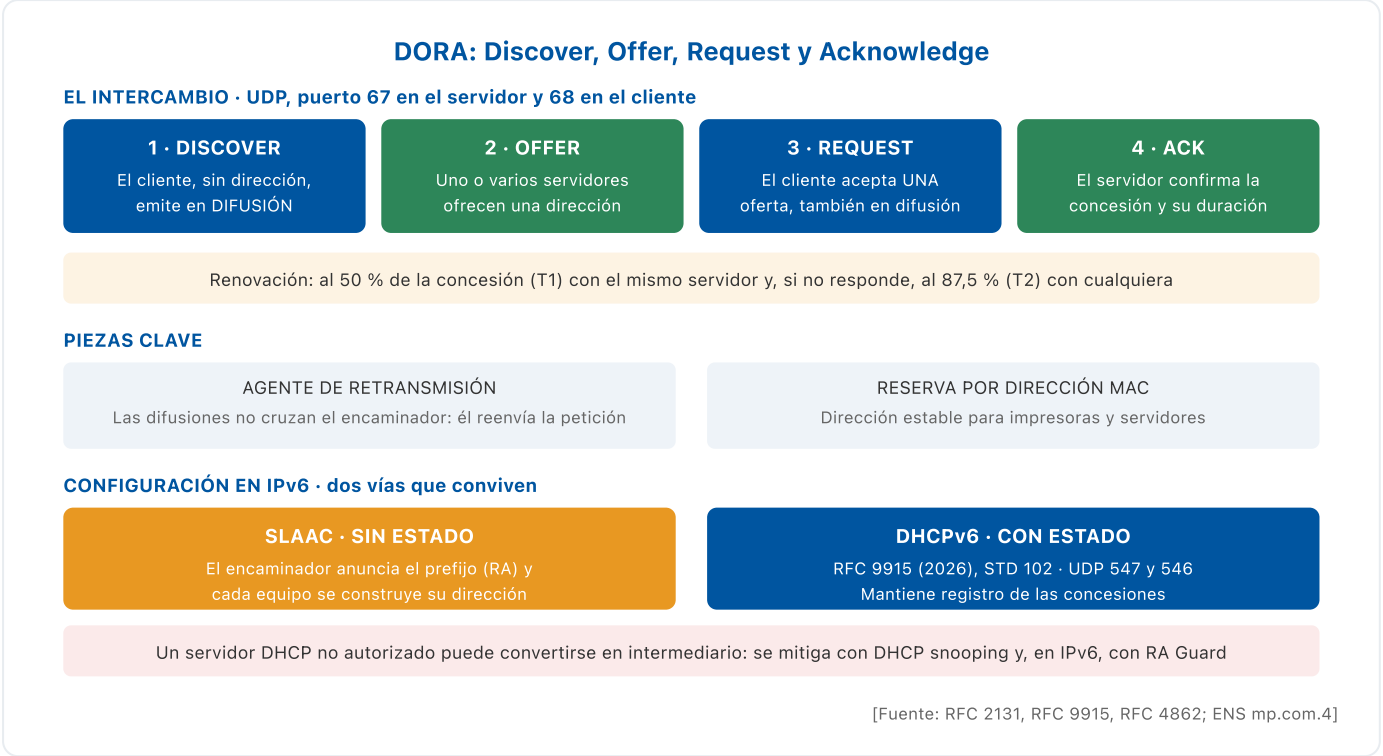
Sección: §3.2.1 — Acceso remoto seguro **Propósito**: Fijar las tres capas del protocolo, los métodos de autenticación y la confianza en el primer uso, que son los tres puntos clave del epígrafe.



[Fuente: RFC 4251-4254; CCN-STIC serie 500/600]

D13 · DHCP: intercambio DORA y configuración en IPv6

Sección: §3.2.2 — Configuración dinámica de red **Propósito**: Memorizar la secuencia DORA con sus puertos y contrastar la configuración de IPv4 con las dos vías de IPv6, incluida la consecuencia de SLAAC sobre la trazabilidad.



D14 · Anatomía de un mensaje HTTP: petición y respuesta

Sección: §4.2.1 — Estructura de mensajes, métodos y códigos de respuesta **Propósito**: Ver las tres partes del mensaje y tener en una sola imagen la clasificación de métodos por seguridad e idempotencia y las cinco familias de códigos de estado.

Línea de inicio + cabeceras + línea en blanco + cuerpo opcional

PETICIÓN

```
GET /tramites/licencias?id=471 HTTP/1.1
Host: sede.madrid.es
Accept: text/html
Cookie: JSESSIONID=8F2A...

Línea en blanco y, si el método lo lleva, cuerpo
```

RESPUESTA

```
HTTP/1.1 200 OK
Content-Type: text/html; charset=utf-8
Content-Length: 34871
Cache-Control: no-store

Línea en blanco y cuerpo con el documento
```

MÉTODOS · seguro = no modifica el estado · idempotente = repetirlo da el mismo efecto

SEGUROS E IDEMPOTENTES	SOLO IDEMPOTENTES	NI SEGUROS NI IDEMPOTENTES
GET · HEAD · OPTIONS · TRACE	PUT · DELETE	POST · PATCH

CÓDIGOS DE ESTADO · la primera cifra manda

1xx	2xx · éxito	3xx · redirección	4xx · cliente	5xx · servidor
Informativo	200 · 201 · 204	301 · 302 · 304	400 · 401 · 403 · 404	500 · 502 · 503 · 504

401 = NO AUTENTICADO · 403 = autenticado pero SIN PERMISO · 301 permanente y cacheada · 302 y 307 temporales
POST no cifra nada: solo evita que el dato quede escrito en la URL; lo que protege el contenido es HTTPS

[Fuente: RFC 9110 y RFC 9112]

D15 · De HTTP/0.9 a HTTP/3: qué resuelve cada versión

Sección: §4.1.2 — Evolución desde HTTP/1.1 hasta HTTP/3 **Propósito**: Encadenar las cinco versiones por el problema que cada una resolvió y el que dejó abierto, con el bloqueo de cabecera de línea como hilo conductor.

Cada versión de HTTP resuelve el cuello de botella de la anterior

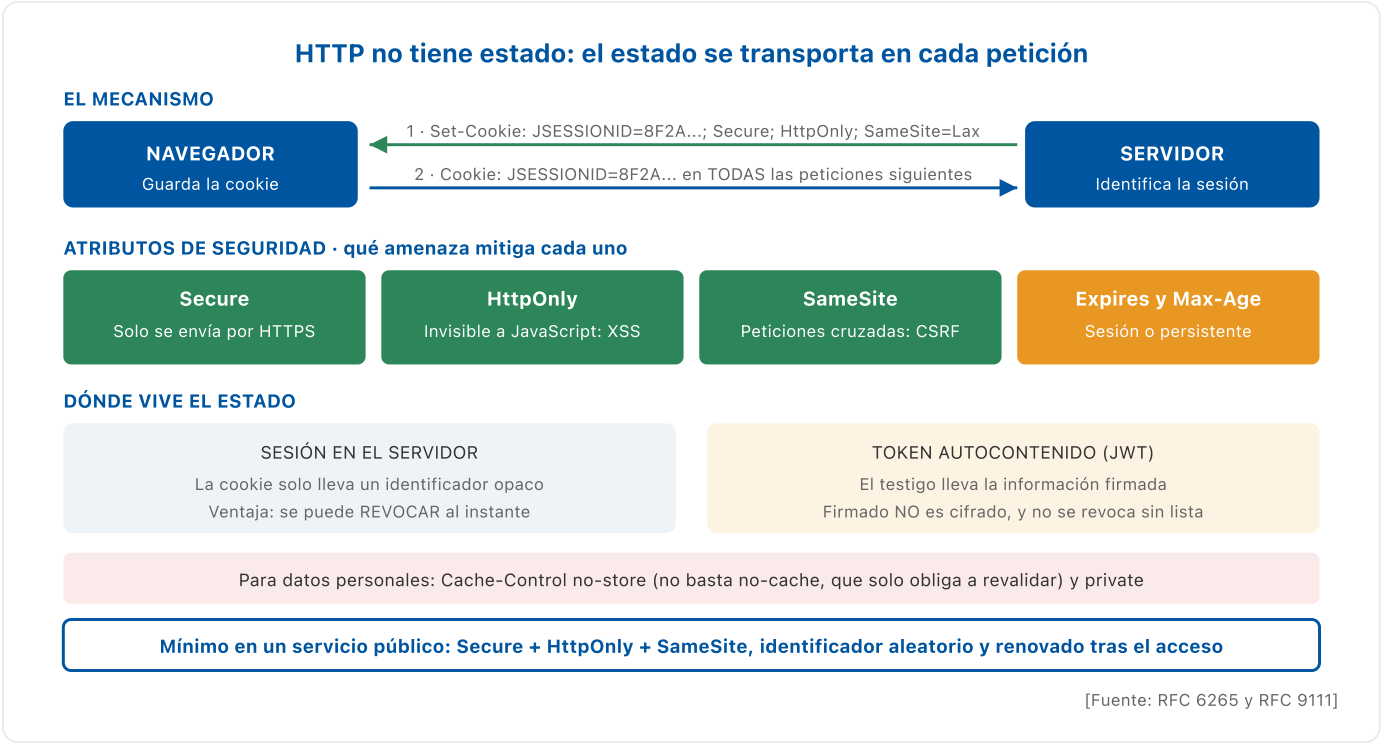
VERSIÓN	QUÉ APORTA	QUÉ PROBLEMA DEJA ABIERTO
HTTP/0.9 1991	Una sola línea: GET /pagina Sin cabeceras, sin códigos de estado, sin versiones	Solo sirve documentos HTML
HTTP/1.0 1996 · RFC 1945	Cabeceras, códigos de estado y MIME Aparecen los métodos HEAD y POST	Una conexión TCP por cada recurso
HTTP/1.1 RFC 9112 · STD 99	Conexiones persistentes y Host obligatoria Alojamiento virtual, rangos, caché y chunked	Bloqueo de cabecera de línea en la APLICACIÓN: respuestas en orden
HTTP/2 2015 · RFC 9113	Binario y multiplexado sobre UNA conexión Compresión de cabeceras HPACK y priorización	Persiste el bloqueo en TCP: un segmento perdido detiene TODO
HTTP/3 2022 · RFC 9114	Sobre QUIC (RFC 9000) y UDP Cifrado obligatorio, QPACK, 1-RTT y migración	Exige UDP abierto y dificulta la inspección en equipos intermedios

La semántica es la MISMA en las tres versiones vigentes: métodos, códigos y cabeceras no cambian
Lo que cambia es cómo se transmiten · HTTP/2 se negocia por ALPN dentro de TLS y HTTP/3 se anuncia con Alt-Svc

[Fuente: RFC 9110 a RFC 9114; RFC 9000]

D16 · El estado en HTTP: cookies, sesiones y atributos de seguridad

Sección: §4.2.2 — Cabeceras HTTP, cookies y sesiones **Propósito**: Mostrar cómo se construye estado sobre un protocolo que no lo tiene, y fijar qué amenaza mitiga cada atributo de la cookie.



[Fuente: RFC 6265 y RFC 9111]

D17 · TLS: subprotocolos y saludo 1.2 frente a 1.3

Sección: §5.1.1 — Arquitectura, subprotocolos y negociación TLS **Propósito**: Fijar que el **Record** es el subprotocolo que encapsula a todos los demás, y comparar los dos viajes del saludo de TLS 1.2 con el único de TLS 1.3.

El Record transporta a todos los demás; el Handshake acuerda las claves

ARQUITECTURA · los subprotocolos viajan DENTRO del Record

HANDSHAKE	ALERT	CHANGE CIPHER SPEC	DATOS DE APLICACIÓN

RECORD PROTOCOL · fragmenta, cifra y protege la integridad de todo lo anterior
Es el subprotocolo de más bajo nivel: en TLS 1.3 el Change Cipher Spec solo se conserva por compatibilidad

EL SALUDO

TLS 1.2 · DOS VUELTAS (2-RTT)

1 · ClientHello: versiones, aleatorio y suites
2 · ServerHello + Certificate (EN CLARO) + Done
3 · ClientKeyExchange + ChangeCipherSpec + Finished
4 · ChangeCipherSpec + Finished del servidor

TLS 1.3 · UNA VUELTA (1-RTT)

1 · ClientHello + key_share: el cliente ya envía su parte del Diffie-Hellman efímero
2 · ServerHello + certificado YA CIFRADO + Finished
Reanudación posterior: 0-RTT (solo si es idempotente)

NOVEDADES DE TLS 1.3 · tres de las cinco

CONFIDENCIALIDAD DIRECTA	SOLO CIFRADO AEAD	SIN RSA NI RENEGOCIACIÓN
Obligatoria: solo ECDHE o DHE	Sin RC4, 3DES ni compresión	RSA sigue valiendo para FIRMAR

SSL 2.0 y 3.0 PROHIBIDOS · TLS 1.0 y 1.1 OBSOLETOS (RFC 8996) · vigentes TLS 1.2 y TLS 1.3 (RFC 9846, julio de 2026)

[Fuente: RFC 9846, RFC 8996, RFC 7568; CCN-STIC-807]

D18 · HTTPS de extremo a extremo en una sede electrónica

Sección: §5.2.1 — Funcionamiento de HTTP sobre TLS · §6.1.1 **Propósito**: Recorrer la conexión completa desde que se escribe el nombre hasta que llega la página cifrada, señalando el único momento de riesgo y la medida del ENS que ampara cada pieza.

HTTPS no es otro protocolo: es HTTP dentro de TLS, en el puerto 443

EL ORDEN DE LAS CAPAS · TCP primero, TLS después, HTTP al final

1 · TCP · saludo en tres pasos	2 · TLS · saludo y claves	3 · HTTP · ya cifrado

LA CONEXIÓN COMPLETA A sede.madrid.es

1. DNS: se resuelve el nombre en una dirección IP (con DoT o DoH la consulta va cifrada)
2. Si la petición sale por HTTP/80, el servidor responde 301 · ÚNICO MOMENTO EN CLARO Y ÚNICO RIESGO
3. TCP/443 y saludo TLS: el cliente envía el nombre del sitio en la extensión SNI, que viaja EN CLARO
4. Validación de la cadena: firma de la AC, vigencia, nombre en el SAN, restricciones básicas y revocación
5. Petición HTTP cifrada; la respuesta incluye HSTS, que evita el paso 2 en las visitas siguientes

REFUERZOS Y RESPALDO NORMATIVO

HSTS y precarga	CAA y CT	mp.com.2 y mp.com.3	mp.s.2 y op.exp.10
Elimina el riesgo del paso 2	Qué AC puede emitir y qué emitió	Cifrado e integridad del canal	Auditoría web y claves

HTTPS oculta el contenido, las cabeceras y la ruta; NO oculta la IP de destino ni el SNI, salvo con ECH

[Fuente: RFC 9110, RFC 6797; ENS anexo II; Ley 40/2015, art. 38]

Casos prácticos

Los tres casos giran sobre el supuesto de referencia del tema (ver la pestaña Contenido, «Convenciones»): la **sede electrónica municipal**. El **Caso 1** trabaja la **publicación de un servicio nuevo en internet** (nombres, direccionamiento, HTTPS y certificados); el **Caso 2**, el **diagnóstico por capas de una incidencia** real, con lectura de trazas y códigos de estado; y el **Caso 3**, los **servicios de soporte**: correo suplantado y transferencia de ficheros con datos personales.

Caso 1 — Publicación de un nuevo trámite en la sede electrónica

Enunciado

El Ayuntamiento va a publicar un **nuevo trámite de solicitud de ayudas** en la dirección `ayudas.sede.madrid.es`. El equipo de proyecto plantea la siguiente configuración inicial:

- El nombre se dará de alta en la zona `madrid.es`, servida por **un único servidor DNS autoritativo** alojado en el CPD del IAM.
- El servicio se publicará **solo en IPv4**, «porque IPv6 todavía no lo usa nadie en España».
- Se atenderá en **HTTP por el puerto 80 y en HTTPS por el 443**, dejando ambos abiertos «para no dejar fuera a nadie».
- Se contratará un **certificado de un año de validez** a una autoridad de certificación pública, con renovación manual anotada en la agenda del responsable.
- La aplicación guardará la sesión en una **cookie sin atributos**, y devolverá las páginas con datos del solicitante **sin cabeceras de caché**.
- El sistema ha sido categorizado **MEDIA** conforme al ENS.

Se pide un informe técnico previo a la puesta en producción.

Cuestiones

Cuestión 1 — Nombres y direccionamiento (3 puntos). Analice las decisiones sobre **DNS** y sobre el **direccionamiento**, indicando qué riesgos introducen y qué configuración propondría en su lugar.

Cuestión 2 — Transporte seguro (3 puntos). Valore la decisión de mantener HTTP y HTTPS abiertos y la del certificado. Indique **qué versiones de TLS** deben admitirse en 2026 y **por qué el certificado propuesto no es viable**.

Cuestión 3 — Configuración de la aplicación (2 puntos). Corrija la configuración de la **cookie de sesión** y de la **caché**, justificando cada atributo por la amenaza que mitiga.

Cuestión 4 — Respaldo normativo (2 puntos). Cite las **medidas del ENS** y los **preceptos legales** que amparan cada una de las correcciones anteriores.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§2.2.2, §2.2.3)

Decisión del proyecto	Riesgo	Propuesta
Un solo servidor DNS autoritativo	**Punto único de fallo**: si cae, el servicio no se cae técnicamente, pero **nadie lo encuentra**, con efecto idéntico a una caída total	**Al menos dos** servidores autoritativos, en **redes y emplazamientos distintos** (uno primario y uno o varios secundarios por transferencia de zona restringida)
Zona sin protección adicional	Suplantación de respuestas y **envenenamiento de caché**	**DNSSEC** en la zona; **registro CAA** para limitar qué AC puede emitir certificados; vigilancia de la **caducidad del dominio** y bloqueo en el registrador
Publicación solo en IPv4	Penaliza el acceso desde redes móviles con **CGNAT** y contradice la orientación de neutralidad tecnológica del ENI	**Doble pila** IPv4/IPv6, con las **reglas de cortafuegos duplicadas** en ambos protocolos: una regla que solo cubre IPv4 deja abierta la puerta IPv6

Se valora que el aspirante **rebata con datos** el argumento «IPv6 no lo usa nadie»: la media mundial superó el **50 %** el 28-3-2026, y aunque España esté en torno al **10 %**, la publicación en doble pila **no perjudica** a los usuarios IPv4 y prepara el servicio para la evolución.

- **C2**: (§5.1, §5.2)
  - **HTTP y HTTPS abiertos a la vez es un error.** El puerto 80 debe mantenerse abierto **solo** para **redirigir con un 301** a HTTPS, nunca para servir contenido. Y la redirección **no basta por sí sola**: la primera petición viaja en claro y es interceptable (*SSL stripping*), por lo que hay que añadir **HSTS** con `includeSubDomains` y, si el dominio lo permite, solicitar la **precarga**, que aplica la protección desde la primera visita.
  - **Versiones**: admitir **TLS 1.2 y TLS 1.3**, con preferencia por 1.3; **deshabilitar SSL 2.0 y 3.0** (prohibidos por los RFC 6176 y 7568) y **TLS 1.0 y 1.1** (obsoletos, RFC 8996). Los

algoritmos y parámetros deben ser los **autorizados por el CCN** (guía **CCN-STIC-807**), que es la formulación que emplea el propio ENS.

  - **El certificado de un año no es viable**: desde el **15 de marzo de 2026** el máximo admitido por el CA/Browser Forum es de **200 días**, y bajará a **100 días en 2027** y a **47 días en 2029**. La consecuencia organizativa es la parte importante: **la renovación manual deja de ser sostenible**, y hay que implantar **renovación automatizada** (ACME), **inventario de certificados** con responsable asignado y alertas anticipadas. La caducidad de un certificado es una causa banal y frecuente de caída de servicios públicos.
  - Añadir **grapado OCSP** o, mejor, asumir el modelo de **certificados de vida corta**, que es hacia donde se dirige el sector tras el apagado del OCSP de Let's Encrypt en agosto de 2025.

- **C3**: (§4.2.2)

Elemento	Configuración correcta	Amenaza que mitiga
Cookie de sesión	`Secure`	Interceptación en tránsito: la cookie no se envía por HTTP
	`HttpOnly`	Robo del identificador mediante **secuencias de órdenes en sitios cruzados (XSS)**
	`SameSite=Lax` o `Strict`	**Falsificación de petición en sitios cruzados (CSRF)**
	Identificador **aleatorio, largo y renovado tras el acceso**, con caducidad por inactividad	Predicción del identificador y **fijación de sesión**
Caché de páginas con datos del solicitante	`Cache-Control: no-store, private`	Que la respuesta quede almacenada en el navegador de un **puesto compartido**. Ojo: `no-cache` **no** vale, porque permite almacenar y solo obliga a revalidar

Se valora añadir las **cabeceras de seguridad** mínimas: `Content-Security-Policy`, `X-Content-Type-Options: nosniff`, `X-Frame-Options` o `frame-ancestors`, y `Referrer-Policy`.

- **C4**: (§6.1.1)

Corrección	Respaldo
Cifrado del canal	`mp.com.2` (protección de la confidencialidad): desde nivel MEDIO exige **+R1**, algoritmos y parámetros **autorizados por el CCN**
Autenticación del servidor e integridad del canal	`mp.com.3` (protección de la integridad y de la autenticidad): en nivel MEDIO, **+R1 +R2**
Auditoría del servicio web y prevención de XSS y escalado de privilegios	`mp.s.2`, exigible en **las tres categorías** con **[R1 o R2]**
Custodia de la clave privada del certificado	`op.exp.10` (protección de claves criptográficas)
Certificado de sede y comunicación segura	**Art. 38 de la Ley 40/2015** y **RD 203/2021**
Disponibilidad del servicio frente a denegación	`mp.s.4`, exigible desde nivel **MEDIO** de disponibilidad
Accesibilidad del nuevo trámite	**RD 1112/2018** y norma **UNE-EN 301 549**, con **declaración de accesibilidad** publicada
Tratamiento de datos personales del solicitante	**Art. 32 del RGPD** y `mp.info.1`

Criterios de evaluación

Criterio	Puntos
Detecta el punto único de fallo del DNS y propone redundancia, DNSSEC y CAA	1,5
Argumenta la publicación en doble pila y advierte de la duplicación de reglas de cortafuegos	1,5
Explica que la redirección 301 no basta y propone HSTS con precarga	1,0
Fija correctamente las versiones de TLS admisibles y las prohibidas	1,0
Detecta la inviabilidad del certificado de un año y propone automatización de la renovación	1,0
Corrige la cookie con los tres atributos, asociando cada uno a su amenaza	1,0
Distingue `no-store` de `no-cache`	1,0
Cita correctamente `mp.com.2`, `mp.com.3` y `mp.s.2`	1,0
Cita el art. 38 de la Ley 40/2015 y el marco de accesibilidad y protección de datos	1,0

Caso 2 — Diagnóstico por capas de una incidencia en una oficina de distrito

Enunciado

El **Centro de Atención a Usuarios** del IAM recibe, a lo largo de la misma mañana, tres avisos procedentes de una **Oficina de Atención a la Ciudadanía** de distrito:

- **Aviso 1**: «No se abre `sede.madrid.es`». En el puesto afectado, `ping 8.8.8.8` responde correctamente, pero `ping sede.madrid.es` devuelve «host desconocido». Desde el móvil del propio empleado, con datos móviles, la sede se abre sin problema.
- **Aviso 2**: en otro puesto, la sede **abre la portada**, pero al enviar el formulario de un trámite el navegador muestra **«502 Bad Gateway»**. Poco después, otros usuarios reciben **«503 Service Unavailable»**.

- **Aviso 3**: un tercer puesto muestra el aviso del navegador **«La conexión no es privada — el certificado no es válido»** al entrar en un servicio interno publicado por HTTPS. El empleado pregunta si puede «darle a continuar».

Además, el responsable de la oficina comenta que esa mañana **un proveedor conectó un portátil a una toma de red de la zona de público** para hacer una demostración.

Cuestiones

Cuestión 1 — Aviso 1 (3 puntos). Determine **en qué capa** está el problema, razone la deducción a partir de las pruebas descritas y proponga **dos comprobaciones adicionales** y la causa más probable, teniendo en cuenta el dato del proveedor.

Cuestión 2 — Aviso 2 (2,5 puntos). Interprete los códigos **502** y **503**: quién los emite, qué significan y en qué se diferencian del 500 y del 504.

Cuestión 3 — Aviso 3 (2,5 puntos). Explique **qué comprueba** un navegador al validar un certificado, enumere las causas posibles del aviso y responda a la pregunta del empleado.

Cuestión 4 — Medida preventiva (2 puntos). Proponga las medidas para que el incidente del portátil conectado a la toma de público no vuelva a producirse, con su respaldo en el ENS.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§2.1.2, §2.2.3, §3.2.2)
  - **Deducción por capas, de abajo arriba**: el `ping` a una **dirección IP** funciona, luego las capas **física, de enlace y de internet** están operativas y hay conectividad hasta un destino externo. Lo que falla es la **traducción del nombre**, que es un servicio de la **capa de aplicación**: el problema está en el **DNS**, no en la red. Que la sede sí abra desde el móvil —que usa el DNS del operador— **confirma** que el servicio publicado está bien y que el fallo es local.
  - **Comprobaciones adicionales**: (1) `nslookup sede.madrid.es` contra el **DNS corporativo** y después contra uno externo: si solo falla contra el corporativo, el fallo está en el resolutor de la organización; (2) `ipconfig /all` o `ip a` para ver **qué servidores DNS y qué pasarela** ha recibido el puesto y **de qué servidor DHCP** procede la concesión.
  - **Causa más probable**, unida al dato del proveedor: un **servidor DHCP no autorizado** en el portátil conectado a la toma de público, que ha entregado a los puestos una configuración con **DNS y pasarela falsos**. Es el escenario clásico: un DHCP no autorizado no solo rompe la resolución, sino que **puede convertir al atacante en**

intermediario de todo el tráfico. Alternativas menos graves: caída del resolutor corporativo o error en la zona.

- **C2**: (§4.2.1)

Código	Quién lo emite	Significado
500 Internal Server Error	La **aplicación** de origen	Error genérico no controlado dentro del propio servidor
502 Bad Gateway	Un **intermediario** (proxy inverso o balanceador)	El servidor de origen devolvió una respuesta **inválida**
503 Service Unavailable	El servidor o el intermediario	El servicio **no está disponible** temporalmente: sobrecarga o mantenimiento. Admite la cabecera `Retry-After`
504 Gateway Timeout	Un **intermediario**	El origen **no respondió a tiempo**

Lectura del caso: 502 seguido de 503 generalizado apunta a que **el servidor de aplicación de origen ha dejado de responder correctamente** y el proxy inverso ha pasado de recibir respuestas inválidas a declarar el servicio no disponible. Es un problema **del lado del servidor**, no del puesto, y procede escalarlo al equipo de la aplicación en lugar de intervenir en la oficina. Se valora señalar que **toda la familia 5xx es responsabilidad del servidor**, mientras que la **4xx** lo es del cliente.

- **C3**: (§5.1.2)
  - **Qué comprueba el navegador** al validar: (1) que la **firma** de cada eslabón sea correcta hasta llegar a una **AC raíz** de su almacén de confianza; (2) la **vigencia** (`notBefore` / `notAfter`); (3) que el nombre solicitado figure en la extensión `subjectAltName` ; (4) las **restricciones básicas** (que las intermedias puedan actuar como AC); y (5) el **estado de revocación** (CRL, OCSP o grapado).
  - **Causas posibles** del aviso: certificado **caducado** —la más frecuente—; **nombre no incluido** en el SAN (por ejemplo, se accede por la IP o por un alias); certificado **autofirmado** o emitido por una **AC interna** no instalada en el almacén del puesto; **cadena incompleta** (falta la intermedia); **fecha del sistema** del puesto desajustada; o, en el peor caso, **interceptación** por un intermediario.
  - **Respuesta al empleado**: **no**. Aceptar el aviso anula precisamente la garantía que aporta TLS, que es saber que se está hablando con quien se cree. Procede **identificar la causa** —comprobando el certificado y la fecha del puesto— y corregirla: renovar el

certificado, completar la cadena, distribuir la AC interna por directiva o corregir el nombre. Se valora relacionarlo con la mala práctica de «acostumbrar al usuario a aceptar avisos», que es la puerta de entrada de los ataques de intermediario.

- **C4**: (§3.2.2, §6.1.1)
  - **Medidas técnicas**: **DHCP snooping** en el conmutador de planta, admitiendo respuestas DHCP solo por los puertos declarados de confianza; **RA Guard** para el equivalente IPv6 (anuncios de encaminador falsos); **deshabilitar las tomas de red no utilizadas**; **autenticación de puerto 802.1X**; y **VLAN separada** para equipos ajenos al Ayuntamiento y para la zona de público.
  - **Medidas organizativas**: procedimiento de autorización previa para conectar equipos de terceros y registro de esas conexiones.
  - **Respaldo del ENS**: `mp.com.4`, «separación de flujos de información en la red», que exige segregar el tráfico y que las comunicaciones inalámbricas vayan en un segmento propio; `mp.com.1`, perímetro seguro; y `mp.eq.4`, otros dispositivos conectados a la red. Se valora citar también la dimensión de **trazabilidad** y la exigencia de **identificación única** de los usuarios.

Criterios de evaluación

Criterio	Puntos
Aísla el problema por capas y concluye que el fallo es de resolución de nombres, no de red	1,5
Propone comprobaciones pertinentes y relaciona la causa con el DHCP no autorizado	1,5
Interpreta correctamente 502 y 503 y los distingue de 500 y 504	1,5
Concluye que la incidencia es del lado del servidor y procede escalarla	1,0
Enumera qué comprueba el navegador al validar el certificado	1,5
Responde correctamente que no debe aceptarse el aviso y razona por qué	1,0
Propone DHCP snooping, RA Guard, 802.1X y segmentación	1,0
Ancla las medidas en `mp.com.4` y `mp.com.1`	1,0

Caso 3 — Correo suplantado y envío de un fichero con datos personales

Enunciado

Dos asuntos llegan el mismo día a la unidad TIC del Ayuntamiento:

Asunto A. Varias personas comunican que han recibido un correo aparentemente enviado desde `tesoreria@madrid.es` en el que se les reclama el pago urgente de una tasa mediante un enlace. El mensaje **no ha salido de los servidores municipales**. Al revisar la configuración del dominio se comprueba que:

- Existe un registro **SPF**, pero termina en `~all` (fallo blando).
- **No hay DKIM** configurado.
- Existe un registro **DMARC** con política `p=none`.

Asunto B. Un servicio del Ayuntamiento debe enviar cada noche a otro organismo un fichero con **datos identificativos y de contacto** de personas solicitantes de una ayuda. La propuesta del proveedor es publicar el fichero en un **servidor FTP anónimo** accesible desde internet, «porque es lo más sencillo y ya lo hacemos con otros clientes».

Cuestiones

Cuestión 1 — Análisis de la suplantación (3 puntos). Explique **por qué el atacante ha podido enviar ese correo** pese a existir SPF y DMARC, y qué papel juega cada uno de los tres mecanismos.

Cuestión 2 — Corrección propuesta (2,5 puntos). Indique la configuración concreta que propondría para los tres mecanismos y **en qué orden** la desplegaría para no bloquear correo legítimo.

Cuestión 3 — Transferencia del fichero (2,5 puntos). Valore la propuesta del proveedor y proponga una alternativa, distinguiendo con precisión las opciones seguras disponibles.

Cuestión 4 — Respaldo normativo (2 puntos). Cite las medidas del ENS y la normativa de protección de datos aplicables a ambos asuntos.

▾ Ver solución orientativa

Solución orientativa

- **C1**: (§3.1.1)

- La raíz del problema es estructural: **SMTP no autentica la cabecera `From`**, que es la que ve el destinatario. Cualquiera puede escribir ahí lo que quiera. Los tres mecanismos existen precisamente para tapar ese agujero, y cada uno hace una cosa distinta:

Mecanismo	Qué hace	Por qué no bastó aquí
SPF	Publica **qué servidores** pueden enviar con el dominio; se comprueba contra la **envuelta** (`MAIL FROM`), no contra el `From` visible	Termina en `~all` , un fallo **blando**: el receptor puede aceptar el mensaje marcándolo, y además SPF **no protege el `From` que ve el usuario**
DKIM	**Firma criptográficamente** cabeceras y cuerpo con una clave cuya pública se publica en el DNS	**No está configurado**: no hay ninguna firma que validar
DMARC	Exige el **alineamiento** entre el `From` visible y lo validado por SPF o DKIM, y fija la **política**	Está en `p=none` : solo **observa e informa**, no pide ninguna acción al receptor

- Conclusión que se espera: **SPF y DKIM por sí solos no impiden el fraude**, porque validan la envuelta o la firma, no lo que ve el usuario; es **DMARC** quien exige la coherencia y quien dice qué hacer, y con `p=none` no dice nada.
- **C2**: (§3.1.1)

1. **Inventariar todos los emisores legítimos** del dominio: servidores del Ayuntamiento, plataformas de notificación, herramientas de boletines, aplicaciones que envían avisos. Es el paso que se salta todo el mundo y el que provoca los bloqueos de correo legítimo.
2. **Configurar DKIM** en todos ellos y publicar la clave pública en su selector.
3. **Endurecer SPF** a `-all` (fallo duro), una vez comprobado que la lista de emisores está completa.
4. **Escalar DMARC progresivamente**: mantener `p=none` recibiendo **informes agregados** unas semanas, pasar después a `p=quarantine` con porcentaje creciente y terminar en `p=reject` , que es el objetivo.
5. Complementar con **MTA-STS** o DANE en el lado saliente y con filtrado antimalware y antispam en el entrante, además de **concienciación** del personal y de un canal para que la ciudadanía comunique correos sospechosos.

Se valora expresamente el **orden**: endurecer la política antes de tener DKIM y el inventario de emisores es la causa más frecuente de que se pierda correo legítimo.

- **C3**: (§3.1.2)
  - **La propuesta es inaceptable** y hay que rechazarla razonadamente: un **FTP anónimo** no autentica a quien accede, y **FTP transmite credenciales y datos en claro**. Un fichero con datos personales expuesto así es una **violación de seguridad** en potencia.
  - **Alternativa propuesta**: **SFTP** —subsistema de **SSH**, puerto **22**— con **autenticación por par de claves** y no por contraseña, acceso **restringido por dirección de origen**, cuenta de servicio con **mínimo privilegio** confinada a su directorio, **registro** de cada transferencia y **cifrado del propio fichero** además del canal, de modo que el dato siga protegido en reposo en el destino.
  - **Precisión que se evalúa**: distinguir **SFTP** de **FTPS**. FTPS **es FTP** envuelto en TLS y conserva sus dos canales, con los problemas de cortafuegos del modo activo; **SFTP no tiene ninguna relación con FTP**, usa un solo canal y es la opción preferible. Alternativas igualmente válidas: **HTTPS** con API autenticada, o los servicios de intercambio de la **red SARA** y las plataformas de intermediación de datos, que además evitan tener que enviar el fichero.
  - Conviene además cuestionar el propio envío: si el organismo destinatario puede obtener el dato por **intermediación**, lo correcto es **no transferir el fichero**, aplicando minimización.
- **C4**: (§6.1.1)

Asunto	Respaldo
Correo	`mp.s.1` — protección del correo electrónico, exigible en **las tres categorías**: protección de la información y de los **datos de encaminamiento**, y actuación frente a **correo no solicitado**, **código dañino** y **código móvil**, con normativa de uso y **concienciación**
Transferencia cifrada	`mp.com.2` (confidencialidad) y `mp.com.3` (integridad y autenticidad) del canal
Cifrado del fichero y del soporte	`mp.si.2` — criptografía en los soportes de información
Gestión de las claves SSH	`op.exp.10` — protección de claves criptográficas
Acceso de la cuenta de servicio	`op.acc.4` (proceso de gestión de derechos de acceso) y el **mínimo privilegio** del art. 20 del ENS
Datos personales	**Art. 5.1.f y art. 32 del RGPD** (seguridad del tratamiento), `mp.info.1` del ENS y, si hubiera exfiltración, la **notificación en 72 horas** de los arts. 33 y 34 del RGPD
Suplantación con perjuicio a la ciudadanía	Comunicación al **CCN-CERT** conforme a la gestión de ciberincidentes, y aviso público en los canales municipales

Criterios de evaluación

Criterio	Puntos
Explica que SMTP no autentica el `From` y que ahí está la raíz del problema	1,0
Distingue con precisión qué hace SPF, qué DKIM y qué DMARC	1,0
Identifica que `~all` y `p=none` son la causa concreta de que no se bloqueara	1,0
Propone la configuración correcta y, sobre todo, el **orden** de despliegue	1,5
Advierte del riesgo de endurecer la política sin inventario de emisores	1,0
Rechaza el FTP anónimo con argumentos técnicos	1,0
Propone SFTP con claves y distingue correctamente SFTP de FTPS	1,5
Cita `mp.s.1`, `mp.com.2` y `mp.si.2`	1,0
Relaciona el caso con el RGPD y con la notificación de violaciones	1,0

Fuentes

Tier 1 — Normativa y estándares

Normativa española y europea

ID	Referencia
`[ENS]`	Real Decreto **311/2022, de 3 de mayo**, por el que se regula el **Esquema Nacional de Seguridad** (BOE núm. 106, de 4 de mayo de 2022). En este tema se citan, verificadas contra el PDF del BOE: el art. 20 (mínimo privilegio y configuración de seguridad), el art. 22 y, del **anexo II**, las medidas `mp.com.1` (perímetro seguro), `mp.com.2` (protección de la confidencialidad), `mp.com.3` (protección de la integridad y de la autenticidad), `mp.com.4` (separación de flujos de información en la red), `mp.s.1` (protección del correo electrónico), `mp.s.2` (protección de servicios y aplicaciones web), `mp.s.3` (protección de la navegación web), `mp.s.4` (protección frente a la denegación de servicio), `mp.si.2` (criptografía), `mp.eq.4`, `op.acc.4`, `op.acc.5`, `op.acc.6` y `op.exp.10` (protección de claves criptográficas).
`[CCN-STIC-807]`	Centro Criptológico Nacional. *CCN-STIC-807: Criptología de empleo en el ENS*. Fija los **algoritmos y parámetros criptográficos autorizados** y sus longitudes de clave por nivel; es la guía a la que remiten `mp.com.2.r1` y `mp.com.3.r2`. Es la referencia correcta en un pliego, en lugar de congelar un número de RFC.
`[CCN-STIC-500]`	Centro Criptológico Nacional. Guías de **bastionado** de las series 500 y 600 (configuración segura por tecnología: servidores web, servidores de correo, DNS, SSH), exigidas por `op.exp.2` y por el art. 20.d del ENS.
`[L39-2015]`	Ley **39/2015, de 1 de octubre**, del Procedimiento Administrativo Común de las Administraciones Públicas. Derecho a relacionarse electrónicamente y obligación para las personas jurídicas (art. 14), sistemas de **identificación** (art. 9) y de **firma** (art. 10) y registro electrónico (art. 16).
`[L40-2015]`	Ley **40/2015, de 1 de octubre**, de Régimen Jurídico del Sector Público. **Art. 38 (sede electrónica)**: titularidad, gestión y administración de una Administración Pública, principios aplicables y comunicaciones mediante **certificado de sede electrónica**; **art. 39** (portal de internet); arts. 40-43 (sello electrónico y **CSV**); art. 41 (actuación administrativa automatizada); y **art. 156**, fundamento legal del ENI y del ENS.

ID	Referencia
`[RD203-2021]`	Real Decreto **203/2021, de 30 de marzo**, Reglamento de actuación y funcionamiento del sector público por medios electrónicos: sede electrónica y sede asociada, punto de acceso general electrónico, CSV y archivo electrónico único.
`[ENI]`	Real Decreto **4/2010, de 8 de enero**, por el que se regula el **Esquema Nacional de Interoperabilidad**, y sus **Normas Técnicas de Interoperabilidad**. Principio de **neutralidad tecnológica** y uso de estándares abiertos, relevante para la publicación de servicios en doble pila y para los formatos. Ver Tema 39.
`[RGPD]`	Reglamento (UE) **2016/679**, General de Protección de Datos. Art. 5.1.f (integridad y confidencialidad), art. **32** (seguridad del tratamiento) y arts. **33 y 34** (notificación de violaciones de seguridad: **72 horas**).
`[LOPDGDD]`	Ley Orgánica **3/2018, de 5 de diciembre**, de Protección de Datos Personales y garantía de los derechos digitales.
`[LSSI]`	Ley **34/2002, de 11 de julio**, de servicios de la sociedad de la información y de comercio electrónico. **Art. 22.2**: consentimiento para el uso de **cookies** no imprescindibles, con la AEPD como autoridad competente.
`[RD1112-2018]`	Real Decreto **1112/2018, de 7 de septiembre**, sobre **accesibilidad** de los sitios web y aplicaciones para dispositivos móviles del sector público (transposición de la Directiva (UE) 2016/2102). Norma **UNE-EN 301 549** y **declaración de accesibilidad** obligatoria.
`[NIS2]`	Directiva (UE) **2022/2555**, relativa a las medidas destinadas a garantizar un elevado nivel común de **ciberseguridad** en la Unión.
`[EIDAS2]`	Reglamento (UE) **2024/1183**, que modifica el Reglamento (UE) 910/2014 en lo relativo al **marco europeo de identidad digital**. Su **art. 45** y el anexo IV regulan los **certificados cualificados de autenticación de sitio web (QWAC)** y su reconocimiento por los navegadores; desarrollo técnico en la **ETSI TS 119 411-5** (modelos 1-QWAC y 2-QWAC).

Especificaciones del IETF (RFC)

ID	Referencia
`[RFC-ED]`	**RFC Editor**, *rfc-index*, y **RFC 2026** (proceso de estandarización) y **RFC 6410** (reducción a dos escalones: *Proposed Standard* e *Internet Standard*). Reglas de la serie: numeración inmutable, relaciones *obsoletes* y *updates*, categorías y serie **STD**.
`[RFC801]`	*NCP/TCP Transition Plan* (1981). Documento del plan de migración de ARPANET que fija el **1 de enero de 1983** como fecha de corte.
`[CERF-KAHN]`	V. Cerf y R. Kahn, *A Protocol for Packet Network Intercommunication*, IEEE Transactions on Communications (**1974**). Origen del protocolo TCP y de los principios de diseño de la interconexión de redes.
`[RFC1122]`	*Requirements for Internet Hosts — Communication Layers* (1989), y **RFC 1123**. Definición canónica del modelo **TCP/IP de cuatro capas** y ubicación de ARP.
`[RFC791]`	*Internet Protocol* (1981) y **RFC 792 (ICMP)**. Especificación de IPv4.
`[RFC8200]`	*Internet Protocol, Version 6 (IPv6) Specification* (julio de 2017, **STD 86**). Obsoleta el RFC 2460. Cabecera fija de 40 bytes, cabeceras de extensión, sin suma de control y fragmentación solo en el origen.
`[RFC4291]`	*IP Version 6 Addressing Architecture*. Tipos de dirección: unidifusión global, enlace local `fe80::/10`, únicas locales `fc00::/7`, multidifusión `ff00::/8` y anycast.
`[RFC1918]`	*Address Allocation for Private Internets* (**BCP 5**). Rangos **10.0.0.0/8**, **172.16.0.0/12** y **192.168.0.0/16**.
`[RFC6598]`	*IANA-Reserved IPv4 Prefix for Shared Address Space*. Rango **100.64.0.0/10** para **CGNAT**.

ID	Referencia
[RFC4632]	*Classless Inter-domain Routing (CIDR)*. Supresión del direccionamiento con clases y agregación de rutas.
[RFC3022]	*Traditional IP Network Address Translator (Traditional NAT)*. NAT y PAT.
[RFC6146]	*Stateful NAT64* y **RFC 6147 (DNS64)**; **RFC 6877 (464XLAT)**. Traducción entre IPv6 e IPv4. El antiguo **NAT-PT** (RFC 2766) fue declarado **histórico** por el **RFC 4966**.
[RFC6724]	*Default Address Selection for IPv6* y **RFC 8305 (Happy Eyeballs v2)**. Selección de protocolo en entornos de doble pila.
[RFC4271]	*A Border Gateway Protocol 4 (BGP-4)*. Único protocolo de encaminamiento **exterior** de Internet; funciona sobre **TCP/179** y es de **vector de caminos**.
[RFC1034]	*Domain Names — Concepts and Facilities* (noviembre de 1987). Jerarquía, delegación, zonas, resolución **recursiva** e **iterativa** y caché con TTL.
[RFC1035]	*Domain Names — Implementation and Specification* (noviembre de 1987). Formato de mensaje, tipos de registro, puerto **53**, uso de UDP y TCP y transferencias de zona.
[RFC6891]	*Extension Mechanisms for DNS (EDNS(0))*. Supera el límite histórico de 512 bytes del mensaje DNS por UDP.
[RFC4033]	*DNS Security Introduction and Requirements*, y **RFC 4034 y 4035**. **DNSSEC**: firma de los datos de la zona y cadena de confianza desde la raíz.
[RFC7858]	*Specification for DNS over Transport Layer Security (TLS)*. **DoT**, puerto **TCP 853**.
[RFC848	*DNS Queries over HTTPS (DoH)*. Puerto **443**.

ID	Referencia
`4]`	
`[RFC8659]`	*DNS Certification Authority Authorization (CAA) Resource Record*. Limita qué AC puede emitir certificados para un dominio.
`[RFC5321]`	*Simple Mail Transfer Protocol*. **SMTP**: envío y tránsito del correo.
`[RFC1939]`	*Post Office Protocol — Version 3* (**STD 53**). **POP3**.
`[RFC9051]`	*Internet Message Access Protocol (IMAP) — Version 4rev2* (2021). Obsoleta el RFC 3501.
`[RFC8314]`	*Cleartext Considered Obsolete: Use of TLS for Email Submission and Access*. Recomienda **TLS implícito** (465, 993, 995) frente a STARTTLS.
`[RFC2045]`	*MIME (Multipurpose Internet Mail Extensions)*, RFC 2045 a 2049. Adjuntos, juegos de caracteres y codificación **Base64**.
`[RFC7208]`	*Sender Policy Framework (SPF) for Authorizing Use of Domains in Email, Version 1*.
`[RFC6376]`	*DomainKeys Identified Mail (DKIM) Signatures* (**STD 76**).
`[RFC9989]`	*Domain-Based Message Authentication, Reporting, and Conformance (DMARC)* (**mayo de 2026**), junto con el **RFC 9990** (informes agregados) y el **RFC 9991** (informes de fallo). **Obsoletan el RFC 7489**, que era *Informational*, y elevan DMARC a *Standards Track*.
`[RFC8461]`	*SMTP MTA Strict Transport Security (MTA-STS)*. Exige TLS en el correo saliente hacia los dominios que lo declaran.

ID	Referencia
`[RFC959]`	*File Transfer Protocol (FTP)* (1985). Canal de **control (21)** y de **datos (20)**; modos **activo** y **pasivo**.
`[RFC4251]`	*The Secure Shell (SSH) Protocol Architecture*, y **RFC 4252** (autenticación), **RFC 4253** (transporte) y **RFC 4254** (conexión). **Puerto TCP 22**; base de **SFTP** y **SCP**.
`[RFC2131]`	*Dynamic Host Configuration Protocol*. **DHCP**: intercambio **DORA**, puertos **UDP 67 y 68**, concesiones y temporizadores T1 y T2.
`[RFC9915]`	*Dynamic Host Configuration Protocol for IPv6 (DHCPv6)* (**enero de 2026**, **STD 102**). **Obsoleta el RFC 8415**. Puertos **UDP 547 y 546**.
`[RFC4862]`	*IPv6 Stateless Address Autoconfiguration (SLAAC)*. Configuración **sin estado** a partir de los anuncios del encaminador.
`[RFC9110]`	*HTTP Semantics* (junio de 2022, **STD 97**). **Obsoleta los RFC 2818, 7230-7235, 7538, 7615 y 7694**. Métodos y sus propiedades de **seguridad** e **idempotencia**, códigos de estado, cabeceras y definición de **HTTPS** (§4.2.2).
`[RFC9111]`	*HTTP Caching* (**STD 98**). Directivas `Cache-Control`, validación condicional con `ETag` y `Last-Modified`, y respuesta **304**.
`[RFC9112]`	*HTTP/1.1* (**STD 99**). Sintaxis del mensaje, conexiones persistentes y transferencia por trozos.
`[RFC9113]`	*HTTP/2*. Protocolo binario, multiplexación de corrientes, compresión **HPACK** (**RFC 7541**) y priorización.
`[RFC9114]`	*HTTP/3*. HTTP sobre **QUIC**, con compresión **QPACK** (**RFC 9204**).
`[RFC9000]`	*QUIC: A UDP-Based Multiplexed and Secure Transport* (2021), con **RFC 9001** (uso de TLS en QUIC) y **RFC 9002** (detección de pérdidas y control de congestión). Establecimiento **1-RTT** y

ID	Referencia
`0]`	**0-RTT**, y **migración de conexión**.
`[RFC6265]`	*HTTP State Management Mechanism*. Cookies y atributos `Secure`, `HttpOnly`, `SameSite`, `Domain`, `Path`, `Expires` y `Max-Age`.
`[RFC3986]`	*Uniform Resource Identifier (URI): Generic Syntax*. Esquema, autoridad, ruta, consulta y fragmento.
`[RFC7301]`	*Transport Layer Security (TLS) Application-Layer Protocol Negotiation Extension (ALPN)*. Mecanismo por el que se negocia HTTP/2 dentro del saludo TLS.
`[RFC9846]`	*The Transport Layer Security (TLS) Protocol Version 1.3* (**julio de 2026**). **Obsoleta los RFC 8446 (TLS 1.3), 5246 (TLS 1.2), 5077, 6961, 7627 y 8422** y actualiza los RFC 5705 y 6066. Unifica la especificación y añade requisitos para las implementaciones de TLS 1.2. **Es la referencia vigente de TLS.**
`[RFC8446]`	*The Transport Layer Security (TLS) Protocol Version 1.3* (agosto de 2018). Versión histórica, **obsoletada por el RFC 9846**; se conserva la cita por ser la que recogen la mayoría de los temarios y la bibliografía.
`[RFC8996]`	*Deprecating TLS 1.0 and TLS 1.1* (2021). Declara **obsoletas** ambas versiones.
`[RFC7568]`	*Deprecating Secure Sockets Layer Version 3.0* (2015), y **RFC 6176** para SSL 2.0. **Prohíben** el uso de SSL.
`[RFC6797]`	*HTTP Strict Transport Security (HSTS)*. Cabecera `Strict-Transport-Security` y lista de **precarga**.
`[RFC5280]`	*Internet X.509 Public Key Infrastructure Certificate and CRL Profile*. Perfil del certificado **X.509 v3**, extensiones (**`subjectAltName`**, `keyUsage`, `basicConstraints`), validación de la **ruta de certificación** y **CRL**.
`[RFC6960]`	*X.509 Internet PKI Online Certificate Status Protocol (OCSP)*. Respuestas `good`, `revoked` y `unknown`; el **grapado** se define en la extensión `status_request` del **RFC 6066**.

ID	Referencia
`[RFC6962]`	*Certificate Transparency*. Registros públicos y auditables de los certificados emitidos.

Otros estándares

ID	Referencia
`[ISO7498]`	**ISO/IEC 7498-1**. *Modelo de referencia OSI*: siete capas, servicios y unidades de datos.
`[W3C]`	**World Wide Web Consortium**. Estándares de la Web: **HTML**, **CSS**, **DOM**, **XML**, **RDF**, **OWL** y **SPARQL** (Web Semántica) y las pautas de accesibilidad **WCAG**. Fundado por **Tim Berners-Lee** en octubre de 1994.
`[IEEE802]`	**IEEE 802**. Normas de las capas física y de enlace: **802.3** (Ethernet) y **802.11** (Wi-Fi), y **802.1X** (control de acceso a la red por puerto).
`[FIPS203]`	NIST. **FIPS 203 (ML-KEM)**, base del intercambio híbrido **X25519MLKEM768** empleado hoy en TLS. Su integración en TLS 1.3 se especifica en `draft-ietf-tls-ecdhe-mlkem`, aprobado y **pendiente de publicación como RFC en agosto de 2026**; el valor asignado por la IANA es **4588 (`0x11EC`)**.

Tier 2 — Informes, estadísticas y documentación de referencia

ID	Referencia
`[FNC]`	**Federal Networking Council**, resolución de **24 de octubre de 1995**, con la definición oficial del término «Internet»: espacio de direcciones único basado en IP, comunicaciones con TCP/IP y servicios de alto nivel superpuestos.
`[LEINER]`	B. Leiner, V. Cerf, D. Clark, R. Kahn, L. Kleinrock, D. Lynch, J. Postel, L. Roberts y S. Wolff, *Brief History of the Internet* (Internet Society). Relato de los protagonistas; desmiente expresamente el mito del origen antinuclear de ARPANET.
`[ICANN]`	**ICANN**. Modelo de múltiples partes interesadas, funciones **IANA** y su transición a **PTI** el **1 de octubre de 2016**, tras la expiración del contrato con la NTIA el 30 de septiembre de 2016; sistema de servidores raíz (**13 identidades**) y **RSSAC**.
`[RIPE]`	**RIPE NCC**. Registro regional de Europa, Oriente Medio y Asia Central. Agotamiento de IPv4: fase del **último** `/8` desde el **14 de septiembre de 2012** (una única asignación de `/22` por operador) y **agotamiento pleno el 25 de noviembre de 2019**, con lista de espera para direcciones recuperadas. La IANA había agotado su reserva libre el **3 de febrero de 2011**.
`[IETF]`	**IETF**. Estructura (grupos de trabajo, áreas, **IESG**, **IAB**, **IRTF**), funcionamiento por consenso aproximado y proceso de publicación de los RFC.
`[ITU2025]`	**UIT**, *Measuring Digital Development: Facts and Figures 2025* (noviembre de 2025). **≈ 6.000 millones** de personas usuarias de Internet (**74 %** de la población mundial), **2.200 millones** sin conexión (26 %), y brechas por renta, sexo y ámbito urbano-rural.
`[GOOGLE-IPV6]`	**Google**, *IPv6 Statistics*. Adopción medida sobre el acceso a los servicios de Google: supera el **50 %** por primera vez el **28 de marzo de 2026** (50,10 %). España se sitúa en torno al **10 %**.
`[CIDR]`	**CIDR Report** y mediciones de **APNIC**. Tamaño de la tabla global de encaminamiento: **más de 1.000.000** de prefijos IPv4 y ≈ **250.000** de IPv6; ≈ **80.000** sistemas autónomos activos (2026).
`[W3TECHS]`	**W3Techs**. Adopción de HTTP/3: ≈ **39,5 %** de los sitios lo anuncian (junio de 2026). La cifra mide **anuncio** (`Alt-Svc` o registro DNS HTTPS), no peticiones efectivamente servidas.
`[CHROME-`	**Google**, *HTTPS encryption on the web* (Transparency Report). **Más del 95 %** de las cargas de página en Chrome de escritorio y **más del 97 %** en Android se realizan por HTTPS (2026).

ID	Referencia
`TR]`	
`[CABF]`	**CA/Browser Forum**, *Ballot SC-081v3* (abril de 2025). Calendario de reducción de la validez máxima de los certificados TLS públicos: **200 días desde el 15-3-2026**, **100 días desde el 15-3-2027** y **47 días desde el 15-3-2029**, con reducción paralela de los periodos de reutilización de datos de validación.
`[LE-OCSP]`	**Let's Encrypt**. Fin del servicio **OCSP el 6 de agosto de 2025** por motivos de privacidad, sustitución por **CRL** y emisión de certificados de **seis días** de validez.
`[ESPANIX]`	**ESPANIX** (constituido el **13 de mayo de 1997**) y **DE-CIX Madrid** (2016). Puntos neutros españoles: ESPANIX registra picos por encima de **2 Tbps** con un crecimiento superior al 12 % interanual en 2026, y DE-CIX Madrid supera **1,5 Tbit/s**.
`[DOMINIOS-ES]`	**Red.es · Dominios.es**. Registro del ccTLD `.es` : **2.226.598** dominios registrados a **6 de agosto de 2026**.
`[DNSSEC-STATS]`	Estadísticas de despliegue de **DNSSEC** en la raíz: **1.348 de 1.437** dominios de primer nivel firmados (≈ **93,8 %**) a julio de 2026, frente a una adopción muy minoritaria en los dominios de segundo nivel.
`[ROOT-SERVERS]`	**root-servers.org** y RSSAC. **13 identidades** (A-M) operadas por **12 organizaciones**, desplegadas mediante **anycast** en más de **2.000 instancias** operativas (agosto de 2026).
`[MANRS]`	**MANRS** (*Mutually Agreed Norms for Routing Security*) y **RPKI** (RFC 6480 y siguientes), con objetos **ROA**. Contramedidas frente al secuestro de prefijos BGP y las fugas de rutas.
`[OWASP]`	**OWASP**, *Top 10*. Catálogo de riesgos de las aplicaciones web al que responden las cabeceras de seguridad y los atributos de cookie tratados en §4.2.2. Desarrollado en los Temas 23 y 25.

Tier 3 — Contexto municipal

ID	Referencia
`[MADRID-SEDE]`	**Ayuntamiento de Madrid**, sede electrónica `sede.madrid.es` y portal `madrid.es`. Supuesto de referencia empleado en todo el tema y en los tres casos prácticos.
`[BOAM-10032]`	**BOAM núm. 10.032**, bases específicas de la convocatoria de Técnico Auxiliar de Informática del Ayuntamiento de Madrid. Enunciado oficial del Tema 35 y de los temas con los que limita (33, 34, 36, 37 y 39).
`[SARA]`	**Red SARA** y **Punto de Acceso General electrónico**. Infraestructura de interconexión de las Administraciones españolas, alternativa a la transferencia directa de ficheros entre organismos.